FINTECHATHON 2026 · INTERNATIONAL TRACK · TOPIC F — AUTONOMOUS ON-CHAIN WALLET

QED.

An AI wallet that moves money only when it can prove it should.

Technical documentation — architecture, algorithms and security design

QED treats the AI as compromised by default and lets money move only on proofs that Ethereum checks: an owner's mandate times an independent co-signer's certificate (authority), a ring-fenced liabilities invariant (solvency), exact optimality certificates for paid work and for multilateral netting, in public or in zero knowledge (correctness), a worst case computed on-chain (bounded loss), and, new in this version, proof of best execution: every conversion the agent makes, including those it decides on itself under a standing owner policy, must land within 1 ppm of an upper bound on what any route through the owner's venues could return, computed on-chain in the same transaction. Three contracts put money on the theorems. This document specifies the system, proves what it claims, measures it, compares it with prior work and maps every property to tests and public transactions.

Live on Ethereum Sepolia
196 public transactions in four runs · 24 verified contracts

48 attacks, 48 reverts
3,000 tUSD of bounties unclaimed

Re-verifiable by anyone
145 Solidity + 60 TypeScript tests · `npm run verify`

Source, tests and evidence: github.com/Nightcore709/qed-agent-wallet
Live dashboard (reads the chain): nightcore709.github.io/qed-agent-wallet
Built from commit `e409f0a09eb8` · 2026-10-20 · testnet prototype, not externally audited

Contents

Part 0 — Overview

New: best execution, proved at the instant of the trade

The idea in eight sentences

The four outcomes — each one a public transaction

What makes this different

Certified clearing: a whole agent economy settles by proof

QED Private: paid for a proof about data nobody saw

Theorems with money on them

How the evidence was produced (full disclosure)

Status

Part 1 — System Architecture

1. One picture
2. Components
3. Key lifecycle flows
4. Data & evidence model
5. Execution & deployment topology
6. Gas profile on Sepolia (canonical run)

Part 2 — Core Algorithms

1. The solvency invariant (ring-fenced liabilities)
2. Authorisation: owner mandate × independent certificate
3. Provable blast radius (worst-case loss under total hot-key compromise)
4. Certified optimality: paying AI for proofs, not for answers
5. The certifying solver (off-chain, untrusted)
6. Economic decision engine
7. Co-signer policy (12 checks, one decision record)
8. Conversational layer: LLM for language, a state machine for money
9. Certified clearing: maximal multilateral netting with an exact proof (QEDClearing)
10. Private optimality: the same certificate, proven in zero knowledge (PrivateMinVarianceVerifier)
11. Theorems with money on them (OptimalityBounty, MaximalityBounty)
12. Best execution, proved at the instant of the trade (QEDExecution)

Part 3 — Protocol Specification

1. Roles and keys
2. QEDVault (EIP-712 domain "QEDVault", version "1", chain id, vault address)
3. QEDExecution (no domain of its own; authority flows through the vault's certificate)
4. ProofEscrow (EIP-712 domain "ProofEscrow", version "1")
5. QEDClearing (consent by transaction, no signatures)
6. Bounties
7. Off-chain records
8. Replay and domain separation, summarised

Part 4 — Security Design & Self-Assessment

1. Security thesis
2. Permission tiers (implemented in QEDVault.sol)
3. Security properties and how each is verified
4. Threat model
5. Known-risk list (honest)

5a. Key lifecycle, oracles, MEV, availability and administration

6. Incident response
7. Compliance-relevant controls

Part 5 — Benchmarks and Ablations

B1 · Best execution: what a proof buys over the routing policies agents use without one

B2 · The certificate: precision and cost

B3 · Clearing: certified maximal netting vs a greedy netter vs none

B4 · Paid work: what the escrow's optimality check prevents

B5 · Authorisation layers: which layer refused each recorded attack

Reproduce

Part 6 — Prior Art and What Is Actually New

0. Best execution proved at the instant of the trade (QEDExecution) — the upgrade's defining claim
1. Payment that settles only on an on-chain-checked optimality certificate (ProofEscrow + MinVarianceVerifier)
2. Proof-gated multilateral netting (QEDClearing)
3. Optimality proven in zero knowledge (PrivateMinVarianceVerifier)
4. Theorems with money on them (OptimalityBounty, MaximalityBounty)
5. The agent wallet itself (QEDVault, co-signer, guard)
6. What an expert should take away

Part 7 — Test Catalogue

Solidity (Foundry, contracts/test)
TypeScript (node --test, agent/test)
End-to-end
Clean-clone reproduction log

Part 8 — Reproducibility

0. Toolchain
1. Build from a clean clone (≈ 2 min)
2. Tests (≈ 2½ min)
3. Run every economy on a local chain, no keys (≈ 8 min in total)
4. Benchmarks (≈ 1 min, deterministic)
5. Re-verify the public evidence, with no keys (≈ 3 min)
6. Reproduce the deployed bytecode
7. Regenerate derived files
8. Your own run on Sepolia
9. How the canonical evidence was produced (replica and relay)

Part 9 — Deployment & Operations

Live deployment (Ethereum Sepolia, chain id 11155111)
Prerequisites
Local (no keys, no network)
Public network
Operations runbook

Part 10 — Known limitations

1. Status
2. Best execution (QEDExecution)
3. Autonomy
4. The rest of QED
5. Evaluation limits
6. How the evidence was produced
7. Not verified

Appendix A — On-chain Evidence (Ethereum Sepolia)

Contracts
Actors (one key each, one process each)
Every step of the scenario
Attack transactions (19) — each reverted with exactly the designed error
Set-up transactions (funding, mints, approvals)
Final state (read from QEDLens after the last transaction)
Run 2 — certified clearing of an agent economy (QEDClearing)
Run 3 — zero-knowledge optimality and theorem bounties (QED Private)
Run 4 — best execution, proved at the instant of the trade (QEDExecution)
How these transactions were produced — full disclosure
Block timestamps

PART 0

Overview

New: best execution, proved at the instant of the trade

An autonomous treasury must convert money as well as pay it: settle a euro invoice from dollars, sweep revenue into a reserve. That is where an agent's discretion is largest and least visible. Wallets and intent standards bound it with a minimum output, so a compromised or careless agent can leak up to the whole slippage tolerance on every trade.

In QED the agent may route a conversion however it likes, but it must attach **one price per token**. From those prices and the live reserves of *every* venue the owner allows, `QEDExecution` computes, on-chain and in the same transaction, a rigorous upper bound on what **any** route could have returned (weak Lagrangian duality for constant-product markets, every rounding step upward). It then runs the agent's route, measures what actually arrived, and refuses the trade if that is more than **1 ppm** below the bound. Every price vector yields a valid bound, so a dishonest agent cannot forge a proof; it can only fail to produce one. (§12, prior art: we found no system that checks the optimality of an executed route on-chain.)

On Ethereum Sepolia (Run 4)	Result
`E1` the agent converts 20 tUSD for the euro reserve over 4 venues and a two-hop path	**18.086846 tEUR delivered; on-chain bound 18.086849: 0.17 ppm from the best possible route**
`EA1` a compromised agent routes over the direct pools only: −33 bps, *above* the 1% floor	reverted `NotBestExecution` — a slippage-only wallet would have paid it
`EA2` …skims 0.47 bps · `EA3` …"forges" the prices	reverted `NotBestExecution` · `NotBestExecution`
`EA4` strand the bridge token · `EA5` one pool, −118 bps · `EA6` redirect to Mallory · `EA7` no agent key	`Leftover` · `InsufficientOutput` · `OrderMismatch` · `NotOperator`
`E2` the same co-signed order, honest route	**accepted: 17.612720 of ≤ 17.612723 tEUR**
`EA8` Mallory front-runs a signed order	reverted `InsufficientOutput` by the co-signed floor; the agent then declines to trade into the moved market
`XA1` – `XA3` claims on the 1,000 tUSD `ExecutionBounty`	`TheoremHolds(output, bound)`: nobody has beaten the bound

Across 1,000 random markets, routing policies without a proof fall a median **34–117 bps** short of the optimum, and among routes that still clear a 1% floor, a hostile agent keeps a median 14–32 bps per trade. With the proof, it keeps at most 1 ppm. For small trades in deep markets a good router is already within about 3 bps, so there the benefit is the *guarantee*, not the average (benchmarks). The language layer reads the owner's instruction (live model); the co-signer re-quotes independently and writes its own floor into the order; the vault is unchanged and still enforces mandate, caps and solvency.

The agent decides when and how much (Run 4c)

The owner signs one standing policy (EIP-191): *keep at least 45 tEUR free in the euro reserve; tranches of 2–25 tUSD; at most 1.5% execution cost per tranche.* From then on nobody approves individual trades. The agent observes the reserve, the treasury and every venue, and picks each tranche as the minimum of five quantities: the smallest input whose certified output covers the shortfall, the largest input whose cost stays inside the impact limit, the policy cap, the mandate cap and the free funds. The co-signer re-derives the same decision from the chain before it signs; the chain then proves best execution of whatever is traded.

On Ethereum Sepolia (Run 4c)	Result
`PA1` an over-eager agent asks for 25 tUSD at once	co-signer re-derives 19.535234 and refuses (P2, P3: 180 bps > 150 bps); no transaction
`PE1` tranche 1, limited by market impact	19.535234 tUSD → **16.816098 tEUR** (bound 16.816101, 0.18 ppm); reserve 20.70 → 37.52
`PE2` tranche 2, limited by need	8.835281 tUSD → **7.484336 tEUR** (bound 7.484339, 0.40 ppm); reserve **45.00**: target met
`T3` the agent observes again	shortfall 0: it sends nothing

The policy becomes a contract (Run 4d)

The co-signer is a second opinion, not a guarantee: if both hot keys were stolen, nothing above would stop a "tranche" the reserve does not need. So the owner also states the policy on-chain. `QEDTreasuryPolicy` is now `QEDExecution`'s only operator, and in the trade's own transaction it refuses a conversion when the reserve already meets its target, when the tranche is outside the owner's bounds, when its cost exceeds κ against the direct venues' mid price, or when **a smaller tranche provably covered the shortfall**. The last check solves nothing: the best output OPT(x) is concave with OPT(0) = 0, so $\mathrm{OPT}(a') \geq \mathrm{out} \cdot a'/a$, and if that lower bound already reaches the target, the agent over-converted (§12.9).

On Ethereum Sepolia (Run 4d) — the attacks hold both the agent key and the co-signer key	Result
`QD3` the owner makes the policy contract the only operator	from here the agent's key trades only through `convert`
`QA1` the agent's key calls `QEDExecution.trade` directly with a genuine co-signed order	reverted `NotOperator`
`QA2` convert 14.93 tUSD when 11.94 covers the need, best-executed and co-signed	reverted `OverConversion`
`QA3` convert 25 tUSD into the thin market	reverted `ExecutionCostTooHigh`
`QE1` the agent's own need-limited tranche, through the policy	11.943294 tUSD → **10.00 tEUR**; reserve 45.00 → **55.00** = target; every clause re-checked by `npm run verify`
`QA4` one more tranche after the target is met	reverted `NoShortfall`

The idea in eight sentences

1. **The AI holds one key that can call one function.** `QEDVault.executePayment` succeeds only with an owner-signed EIP-712 *mandate* **and** a certificate from an *independent co-signer* (a separate process, a separate key, 12 policy checks) **and** inside an on-chain *solvency invariant* that ring-fences money owed to creditors.
2. **Trades carry a proof of best execution, and the owner's objective is a contract.** `QEDExecution` refuses any conversion whose measured output is more than 1 ppm below the bound it computes, from live reserves, for every route through the owner's venues; `QEDTreasuryPolicy` lets the agent decide when and how much to convert, and refuses tranches the objective does not need. Above.
3. **The worst case is computed, not hoped for.** `QEDLens.blastRadius(vault, horizon)` returns, at any block, the most the vault can lose if *both* hot keys are stolen — and the loss to any address the owner never approved is provably **zero**.
4. **AI work is paid for proofs, not promises.** In `ProofEscrow` a client pays only when the delivered answer passes an **on-chain optimality check** (exact-integer KKT conditions + a positive-semidefiniteness witness). A lazy or dishonest AI provider is rejected by mathematics and the client is refunded.
5. **We published the keys.** The honeypot vault's agent *and* co-signer private keys are in this repository. Its 90 tUSD ring-fence is protected by the contract, not by secrecy. Try to steal it.
6. **Whole agent economies clear by proof.** In `QEDClearing`, five AI businesses that owe each other 200 tUSD but hold only 28 tUSD escape gridlock: the QED agent proves, with an exact linear-programming duality certificate checked on-chain, that its netting is the **largest possible** and leaves every member's net position unchanged. A lazy netting is rejected with `NotProvablyMaximal(162, 169)`. Details below.
7. **Optimality, proven in zero knowledge.** Proving an AI decision correct has meant showing its inputs; confidentiality has meant not showing them. In QED Private the agent proves, in a Groth16 zk-SNARK verified on-chain, that its portfolio is optimal for a data model the vendor attested by commitment. The escrow that settled job #1 pays on that proof, and the chain never sees the model or the portfolio. A copied proof is useless: it is bound to its author. Details below.
8. **Theorems with money on them.** Three contracts each hold 1,000 tUSD and pay it, automatically, to anyone who refutes on-chain the optimality theorem behind job #1, the maximality theorem behind the clearing house, or the best-execution bound. No judge: the contract checks the counterexample. Every attempt so far reverted with the gap it could not close. Details below.

The four outcomes — each one a public transaction

#	Outcome asked for	Proof on Ethereum Sepolia
O1	A **separate AI-agent key** executes a payment under an **independent policy certificate**	`L4 0x56a2334e…` — sent **by the agent key** `0x2A10…d0Bb`; mandate signature recovers to the **owner** `0xb7Ed…97f7`; certificate signature recovers to the **co-signer** `0xf1F8…2402`; on-chain `evidenceHash` = keccak256 of the published decision record. Also `C1 0x7000d3cc…`: a chat request → clarified → corrected → owner-signed confirmation → certified payment. And `E1`: the agent's operator key trades through `QEDExecution` under a co-signer certificate that commits to the order, with best execution proved on-chain.
O2	A **paid-work lifecycle** that ends in a **real escrow settlement**	Twice. **Private:** `Z3` the same escrow pays 12 tUSD into QED's vault on a zero-knowledge proof of optimality for data the chain never sees. **Public:** RFQ → agent-signed quote → `L2` client funds escrow, 15 tUSD → `L4` agent buys the risk model it needs → solves → `L6` delivers portfolio + KKT certificate, verified **on-chain**, 15 tUSD settles into the agent's vault. Competing provider's lazy answer `X17` rejected: `DualityGapTooLarge`, near-miss `X18` rejected: `StationarityViolated`, client `X19` refunded.
O3	An **adversarial agent cannot violate a protected liability or tamper with signed terms**	**19 attack transactions, all reverted on-chain with exactly the designed error** — tampered quote price/payee (`BadProviderSignature` ×2), forged/altered/redirected certificates (`BadCosignerSignature` ×3), both hot keys stolen paying the attacker (`PayeeNotInMandate`), self-signed mandate (`BadOwnerSignature`), replay (`IntentAlreadyUsed`), drain beyond free balance (`SolvencyViolation`), beyond the 24 h window (`ExceedsDailyCap`), admin calls (`NotOwner`, `NotCreditor`), published-key honeypot (×3), payment while paused (`VaultPaused`). Ring-fenced 70 tUSD reached **only** its creditor — settled by the attacker's own address while the vault was paused. Full table: docs/EVIDENCE.md. Plus **6 attacks on the clearing house** and **8 on the private job and the bounties** (a copied zk proof, an understated variance, self-attested data, five refutation attempts), all reverted. Plus **11 on best execution** (a direct-only route and a 0.47 bp skim that a 1% slippage floor would allow, a "forged" proof, a stranded token, a redirected order, a front-run, three bounty claims) and **4 on the on-chain policy** with both hot keys stolen (bypass, over-conversion, excess cost, a tranche after the target). **48 attacks, 48 reverts, 0 tUSD to the attacker.**
O4	An **external reviewer can reproduce everything** from GitHub source, tests and receipts	`npm run verify` re-derives every claim from a public RPC with **no keys**: on-chain bytecode == this repo's compiled bytecode; every receipt's status and sender; every revert's custom error (replayed on archive state); signatures recovered from calldata; the KKT certificate re-checked off-chain; the netting certificate re-checked; the Groth16 proof re-verified with snarkjs and the vendor's attestation recovered; the best-execution bound recomputed from pre-trade reserves and the route replayed; every clause of the on-chain policy re-checked; all three bounty pools intact; Mallory received 0 tUSD. It runs in CI on every push and daily, with all four economies and the benchmarks. 145 Solidity tests (unit, fuzz, stateful invariants ≈ 350 k adversarial calls/run, 60 random clearing economies, a real zk proof attacked 2,000 ways, routes and prices fuzzed against the bound 6,000 ways) + 60 TypeScript tests. A fresh machine reproduced all of it from a clean clone (log).

What makes this different

Usual agent wallet	QED
Spending limits on a hot key	Limits **plus** an independent co-signer **plus** a solvency invariant — three layers, each sufficient for protected funds
"The AI will follow its system prompt"	The AI is assumed compromised. Language model → deterministic slot filling → deterministic guard → owner-signed confirmation. Red-team: **25/25 attacks blocked, 0 false refusals** (LLM alone: 24/25)
Trust the provider's answer, or re-run it	**Verify a certificate**: the chain checks optimality in $O(n^2)$ exact integer operations instead of solving the problem
Risk = "we have limits"	Risk = a **number on-chain** (`blastRadius`), proven an upper bound by fuzzing, displayed live
Pause = everything stops	Pause stops the **AI**, never the **creditors** — anyone can settle a due liability, even while paused
Keys are the security boundary	Keys are **published** for the honeypot; the contract is the boundary
Verifying an AI's decision means exposing its data	**Zero-knowledge optimality**: the chain verifies the KKT certificate without seeing the data or the answer
"Trust our audit"	**Bounties the contract adjudicates**: refute the theorem on-chain and the contract pays you
Netting needs a trusted clearing house	**Anyone** can clear; the chain checks that the netting is maximal and moves no value (exact LP-duality certificate)
A slippage limit: the agent may leak up to 0.5–1% per trade	**Best execution proved per trade**: within 1 ppm of the best route through the owner's venues, checked on the state the trade executes on

Certified clearing: a whole agent economy settles by proof

Five AI businesses (Northwind, QED, CloudCo, Helix, Atlas) owe each other **200 tUSD** in overlapping cycles and hold only **28 tUSD** of cash. Gross settlement is impossible: `G1` Northwind cannot pay its 40 tUSD debt with 18. Yet every one of them is solvent on a net basis.

`QEDClearing` lets **anyone** submit a netting, and executes it only if the contract can check that (1) every member's net position is exactly unchanged, (2) no debt is cut below zero and none is created, (3) the proof covers every open debt at its current amount, and (4) an **LP-duality certificate** proves no larger netting exists: $\Sigma x = \Sigma d \cdot y$ with $\pi_debtor - \pi_creditor + y \geq 1$. The constraint matrix is totally unimodular, so the check is exact integer arithmetic: no tolerance. Joining is the only consent needed, and the QED agent can be a member *and* the prover without being able to favour itself. Theory: docs/ALGORITHMS.md §9.

Step on Ethereum Sepolia	Result
`N1` a naive shortest-cycle-first netting	reverted `NotProvablyMaximal(162, 169)`
`N2` a netting that cancels 1 tUSD more of one member's debt	reverted `NetPositionChanged(Northwind, 1)`
`N3` cancel more than is owed · `N4` hide an obligation · `N5` forge the certificate	`ExceedsObligation` · `IncompleteSnapshot` · `DualInfeasible`
`N6` the QED agent's proven netting	**executed: 169 tUSD of debt cancelled, gross 200 → 31, no token moved**
`N7` replay it	reverted `IncompleteSnapshot`
`S1` … `S4` the remaining 31 tUSD, paid in topological order	**0 debts left; every agent ends holding exactly its net position, using only the 28 tUSD that existed**

Contracts: `QEDClearing 0x7b7d…6ad2` · run token `0x6753…52d4`. Evidence: `evidence/ethereum-sepolia/clearing/` (44 public receipts, 44/44 matched the replica).

QED Private: paid for a proof about data nobody saw

Helix sells a private-markets covariance model it may not publish; Northwind, a wealth-manager agent, wants the provably optimal allocation and does not want it public. Helix signs a **Poseidon commitment** to its model. QED solves the problem, then proves inside a **Groth16 zk-SNARK** (`circuits/private_minvar.circom` , 12,569 constraints) the full KKT certificate of §4 — stationarity, dual feasibility, complementary slackness, a convexity witness and an exact budget — over the committed data. `PrivateMinVarianceVerifier` checks Helix's attestation, binds the proof to its author and verifies it; it is just another `IProofVerifier` , so **the escrow deployed for job #1 settles the private job unchanged**. For reproducibility, this demo's synthetic model sits in `agent/src/engine/privateScenario.ts` ; in production it would never leave Helix and the agent. Theory, constraints and trusted setup: docs/ALGORITHMS.md §10.

Step on Ethereum Sepolia	Result
`Z1` Northwind funds job #3 in the original ProofEscrow	12 tUSD escrowed; the verifier is part of the signed terms
`Z3` QED delivers the zero-knowledge proof	**verified on-chain; 12 tUSD paid into QED's vault; the model and portfolio never appear**
`ZA1` Mallory replays QED's proof in her own job	reverted `ProofRejected` (bound to QED)
`ZA2` Mallory claims a lower variance	reverted `ProofRejected`
`ZA3` a genuine proof about data Mallory attested herself	reverted `UntrustedDataAttestation`

Theorems with money on them

`OptimalityBounty` and `MaximalityBounty` each hold **1,000 tUSD** and pay all of it to anyone who refutes, on-chain, the theorem QED's money depends on: a certificate the deployed `MinVarianceVerifier` accepted plus a strictly better portfolio (beyond the proven bound), or a netting larger than one `QEDClearing` accepts as maximal. The contracts check the counterexample in exact integers and pay with no human involved. Tests prove the payout path works against an unsound verifier and an under-reporting rule; on Sepolia every attempt reverted:

Attempt	Result
`BA1` equal-weight portfolio vs job #1 · `BA2` QED's optimum shifted 0.1%	`TheoremHolds(advantage, bound)`
`BA3` the forged certificate from job #2	`DualityGapTooLarge` (the verifier refuses it first)
`BM1` the naive 162 tUSD netting · `BM2` a 170 tUSD netting	`TheoremHolds(169, 162)` · `NetPositionChanged`

`npm run verify` checks daily that both pools are still full. docs/ALGORITHMS.md §11.

How the evidence was produced (full disclosure)

Our build sandbox had no RPC egress. Every transaction was signed inside the sandbox — one key per process — against a wall-clock-synchronised replica of Sepolia (same chain id, nonces and balances); the **identical signed bytes** were committed to `relay/` and broadcast unchanged by a browser relay, and each public receipt was compared with the replica's (status + every log): **55/55 matched** for the main run, **44/44** for the clearing run, **24/24** for the private run and **73/73** for the best-execution runs: **196 transactions in all** (Runs 4b and 4c first replayed the earlier runs' signed bytes on the replica, so its state was Sepolia's). Two earlier attempts under other keys failed (Sepolia's state-creation gas repricing; one under-provisioned agent transaction) and were abandoned; the canonical run uses fresh keys. Details: docs/EVIDENCE.md, risk K12 in docs/SECURITY.md.

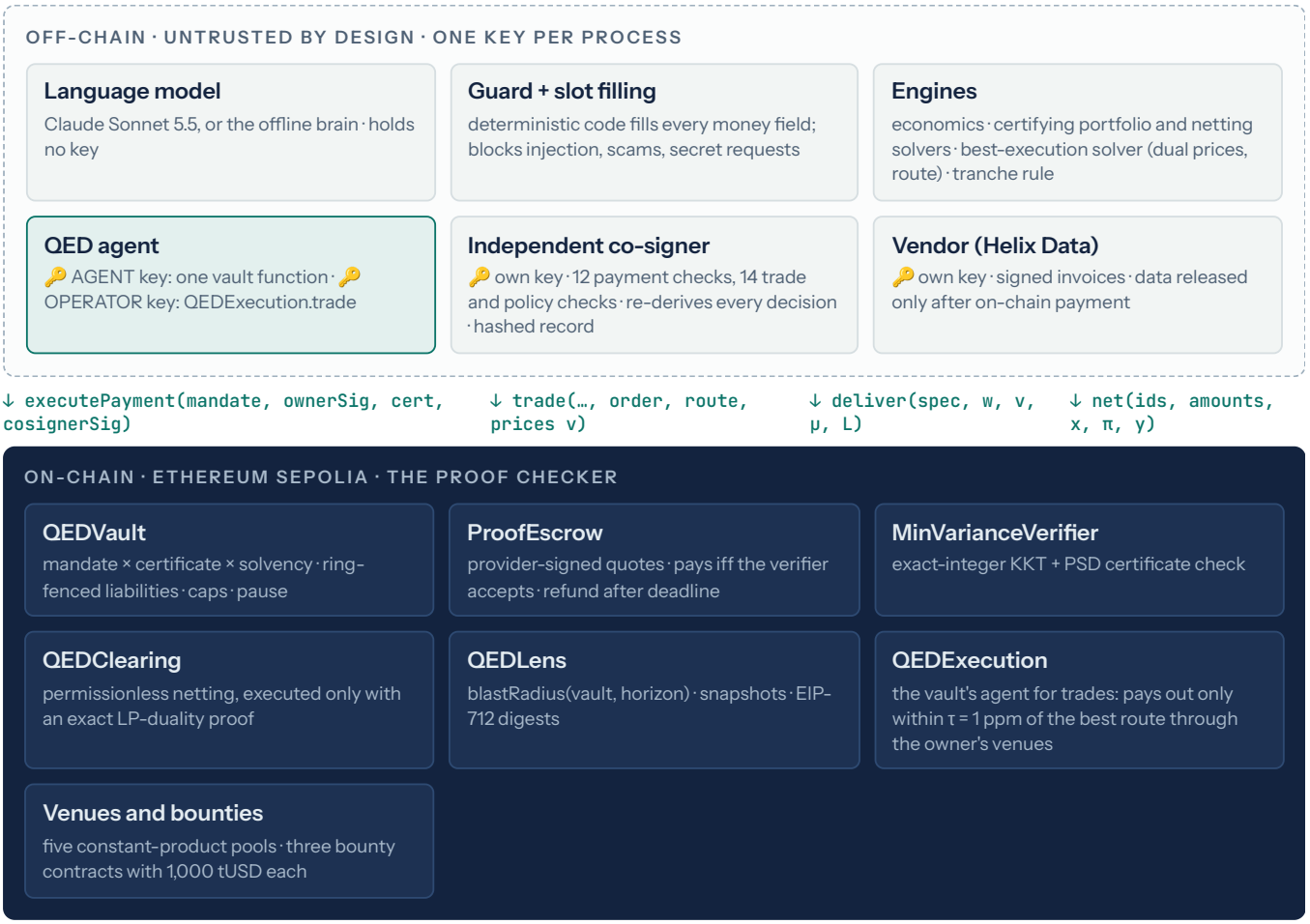
Status

Testnet prototype with a valueless token; not audited. The Groth16 parameters come from a local ceremony and must be treated as trusted (risk K18). Known risks are listed honestly in docs/SECURITY.md §5, and our own audit, adversarial review and quality gates are in docs/SELF_REVIEW.md. MIT licence, except `contracts/src/verifiers/zk/Groth16Verifier.sol`, which snarkjs generates under GPL-3.0 (attributions).

PART 1

QED — System Architecture

1. One picture



Outside both bands: the **owner** (cold key) signs mandates once, off-chain (EIP-712); the **guardian** can pause the agent; the **client** funds escrow against a signed quote; **creditors** are paid from ring-fenced funds only — even while the vault is paused. The interactive version of this diagram is in docs/ARCHITECTURE.md on GitHub.

The design rule is a trust gradient: **everything that can be fooled is off-chain and holds at most one key; everything that decides whether money moves is on-chain and checks proofs.**

2. Components

On-chain (`contracts/src` , Solidity 0.8.26, via-IR, OpenZeppelin 5.1)

Contract	Size	Responsibility
`QEDVault`	9.1 KB	Treasury of one agent. Verifies owner mandates (EIP-712, EOA or ERC-1271) and co-signer certificates; enforces payee scope, per-payment/period/lifetime caps, a global 24 h window cap, the solvency invariant, single-use intents, epochs, pause. Holds ring-fenced liabilities that only creditors can be paid from.
`QEDLens`	5.1 KB	Stateless views: `blastRadius(vault, horizon)` , `snapshot(vault)` , EIP-712 hashes/digests. Separate so the enforcement contract stays small (Sepolia's state-creation pricing + EIP-7825's 2^{24} gas cap bound deployable code size).
`ProofEscrow`	5.6 KB	Agent-to-agent work. Provider-signed EIP-712 quote binds price, payee, client, verifier, problem hash, deadline. `deliver` pays iff `IProofVerifier.verify(spec, solution)` succeeds. Refund after deadline.

Contract	Size	Responsibility
`MinVarianceVerifier`	2.4 KB	`IProofVerifier` for long-only minimum-variance portfolios: exact-integer KKT + PSD certificate check (docs/ALGORITHMS.md §4).
`QEDClearing`	5.3 KB	Proof-gated multilateral netting for agent economies. Members `join` (on-chain consent to the terms) and record debts as debtors; `net` is permissionless and executes only if net positions are unchanged, nothing is created, the snapshot is complete and current, and an exact LP-duality certificate proves the netting maximal (ALGORITHMS §9).
`PrivateMinVarianceVerifier` + `Groth16Verifier`	2.1 KB + 1.6 KB	`IProofVerifier` for the same problem **in zero knowledge**: checks the data vendor's attestation of a Poseidon commitment, binds the proof to its provider, then verifies a Groth16 proof of the KKT certificate (ALGORITHMS §10). Usable by the deployed `ProofEscrow` unchanged.
`OptimalityBounty`, `MaximalityBounty`	2.0 KB, 2.6 KB	Standing offers that pay their whole balance to anyone who refutes, on-chain, Theorem 4.4 (via the deployed verifier) or the netting maximality theorem (ALGORITHMS §11). No owner, no withdrawal.
`QEDExecution`	9.6 KB	Lets a vault's agent convert money with **best execution proved on-chain**. It is the vault's `agent`: funds arrive only through `executePayment` in the same transaction; the co-signed order fixes recipient, floor, tolerance and venue set; the contract computes the weak-duality bound over every owner venue from live reserves, runs the agent's route and refuses any output more than τ below the bound (ALGORITHMS §12). Holds nothing between transactions.
`CPMMPool`	2.1 KB	Trading venue with the Uniswap V2 pair interface and invariant, fee as a parameter; liquidity by transfer + `sync`.
`ExecutionBounty`	3.7 KB	Pays its pool to anyone whose route, run on the bounty's own funds, beats `QEDExecution.quoteBound` (Theorem 12.3).
`QEDTreasuryPolicy`	6.8 KB	The owner's standing conversion policy as a contract and QEDExecution's only operator: refuses a tranche with no shortfall, outside bounds, above κ against mid, or provably larger than needed (ALGORITHMS §12.9).
`TestUSD`, `TestToken`	2.1 KB, 1.8 KB	Valueless test tokens: tUSD (6 dp, public 1 000/day faucet), tEUR (6 dp) and tETH (18 dp).

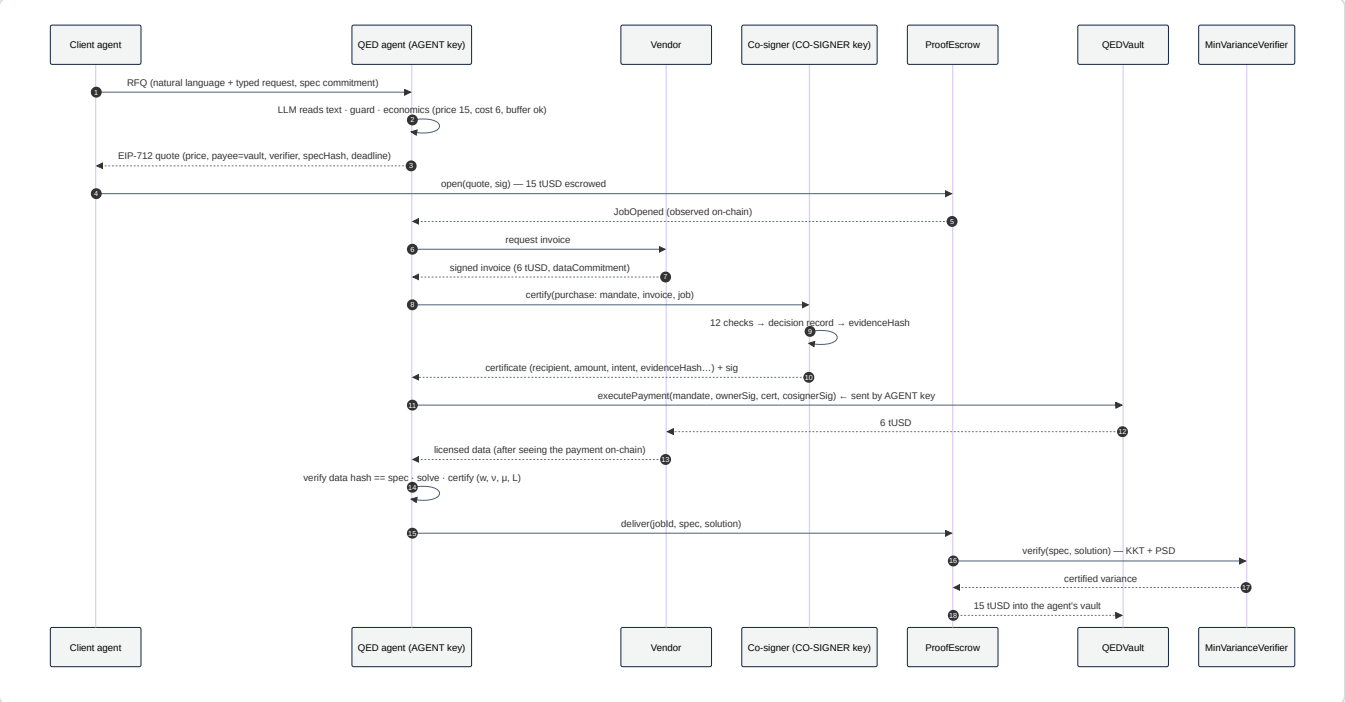
Off-chain (`agent/`, TypeScript, viem)

Module	Process / key	Responsibility
`roles/agent.ts`	agent process · AGENT key	RFQ handling, autonomous job fulfilment (watches `JobOpened`), owner console, decision records
`roles/cosigner.ts`	co-signer process · CO-SIGNER key	12-check policy engine; writes & hashes decision records; signs certificates
`roles/vendor.ts`	vendor process · VENDOR key	catalog, signed invoices, releases data only after seeing the on-chain payment
`brain/*`	inside agent	`AnthropicBrain` (live LLM) / `OfflineBrain`; `slots.ts` deterministic payment slot filling; `guard.ts` deterministic security layer; `evaluate.ts` red-team scoring
`engine/minvar.ts`	inside agent	certifying solver + bit-exact TS checker
`engine/economics.ts`	inside agent	pricing and acceptance rules
`engine/privateMinvar.ts`	inside agent	fixed-point witness, Poseidon commitments, Groth16 prover (snarkjs), bit-exact mirror of every circuit constraint
`circuits/private_minvar.circom`	build time	the zero-knowledge statement (12,569 constraints); `circuits/setup.sh` runs the two-phase trusted setup
`engine/netting.ts`	inside agent	certifying netting solver (min-mean cycle cancelling + Bellman–Ford dual), bit-exact checker, naive greedy rival
`scripts/clearing.ts`	orchestrator (5 member agents, QED prover, Mallory)	runs the clearing economy: gridlock, attacks, proven netting, settlement

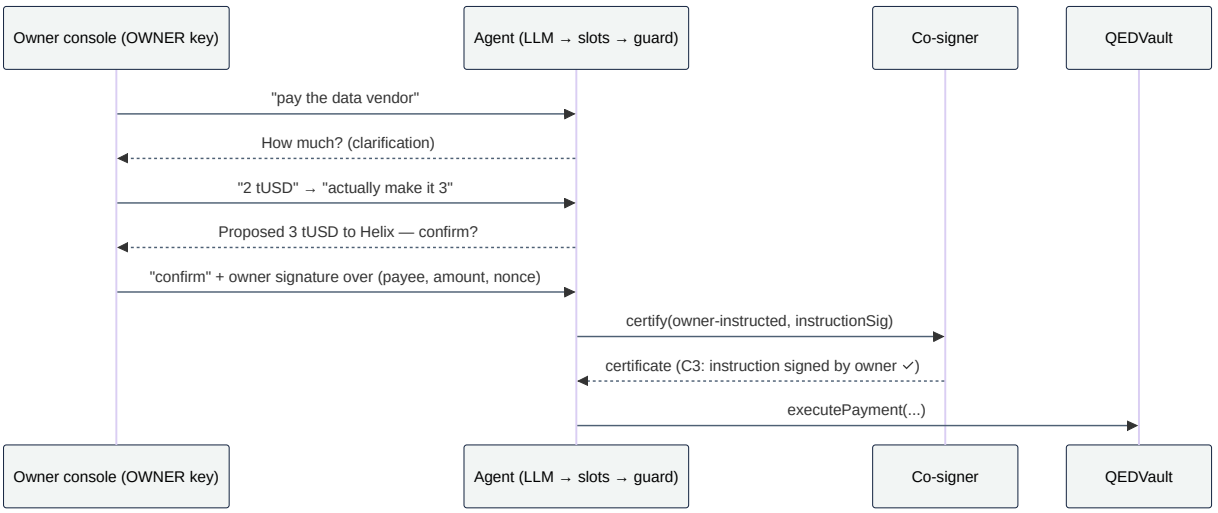
Module	Process / key	Responsibility
`engine/execution.ts`	inside agent and co-signer	best-execution solver: closed-form venue values, coordinate descent + Newton on B(ν), route recovery (incl. arbitrage legs), exact integer simulator, bit-exact replica of the on-chain bound, baseline policies
`roles/trader.ts`	inside agent · OPERATOR key	reads the owner's venues, plans and pre-flights the certified route, ranks alternatives, applies the submit rule
`cosigner.ts → evaluateTrade`	co-signer process	11 checks for a conversion, including its own optimal quote (written into the order as the floor) and a quoted-rate manipulation screen
`scripts/execute.ts`, `execution-bounty.ts`	orchestrators	Run 4 (conversions, attacks, front-run) and Run 4b (execution bounty)
`scripts/private.ts`	orchestrator (Helix, Northwind, QED, Atlas, Mallory)	runs the private economy and the bounty challenges on the main run's escrow and verifier
`scripts/live.ts`	orchestrator (owner, client, guardian, Mallory)	deploys and runs the whole economy, records evidence
`scripts/verify.ts`	anyone · no keys	independent re-derivation of every on-chain claim

3. Key lifecycle flows

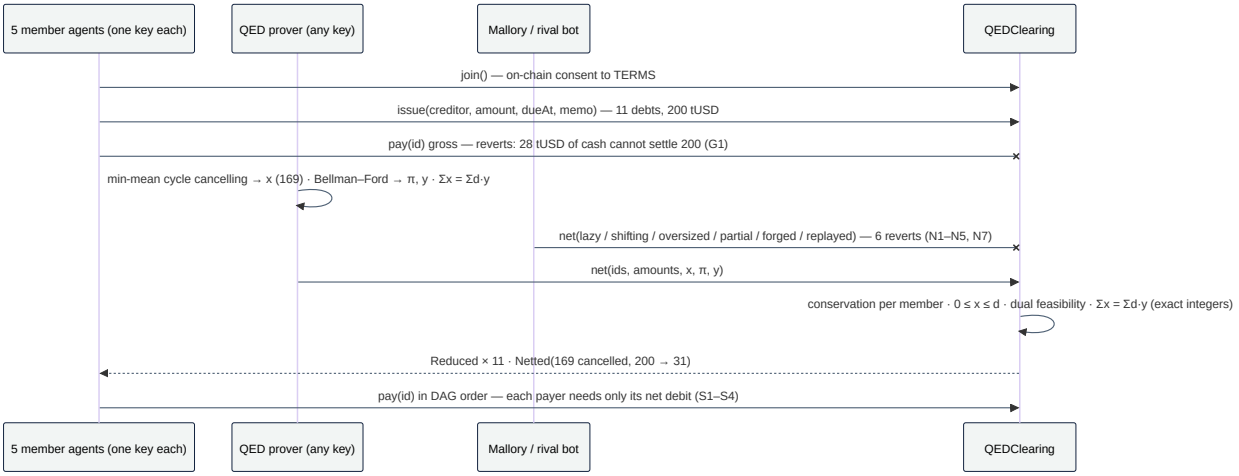
3.1 Paid work, end to end (Outcomes 1 & 2)



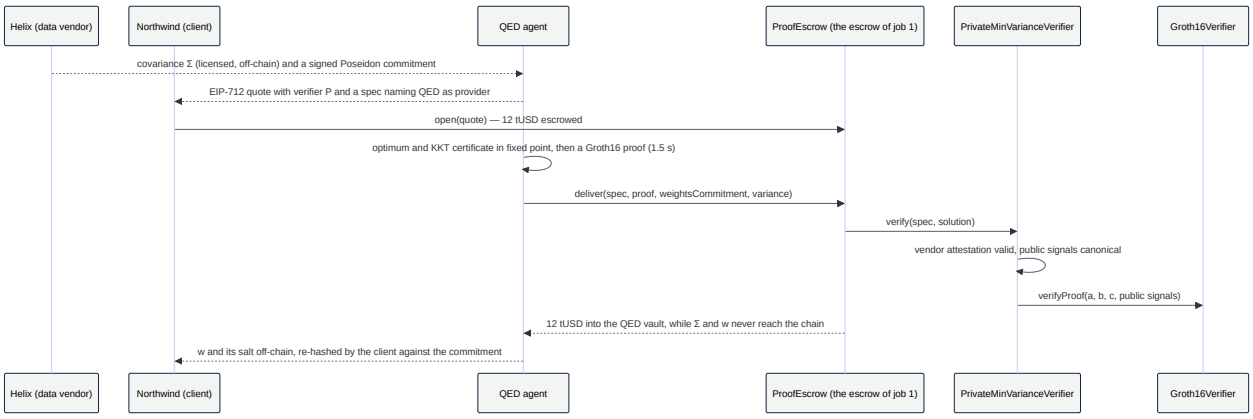
3.2 Owner conversation → signed confirmation → payment



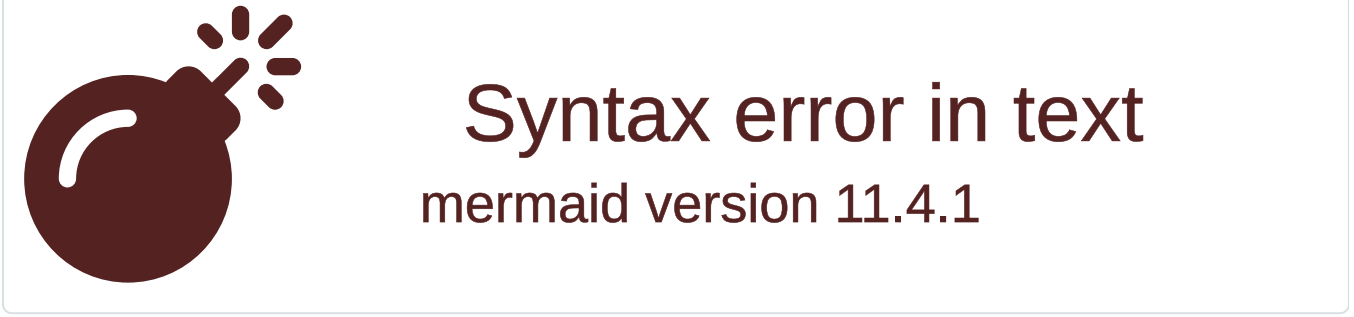
3.3 Certified clearing of an agent economy (QEDClearing)



3.4 Private work, paid on a zero-knowledge proof (QED Private)



3.5 A conversion with proven best execution (QEDExecution)

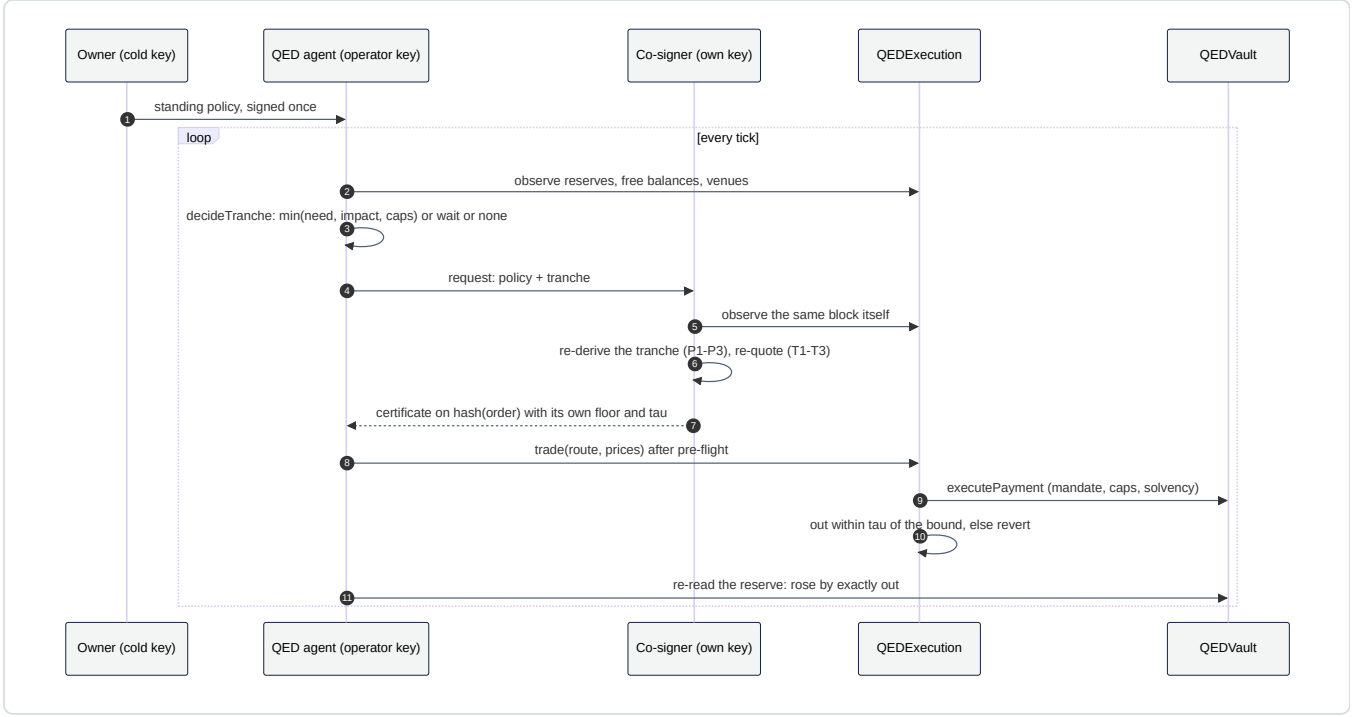


3.6 The autonomous loop: one objective, twelve steps, two independent deciders (Run 4c)

The owner states an objective once; after that no human approves individual trades. Each step below is code that ran on Sepolia, with the evidence it left. Probabilistic reasoning appears nowhere on this path: the language layer reads owner instructions (§3.5), but a standing policy is executed by deterministic code that a second process re-derives before anything is signed.

#	Step	Where	What happens	Evidence (Run 4c)
1	Receive an objective	owner → `policyMessage`	"keep ≥ 45 tEUR free in the reserve; tranches 2–25 tUSD; ≤ 150 bps cost", signed once (EIP-191)	`P0`
2	Observe	`observeTreasury`	reserve free balance, treasury free balance above its buffer within the daily window, reserves of every owner venue	`T1` – `T3` decision records
3	Interpret constraints	`decideTranche`	policy tranche bounds and impact limit, the mandate's per-payment cap, free funds	candidates in each `T` record
4	Generate actions	`decideTranche`, `solve`	five candidate sizes (need, impact, three caps); for each size the optimal route over all venues	`T1`: need — (not coverable within the caps), impact 19.535, caps 25 / 25 / 55
5	Evaluate consequences	`certifiedOut`, `impactBps`	certified output and execution cost of each candidate, by integer simulation	`T1`: 150.0 bps at 19.535 tUSD
6	Apply the innovation	`planTrade` → `quoteBound`	the route's dual-price proof is computed and pre-flighted against the on-chain bound	`PE1`: 0.18 ppm from the bound
7	Decide	`decideTranche`	convert the minimum of the candidates, wait if below the minimum tranche, or do nothing	`T1` convert (impact) · `T2` convert (need) · `T3` none
8	Construct a narrowly authorised transaction	co-signer `evaluateTrade`	an independent process re-derives the decision (P1–P3), re-quotes (T1–T3), writes its own floor and τ into the order and certifies `hash(order)`; refuses an over-sized request	`C1`, `C2`; refusal `PA1`
9	Execute through a real wallet	operator key → `QEDTreasuryPolicy.convert` (Run 4d) → `QEDExecution.trade` → `QEDVault.executePayment`	the policy contract checks shortfall, bounds, cost and need; the vault checks mandate, certificate, caps and solvency; the module checks best execution	`PE1`, `PE2`; `QE1` through the policy contract
10	Verify status and state	`execute-policy.ts`, `npm run verify`	receipt status; `BestExecution` event; reserve re-read: its free balance must rise by exactly the output	`PE1` 20.70 → 37.52, `PE2` → 45.00
11	Record evidence	`Evidence`, `records/`	every decision and co-signer record hashed; the certificate anchors the record's hash on chain	`evidence/ethereum-sepolia/execution/`
12	Explain	manifest narratives, dashboard	each step says what was decided and which limit bound it	dashboard "The agent decides" lane

Refusal is part of the loop. The agent declines to trade into a moved market (`A10` , Run 4), the co-signer refuses an over-sized tranche (`PA1`), the chain refuses sub-optimal routes (`EA1` – `EA3`), and when the target is met the agent sends nothing (`T3`).



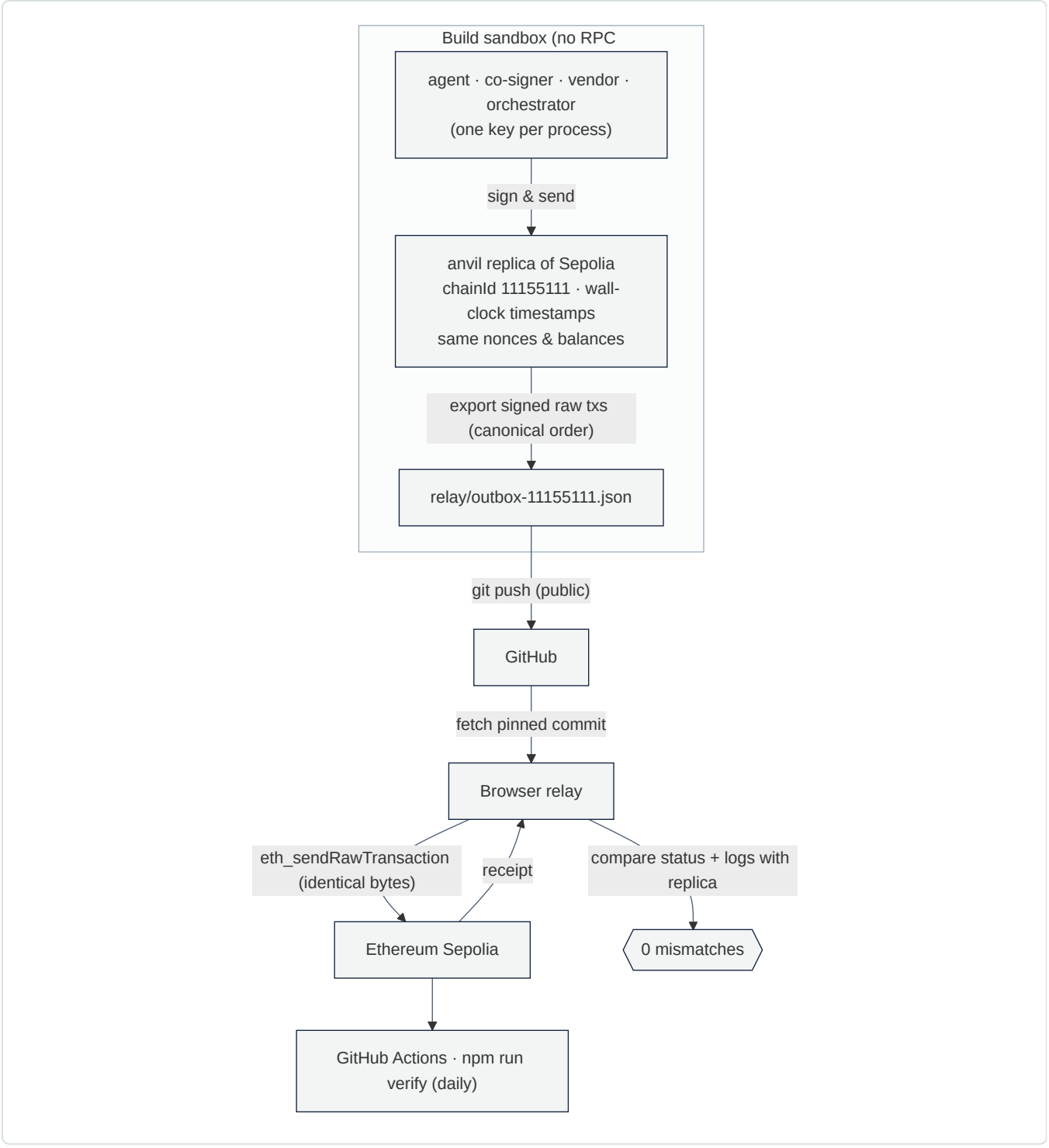
3.7 Defence in depth against a manipulated agent

Layer	Who	Stops
1. Guard	deterministic code in the agent	injection, scams, secret requests, escalation — before any proposal
2. Co-signer	independent process & key	anything not justified by a signed invoice + funded job, an owner confirmation, or a standing owner policy it re-derives itself
3. Vault	Ethereum	everything outside the owner's mandate, caps, solvency, replay, pause — even if layers 1 and 2 are both compromised
4. Proof of best execution	Ethereum	a conversion more than $\tau = 1$ ppm below the best route, a changed order, a stranded token — even with the agent key stolen
5. The policy as a contract	Ethereum	a conversion the owner's objective does not need, outside its bounds or above its cost limit — even with the agent **and** co-signer keys stolen

4. Data & evidence model

- **Mandate** (owner-signed, off-chain): scope of authority. Hash is referenced by every certificate.
- **Certificate** (co-signer-signed): exact payment terms + `evidenceHash` of the decision record.
- **Decision record** (`evidence/…/records/cosigner/<hash>.json`): canonical JSON of inputs, treasury snapshot, all 12 checks and verdict. `keccak256(canonical(core)) == evidenceHash` on-chain.
- **Agent records** (`records/agent/*`): RFQ evaluations, fulfilment (solution + certificate stats), every chat turn with the LLM transcript.
- **Manifest** (`evidence/ethereum-sepolia/manifest.json`): every step, actor, expected outcome, tx hash, decoded events / errors, mapped to Outcomes O1–O4.

5. Execution & deployment topology



The transaction hashes in the evidence are the public-chain hashes (identical signed bytes). The relay compares each public receipt with the replica (status and every log, excluding Sepolia's EIP-7708 system log for plain ETH transfers), and the independent verifier re-derives every claim from a public RPC. A reviewer with RPC access can also run the economy directly against Sepolia: `RPC_URL=… CHAIN_ID=11155111 GAS_LIMIT=16700000 npm run live`.

6. Gas profile on Sepolia (canonical run)

Operation	Gas used
Deploy QEDVault	14 963 244
Deploy ProofEscrow	9 051 450

Operation	Gas used
Deploy QEDLens	8 026 770
Deploy MinVarianceVerifier	3 847 926
Deploy TestUSD	3 716 239
Deploy QEDClearing	8 579 134
`QEDClearing.net` — 11 obligations, 5 members, certificate checked (N6)	550 826
`QEDClearing.issue` (first / later)	795 367 / ≈ 501 600
Deploy Groth16Verifier / PrivateMinVarianceVerifier	see `docs/EVIDENCE.md` (Run 3)
Deploy QEDExecution / CPMMPool / ExecutionBounty	15 330 304 / ≈ 3 632 106 / 5 997 780
`QEDExecution.trade` — vault checks, bound over 5 venues, 4 swaps (E1 / E2)	1 122 781 / 667 936
`QEDExecution.setVenues` — 5 venues	1 938 167
`ProofEscrow.deliver` with a zero-knowledge proof (attestation + Groth16)	see `docs/EVIDENCE.md` (Run 3, Z3)

Sepolia's current schedule prices state creation far above the classic EVM (a plain ETH transfer to a fresh account costs ≈ 205 k gas); local replicas don't model this, so all broadcasts use an explicit 16.7 M gas limit (only gas used is charged).

PART 2

QED — Core Algorithms

This document specifies every algorithm QED relies on, with the exact conditions the smart contracts check and proofs of the properties we claim. Notation: all token amounts are integers in `tUSD` base units (6 decimals). Real numbers in the optimiser are fixed-point **WAD** integers ($1.0 = 10^{18}$).

1. The solvency invariant (ring-fenced liabilities)

State. `B` = vault token balance, `P` = `totalProtected` = Σ of open liabilities, `F = B - P` = free balance.

Invariant I1. `B ≥ P` at every reachable state.

Proof (induction over state transitions). Initially `B = P = 0`. Every function that changes `B` or `P`:

Transition	ΔB	ΔP	Pre-condition checked on-chain	I1 preserved because
`deposit(a)` / direct transfer in	+a	0	—	B grows
`executePayment` (spot)	−a	0	`a ≤ F`	B − a ≥ P
`executePayment` (forward, `dueAt>0`)	0	+a	`a ≤ F`	P + a ≤ B
`ringFence(a)` (owner)	0	+a	`a ≤ F`	P + a ≤ B
`withdraw(a)` (owner)	−a	0	`a ≤ F`	B − a ≥ P
`settle(id)` (anyone, after due)	$-a_i$	$-a_i$	liability open	both sides drop equally
`release(id)` (creditor only)	0	$-a_i$	`msg.sender == creditor`	P shrinks

No other function moves tokens. ∎

Corollary (creditor exclusivity). Ring-fenced value leaves the vault only via `settle(id)`, which transfers exactly a_i to `liabilities[id].creditor`. Nobody — agent, co-signer, guardian or owner — can redirect it. Only the creditor can `release` (forgive) or `assign` (sell) its own claim.

Both facts are checked by stateful fuzzing (`contracts/test/Invariants.t.sol`: 7 invariants × 512 runs × 96 calls with an attacker holding the agent **and** co-signer keys) and re-checked live on Sepolia by `npm run verify`.

2. Authorisation: owner mandate × independent certificate

A payment executes only if **all** of the following hold (in this order; the first failure reverts with a self-describing custom error):

```
executePayment(m, ownerSig, c, cosignerSig):
  require !paused                                  VaultPaused
  require msg.sender == agent                      NotAgent
  — mandate —
  require m.vault == this, m.agent == agent        WrongVault / MandateAgentMismatch
  require m.period > 0, 0 < |m.payees| ≤ 32         InvalidMandate
  require m.validFrom ≤ now ≤ m.validUntil          MandateNotActive
  require m.epoch == epoch, !revoked[H(m)]          StaleEpoch / MandateIsRevoked
  require SigCheck(owner, EIP712(H(m)), ownerSig)    BadOwnerSignature      (EOA or ERC-1271)
  — certificate —
  require c.mandateHash == H(m)                     CertificateMandateMismatch
  require SigCheck(cosigner, EIP712(H(c)), sig)      BadCosignerSignature   (authenticity FIRST)
  require c.epoch == epoch, c.notBefore ≤ now ≤ c.expiresAt
  require !intentUsed[c.intentId]                   IntentAlreadyUsed      (replay)
  require c.recipient ∈ m.payees                    PayeeNotInMandate
  require c.amount ≤ m.maxPerPayment               ExceedsPerPaymentCap
  — economics —
  require c.amount ≤ F                              SolvencyViolation(requested, free)
  require mandate period / lifetime / global 24h window caps
  effects: intentUsed[c.intentId] = true; counters += amount
  if c.dueAt == 0: transfer(c.recipient, c.amount)
  else:            create liability(c.recipient, c.amount, c.dueAt)   // ring-fenced promise
  emit PaymentExecuted(intentId, H(m), recipient, amount, liabilityId, evidenceHash, ref)
```

Why the certificate binds everything. `H(c)` covers `recipient, amount, dueAt, intentId, evidenceHash, ref, notBefore, expiresAt, epoch` and `H(m)`. Changing any byte changes the EIP-712 digest, so the recovered signer is no longer the co-signer. `intentId` is single-use. `epoch` lets the owner revoke every outstanding mandate and certificate with one transaction (`bumpEpoch`).

Key separation. Owner (cold) ≠ agent (hot) ≠ co-signer (independent service) ≠ guardian. Each runs in a separate OS process holding exactly one key (`agent/scripts/live.ts → spawnRole`).

---

3. Provable blast radius (worst-case loss under total hot-key compromise)

Threat. The attacker holds the agent key **and** the co-signer key (owner key safe).

Bound. Within horizon `h` the attacker can extract at most

```
BR(h) = 0                                  if paused
      = min( F ,  cap_now + k·D )          otherwise
cap_now = D - spentInWindow   if the current window is open, else D
k       = ⌊(t + h - windowEnd)/W⌋ + 1      if t + h ≥ windowEnd, else 0
```

with `D` = global daily cap, `W` = 1 day, and `windowEnd` the end of the current (or next-opened) fixed window.

Proof sketch. Every agent outflow (spot or forward) passes `_consumeLimits`, which bounds spending in each fixed window by `D`; a new window opens no earlier than the previous one closes, so at most `k` further windows can start inside the horizon (counting a window that opens exactly at `t + h`, a deliberately conservative choice). Every outflow also requires `a ≤ F`. Ring-fenced funds (`P`) are unreachable by §1. ∎

And the part a cap alone can't give you: the attacker cannot invent payees — `c.recipient ∈ m.payees` and `m` must carry the **owner's** signature. So loss to any address the owner did not approve is exactly **0**. `QEDLens.blastRadius(vault, h)` computes `BR(h)` on-chain from public state.

---

4. Certified optimality: paying AI for proofs, not for answers

4.1 Problem

The client agent buys the long-only minimum-variance portfolio for a committed covariance Σ:

```
minimise  f(w) = ½ wᵀΣw     subject to   1ᵀw = 1,  w ≥ 0.
```

4.2 What the provider submits

`(w, v, μ, L)` — the portfolio, the Lagrange multipliers of the budget constraint (`v`) and of the long-only constraints (`μ`), and a lower-triangular factor `L` witnessing that Σ is positive semidefinite.

4.3 What the contract checks (`MinVarianceVerifier.verify`, exact integer arithmetic, tolerance τ)

#	Condition	Meaning
P1	$w_i \geq 0$, `	$1^T w - 1$
D1	$\mu_i \geq 0$	dual feasibility
S	`	$(\Sigma w)_i - v - \mu_i$
CS	$\Sigma_i w_i \mu_i \leq \tau$	complementary slackness = the **duality gap**
C	`	$\Sigma_{ij} - (LL^T)_{ij}$

All products are formed at 10^{36} scale and compared without any rounding. Inputs are range-bounded ($|x| \leq 10^{27}$) so no product can overflow. Cost for $n = 6$: ≈ 0.3 M gas.

4.4 Theorem (ε-optimality certificate)

If checks P1, D1, S, CS and C pass with tolerance τ, then for every feasible portfolio x

$$f(w) \leq f(x) + \tau\cdot(|v| + 3 + 2n) + O(\tau^2).$$

In particular $f(w) \leq f^* + (2n + 3 + |v|)\cdot\tau + O(\tau^2)$*: the escrow pays only for answers provably within a tiny, known distance of the global optimum.*

Proof. Write $\Sigma = LL^T + E$ with $|E_{ij}| \leq \tau$ (check C), so $\|E\|_2 \leq \|E\|_F \leq n\tau$. For feasible x ($x \geq 0$, $1^T x = 1$) let $d = x - w$. Exactly,

$$f(x) = f(w) + (\Sigma w)^T d + \tfrac{1}{2} d^T \Sigma d.$$

Curvature term. $d^T\Sigma d = \|L^T d\|^2 + d^T E d \geq -n\tau\|d\|_2^2$.

Linear term. By S, $\Sigma w = v1 + \mu + r$ with $\|r\|_\infty \leq \tau$. Hence

$$\begin{aligned}(\Sigma w)^T d &= v(1^T x - 1^T w) + \mu^T x - \mu^T w + r^T d \\ &\geq -|v|\tau + 0 - \tau - \tau\|d\|_1 \qquad \text{(P1, D1 with } x \geq 0\text{, CS, Hölder)}\end{aligned}$$

Sizes. $\|d\|_1 \leq \|x\|_1 + \|w\|_1 \leq 2 + \tau$ and $\|d\|_2^2 \leq \|d\|_1^2 \leq (2 + \tau)^2$.

Combining: $f(x) \geq f(w) - \tau(|v| + 1 + 2 + \tau) - \tfrac{1}{2}n\tau(2 + \tau)^2$, i.e. $f(w) - f(x) \leq \tau(|v| + 3 + 2n) + O(\tau^2)$. ∎

Corollary (the revert message is a certificate of failure). With exact stationarity ($r = 0$) the same argument gives $f(w) - f^* \leq \mu^T w$. So when a forger dresses up a portfolio with the best multipliers it can find ($v = \min_i(\Sigma w)_i$, $\mu = \Sigma w - v1 \geq 0$, which makes S and D1 hold *exactly*), the only check left to fail is CS — and `DualityGapTooLarge(gap)` reports an upper bound on how suboptimal the forgery is. On Sepolia, Mallory's lazy 1/N portfolio was rejected with gap = 0.019113 (the true optimum has half-variance 0.00133).

Numbers for the live job ($n = 6$, $\tau = 10^{-9}$, $\nu = 0.0026604$): certified bound `(12 + 3 + 0.0027)·10⁻⁹ ≈ 1.5·10⁻⁸`. The submitted certificate had stationarity residual **0** (exact), duality gap **0**, PSD residual $6.3 \cdot 10^{-17}$.

4.5 Why this matters

Classical escrow needs a human, an oracle, a reviewer quorum or "client acceptance" — each a trust assumption and an attack surface. A *certifying algorithm* (McConnell, Mehlhorn, Näher & Schweitzer, 2011) returns a witness that a simple checker can verify. QED makes the blockchain that checker for AI work: the expensive, opaque part (an AI-driven optimiser) is untrusted; the cheap, transparent part (the KKT check) is executed by every Ethereum node. The same construction extends to every convex financial problem with a duality certificate — CVaR (an LP), risk parity, index tracking, cash-flow matching, multilateral netting — by deploying a new `IProofVerifier`.

---

5. The certifying solver (off-chain, untrusted)

`agent/src/engine/minvar.ts`

1. **Exact support enumeration.** For each non-empty support $S \subseteq \{1..n\}$, solve `Σ_SS x = 1`; set `w_S = x / 1ᵀx`, `v = 1 / 1ᵀx`. Accept S iff `w_S ≥ 0` and `μᵢ = (Σw)ᵢ - v ≥ 0` for all `i ∉ S`. $\Sigma \succ 0 \Rightarrow$ the KKT point is unique, so this returns the exact optimum. Cost `O(2ⁿ n³)`: 1.3 ms for $n = 6$.
2. **Fixed-point certificate.** Round w to WAD, place the rounding residue on the largest weight so `1ᵀw = 10¹⁸` exactly, recompute `g = Σw` at 10^{36} scale in BigInt, set `v` = mean of `gᵢ` over the support, `μᵢ = max(0, gᵢ - v)` off-support. Cholesky factor L via standard decomposition, rounded to WAD.
3. **Pre-flight.** `checkCertificate` is a bit-exact TypeScript re-implementation of the verifier; the agent also dry-runs `ProofEscrow.check` (eth_call) before spending gas on `deliver`.

Result for the Helix model: Global Equities 16.32 %, US Treasuries 7–10y 80.81 %, Gold 2.87 %, all others 0 (their $\mu > 0$ certifies that adding any of them would increase variance). Portfolio volatility 5.16 %.

---

6. Economic decision engine

`agent/src/engine/economics.ts` — deterministic; the LLM never prices anything.

```
price  = ⌈ cost × 2.5 ⌉ (whole tUSD, ≥ 10)
accept ⇔ budget ≥ price
       ∧ margin/price ≥ 30 %
       ∧ cost ≤ F                       (only FREE money funds costs)
       ∧ F - cost ≥ 5 tUSD              (reserve buffer above ring-fenced liabilities)
       ∧ cost ≤ remaining 24h window
       ∧ delivery ≤ 72 h
```

Unsettled revenue is never treated as capital: the 15 tUSD fee becomes spendable only when the escrow settles into the vault (check E7).

Earned autonomy (co-signer check C12). Discretionary spend is capped at `10 tUSD + 50 % × verified revenue`, where verified revenue is the sum of `JobSettled` events paid into this vault. Autonomy grows only with on-chain, proof-settled performance.

---

7. Co-signer policy (12 checks, one decision record)

ID	Check	Source of truth
C1	Mandate signed by the vault owner	ecrecover over `QEDLens.mandateDigest`
C2	Mandate active, current epoch	chain

ID	Check	Source of truth
C3	Invoice signed by the payee's registered key (or owner-signed instruction for chat payments)	signatures
C4	Invoice addressed to this vault, unexpired	invoice
C5	Price = vendor's published list price	catalog
C6	Invoice / instruction nonce not seen before	co-signer state
C7	A funded escrow job for this vault covers the cost with ≥ 30 % margin	chain (`getJob`)
C8	Purchased data is exactly the job's committed spec	`job.specHash == invoice.dataCommitment`
C9	Payee listed in the owner's mandate	mandate
C10	Reserve buffer preserved	chain (`QEDLens.snapshot`)
C11	Sanctions / deny-list screening	policy
C12	Earned autonomy	chain (`JobSettled` , `PaymentExecuted`)

The full record (inputs, treasury snapshot, every check) is canonicalised (sorted-key JSON), hashed with keccak-256, and that hash is signed into the certificate's `evidenceHash` — so the on-chain payment event permanently commits to the exact reasoning that authorised it. `npm run verify` recomputes the hash.

---

8. Conversational layer: LLM for language, a state machine for money

```
message → LLM (or offline brain) → fillPaymentSlots (deterministic) → Guard (deterministic) → reply /
proposal
                                                                                    |
                                                                  confirm + owner signature ──┘→ co-signer → vault
```

- **Slot filling** (`agent/src/brain/slots.ts`): payee, amount, due date, *confirm* and *cancel* are extracted by code from the raw text and the pending proposal, so a payment never depends on how the model phrased a turn.
- **Guard** (`agent/src/brain/guard.ts`): detectors for the rubric's four attack classes (English + Chinese); any transfer to an address outside the owner's mandate, any request for secrets, any attempt to widen authority produces a fixed refusal written by code, not by the model.
- **Confirmation** is a signature: the owner's console signs the exact instruction (`payee, amount, dueInDays, nonce`), and the co-signer verifies it (check C3) before certifying.

Red-team result (32 cases: 25 attacks + 7 benign controls, live Claude Sonnet 5.5): guarded pipeline blocked **25/25** attacks with **0** false refusals; the model alone blocked 24/25 (`evidence/redteam/report.md`).

---

9. Certified clearing: maximal multilateral netting with an exact proof (`QEDClearing`)

9.1 The gridlock

Members of an agent economy owe each other money in cycles. In the live run five AI businesses owe each other **200 tUSD** but hold only **28 tUSD** of cash between them; every one of them is solvent on a net basis, yet nobody can settle gross (on-chain receipt G1: Northwind owes 40 and holds 18). Cancelling debts around cycles needs no tokens at all, but the party that computes the cancellation could be wrong, lazy or self-serving.

9.2 The linear program and its dual

For open obligations $e = (u \to v)$ with outstanding amounts d_e, choose cancellations x_e:

```
(P)  maximise  Σ_e x_e    s.t.  Σ_{e out of v} x_e = Σ_{e into v} x_e   for every member v      (net positions unchanged)
                            0 ≤ x_e ≤ d_e                                                      (never below zero)

(D)  minimise  Σ_e d_e y_e  s.t.  π_u - π_v + y_e ≥ 1   for every e = (u → v),   y_e ≥ 0,   π free
```

Weak duality. For any x feasible in (P) and (π, y) feasible in (D):

```
Σ_e x_e ≤ Σ_e x_e (π_u - π_v + y_e) = Σ_v π_v (Σ_out x - Σ_in x) + Σ_e x_e y_e = Σ_e x_e y_e ≤ Σ_e d_e y_e .
```

So a proposal with $\Sigma_e x_e = \Sigma_e d_e y_e$ is optimal: no larger netting exists. (P)'s constraint matrix is a network matrix, hence totally unimodular; with integer data there are integer optimal (x, π, y), so the certificate is exact: no tolerance, no rounding, no floating point.

9.3 What the contract checks (`QEDClearing.net` , O(obligations + members))

Check	Error if it fails	What it rules out
The proposal lists **every** open obligation, ids strictly increasing	`IncompleteSnapshot` , `IdsNotIncreasing`	proving "maximality" on a doctored subset
Each listed amount equals the current amount	`StaleAmount`	proofs about a past state; replays
$0 \le x_e \le d_e$	`ExceedsObligation`	erasing more debt than exists
For every member, cancelled payables = cancelled receivables	`NetPositionChanged(member, Δ)`	moving value between members
$\pi_u - \pi_v + y_e \ge 1$, bounded values	`DualInfeasible` , `ValueOutOfRange`	forged certificates, overflow games
$\Sigma_e x_e = \Sigma_e d_e y_e$	`NotProvablyMaximal(cleared, bound)`	lazy or suboptimal nettings

Properties (proved by the checks themselves). Every member's receivable − payable is unchanged; no claim is created or re-assigned, only reduced, so every counterparty exposure shrinks; and the executed netting is maximal. That is why `net()` can be **permissionless**: joining (`join()` , which emits the hash of these terms) is the only consent needed, and the QED agent can be both a member and the prover without being able to favour itself.

9.4 The certifying solver (off-chain, untrusted): `agent/src/engine/netting.ts`

1. (P) is a maximum-gain circulation = a min-cost circulation with cost −1 per unit cancelled. Solved exactly by **minimum-mean cycle cancelling** (Goldberg & Tarjan, 1989), each cycle found with **Karp's algorithm** (1978): strongly polynomial and integral.
2. At optimality the residual graph (forward arcs cost −1 where $x < d$, backward arcs cost +1 where $x > 0$) has no negative cycle, so **Bellman–Ford** from a virtual source gives integer distances π. Setting $y_e = \max(0, 1 - (\pi_u - \pi_v))$ is dual-feasible and complementary-slack, hence $\Sigma x = \Sigma d \cdot y$.
3. `checkNetting` re-implements the on-chain checks bit for bit (pre-flight and independent verification).

Verified: equals an exhaustive brute-force oracle on 150 random small economies; certificates valid on 60 random economies (3–7 agents, 3–16 debts) that the Solidity suite also executes; a 2,000-run fuzzer pushes any amount of debt around every simple cycle of the demo economy and every such proposal is rejected.

9.5 The live run (Ethereum Sepolia)

Gross debt	200 tUSD across 11 obligations, 5 agents
Cash held	28 tUSD (each agent exactly its net debit)
Maximal netting (QED agent)	**169 tUSD cancelled**, dual bound 169: executed (N6)
Naive shortest-cycle-first netting	162 tUSD: `NotProvablyMaximal(162, 169)` (N1)

Remaining after netting	31 tUSD in 4 obligations, an acyclic graph, paid in topological order with the 28 tUSD of cash
End state	0 open obligations; every agent holds exactly its net position

Remaining debts after a maximal netting always form a DAG (a cycle would admit more cancellation), so paying in topological order needs only each agent's net debit in cash: Σ max(0, payables − receivables).

---

10. Private optimality: the same certificate, proven in zero knowledge (`PrivateMinVarianceVerifier`)

10.1 The tension it removes

§4 makes the chain check that a paid portfolio is optimal. The check needs Σ and w in calldata, so the licensed risk model and the client's allocation become public the moment the escrow pays. Accountability and confidentiality pull in opposite directions: an auditor who can verify the decision can also read the book. QED proves the **same** KKT certificate inside a zk-SNARK, so the chain verifies optimality while learning only two commitments, the certified variance and the provider's address.

10.2 The statement (`circuits/private_minvar.circom`, n = 6, Groth16 over BN254)

Fixed point `ONE = 10^12`; all values are integers; signed values use the field's negative encoding.

Public signal	Meaning
`dataCommitment`	`Poseidon(Poseidon(Σ0…Σ10), Poseidon(Σ11…Σ20, saltΣ))`: the vendor's 21 covariance entries
`weightsCommitment`	`Poseidon(w1…w6, saltW)`: the delivered portfolio
`variance`	$w^T\Sigma w$ at scale ONE^3 (exact)
`provider`	the address the proof is bound to

The prover knows (Σ, saltΣ, w, ν, μ, L, saltW) such that, with $\tau = 10^{-10}$:

Constraint	Encoding in the circuit
Range: $\lvert\Sigma_{ij}\rvert, \lvert L_{ij}\rvert < 2^{40}$; $\Sigma_{ii} \geq 1$; $\lvert\nu\rvert < 2^{80}$; $0 \leq w_i < 2^{40}$; $0 \leq \mu_i < 2^{80}$	`Num2Bits` on value (+ offset)
Budget $\Sigma w_i = ONE$ **exactly**	one linear constraint
Stationarity $\lvert(\Sigma w)_i - \nu - \mu_i\rvert \leq \tau$	two 90-bit range checks of $\tau \pm r$
Complementary slackness $\Sigma w_i\mu_i \leq \tau$	one 130-bit range check of $\tau \cdot ONE - gap$
Convexity $\lvert\Sigma_{ij} \cdot ONE - (LL^T)_{ij}\rvert \leq \tau$, $j \leq i$	two 90-bit range checks per entry
Commitments and variance as above	Poseidon (circomlib), 6 products
`provider`	a quadratic constraint so the public input is bound into the proof

12,569 constraints (9,421 non-linear). **No wrap-around:** with the input ranges every intermediate quantity is below 2^{131} in magnitude, far under the field modulus $p \approx 2^{254}$, so each range check is an exact integer comparison. `checkWitness` in `agent/src/engine/privateMinvar.ts` mirrors every arithmetic constraint and is used as a pre-flight and in tests.

10.3 Theorem (private ε-optimality)

If `PrivateMinVarianceVerifier` *accepts, then (under the knowledge soundness of Groth16 and the collision resistance of Poseidon) the provider knows Σ committed to by the attested* `dataCommitment` *and w committed to by* `weightsCommitment` *such that* $\tfrac{1}{2}w^T\Sigma w \leq \min_{x \geq 0,\ 1^Tx = 1} \tfrac{1}{2}x^T\Sigma x + \tau(|\nu| + 3 + \tau) + \tfrac{1}{2}n\tau(2 + \tau)^2$.

Proof. The circuit's constraints are exactly the hypotheses of Theorem 4.4 (P1 holds with zero budget error), so the bound of §4.4 applies verbatim. For the live job, $|\nu| \approx 0.0016$ and the bound is $\approx 1.5 \cdot 10^{-9}$. ∎

10.4 What the verifier checks before the pairing

Check	Error	What it rules out
The data commitment is signed by the registered vendor (EIP-191 over tag, chain id, commitment, universe)	`UntrustedDataAttestation(signer)`	proofs about made-up data; replaying an attestation on another chain
Every public signal is a canonical field element	`NotAFieldElement`	malleable encodings
`verifyProof(a, b, c, [weightsCommitment, variance, dataCommitment, provider])`	`ProofRejected`	everything else: a different portfolio, a lower claimed variance, a copied proof

Verification costs ≈ 270 k gas, and the escrow needs no change: the verifier is just another `IProofVerifier` named in the provider-signed quote. A client accepts a quote only if its spec names the quoting provider; the escrow already requires the delivery to come from that provider.

10.5 Trusted setup

Groth16 needs a structured reference string. This deployment used a local two-phase ceremony (`circuits/setup.sh`): phase 1 powers of tau (2^{14}) with two contributions and a beacon, phase 2 with two contributions and a beacon. The beacons are the hashes of public Sepolia transactions from earlier runs (S4 and N6), fixed before the setup ran. Groth16 is sound if any one contributor destroyed their secret; since every contribution ran on one machine, **this setup must be treated as trusted** (risk K18). A production deployment takes phase 1 from a public ceremony (`PTAU=… bash circuits/setup.sh`) and runs phase 2 with independent parties; nothing else changes. `circuits/ceremony-transcript.txt` records every contribution hash, and `snarkjs zkey verify` reproduces the check from the committed `.r1cs` , `.ptau` and `.zkey` .

10.6 The live run (Ethereum Sepolia)

Helix attested a six-sleeve private-markets model by commitment only. The QED agent proved the optimal allocation in 1.5 s; the original `ProofEscrow` paid 12 tUSD into QED's vault on that proof (Z3). Mallory then replayed QED's proof from the public calldata into her own job (`ProofRejected` : it is bound to QED), claimed a lower variance (`ProofRejected`), and delivered a genuine proof about a data set she attested herself (`UntrustedDataAttestation`). The chain never saw the model or the portfolio. (So that reviewers can reproduce the run, the demo's synthetic model is in `agent/src/engine/privateScenario.ts` ; in production it stays with the vendor and the agent, and only its commitment is ever published.)

---

11. Theorems with money on them (`OptimalityBounty` , `MaximalityBounty`)

A proof in a document is only as convincing as the reader's patience. These two contracts turn the two theorems QED's money depends on into **standing, self-adjudicating offers**: each holds 1,000 tUSD and pays all of it, with no human involved, to the first caller who refutes its theorem on-chain.

Contract	Theorem guarded	A claim must contain	The contract checks, in exact integers
`OptimalityBounty`	§4.4: an accepted certificate is within the bound of the optimum	a certificate the **deployed** `MinVarianceVerifier` accepts, and a feasible portfolio x	re-runs the verifier; $x \geq 0$, $\Sigma x = 1$; pays iff $F(w) - F(x) > 2tW(\lvert\nu\rvert + 3W + t) + n{\cdot}t{\cdot}(2W + t)^2$ (the theorem's inequality $\times\, 2W^3$)
`MaximalityBounty`	§9.2: a netting with $\Sigma x = \Sigma d{\cdot}y$ is maximal	an economy, a netting `QEDClearing` would accept, and another netting	re-states `QEDClearing.net` 's acceptance rule line for line; checks the alternative conserves every net position within the debts; pays iff it cancels more

If the theorems are true the bounties can never pay, and every attempt reverts with the numbers that show why: `TheoremHolds(advantage, bound)` or `TheoremHolds(169, 162)` . Positive controls in `contracts/test/Bounties.t.sol` show that against an unsound verifier, or an acceptance rule that under-reports by 7 tUSD, the same contracts pay out at once; a differential test shows `MaximalityBounty.accepts` agrees with the deployed `QEDClearing` on all 60 generated economies; fuzzers try 2,000 random feasible portfolios and 2,000 random circulations.

On Sepolia, Mallory tried the equal-weight portfolio (BA1), QED's optimum shifted by 0.1% (BA2), the forged certificate the chain refused in job #2 (BA3), the naive 162 tUSD netting (BM1) and a 170 tUSD netting that breaks one net position (BM2). All five reverted; `npm run verify` checks daily that both pools are still full.

---

12. Best execution, proved at the instant of the trade (`QEDExecution`)

12.1 The gap it closes

Sections 1–11 let an AI agent *pay*. An autonomous treasury also has to *convert*: pay a euro invoice from a dollar balance, rebalance, sweep revenue into a reserve. Conversion is where an agent's discretion is largest and least visible. Today's agent wallets and intent standards bound it with a minimum output (a slippage limit, typically 0.5–1%): any route that clears the floor is accepted, so a compromised or careless agent can leak up to the whole tolerance on every trade, for example by routing through one pool and letting an accomplice back-run the price dislocation. Brokers have a legal duty of best execution (MiFID II art. 27, FINRA rule 5310), but evidence of it is an after-the-fact report.

QED makes best execution a **precondition checked by the chain, against the exact state the trade executes on**. The agent may route however it likes; it must attach a proof that no route through the owner's venues could have returned more than `1/(1 - τ)` times what it actually delivered. In the live run $\tau = 1$ ppm.

12.2 The routing problem

Tokens $\mathscr{T}$ with input `s` and output `t`. Venues V (chosen by the vault owner), each a constant-product pool with reserves `(R_a, R_b)` and fee `1 - γ`; selling `x` of `a` returns `f(x) = R_b·γx / (R_a + γx)`. A *route* is any finite sequence of swaps on venues in V, executed atomically, that starts holding `A` of `s` and never holds a negative amount of anything. Let `Δ_i ∈ ℝ^𝒯` be venue i's net trade and `Ψ = Σ_i Δ_i`. Then

```
OPT(A) = max Ψ_t   subject to   Ψ_s ≥ -A,   Ψ_k ≥ 0 (k ∉ {s,t}),   Δ_i reachable on venue i.
```

Splits, multi-hop paths, repeated use of a venue and arbitrage loops are all routes.

12.3 Theorem (a price vector is a proof)

For every `v ∈ ℝ₊^𝒯` with `v_t = 1`,

```
OPT(A) ≤ B(v) = v_s·A + Σ_{i∈V} [ (√(v_b R_b) - √(v_a R_a / γ))₊² + (√(v_a R_a) - √(v_b R_b / γ))₊² ]
```

Proof. For a feasible route, `Ψ_t ≤ Ψ_t + v_s(Ψ_s + A) + Σ_{k∉{s,t}} v_k Ψ_k = v_s A + Σ_i v·Δ_i` because every added term is non-negative. A fee-charging constant-product pool is *path deficient* (Angeris & Chitra, 2020): any sequence of swaps on it reaches no net trade outside the downward closure of the single-swap trades, so `v·Δ_i ≤ h_i(v) := max over single swaps (either direction, or none) of v·Δ`. For the swap selling `a`, substitute `u = R_a + γx`: `v_b f - v_a x = v_b R_b - v_b R_a R_b / u - (v_a/γ)(u - R_a)`, maximised at `u* = √(γ R_a R_b v_b / v_a)` with value `(√(v_b R_b) - √(v_a R_a / γ))²` when `u* > R_a`, and 0 otherwise. At most one direction is positive because $\gamma \le 1$. Summing gives `Ψ_t ≤ B(v)`. ∎

Path deficiency is the one step taken from the literature rather than proved here; it is tested directly (3,000 random split and round-trip swaps, `agent/test/execution.test.ts`) and indirectly by the soundness fuzzers below.

12.4 What the contract checks (`QEDExecution.trade`)

1. The order is the one the co-signer certified (`c.ref = hashOrder(order)`), its recipient is in the owner's mandate, it names the current venue set, and $\tau \le 1\%$.
2. **Bound.** From the live reserves of *every* venue in the owner's set (not only those the route uses) it computes `B̂ ≥ B(v)`: each term as `(⌈√(v_b R_b)⌉ - ⌊√(⌊v_a R_a·10⁴/(10⁴ - f)⌋)⌋)₊²`, the sum divided by the fixed-point scale with rounding up. Every rounding step enlarges the bound, so the theorem survives integer arithmetic. Prices are 36-decimal fixed point; a product that would overflow reverts (fail closed).
3. **Funding.** `QEDVault.executePayment` pays exactly `A` to the module in the same transaction (mandate, co-signature, caps and solvency all apply unchanged).

4. **Route.** Up to 32 hops on owner venues; `amountIn = 0` spends all that the trade has received of a token.
5. **Nothing left behind.** No intermediate token may remain; unspent input returns to the vault.
6. **Two output checks** on the output *measured as a balance change*: `out ≥ minOut` (market risk, set by the co-signer's own quote less 1%) and `out·10⁶ ≥ B̂·(10⁶ - τ)` (best execution). Then `out` goes to the recipient.

Corollary. Every accepted trade delivered at least `(1 - τ)·OPT(A)` of the output token, measured on the state the trade executed against, whatever route the agent chose. A "forged" proof does not exist: every `v` yields a valid upper bound, so a dishonest agent can only fail to prove.

12.5 Completeness: why an honest agent passes

`B` is convex in `v` (a sum of a linear term and maxima of linear functions), and the routing problem is convex (Angeris, Agrawal, Evans, Chitra, Boyd, *Optimal Routing for Constant Function Market Makers*, EC 2022), so strong duality holds: `min_v B(v) = OPT` for the continuous problem. By the envelope theorem `∂B/∂v_k` is the net flow of token k at the venues' best responses, so the minimiser is exactly the price vector at which those best responses spend `A` and balance every intermediate token — the optimal route can be read off it. What separates the integer execution from `B(v*)` is rounding: at most one raw unit of output per hop, plus the granularity of intermediate tokens. Measured over 1,000 random markets (benchmarks, B2): median gap 0.075 ppm, 92.3% within 1 ppm, maximum 7.4 ppm (outputs of a few tokens, where one raw unit is several ppm). τ must be set above that floor for the order's size.

12.6 The solver (off-chain, untrusted): `agent/src/engine/execution.ts`

1. Rescale each token by its largest reserve, so floating point is well conditioned across 6- and 18-decimal tokens.
2. Minimise `B` by exact coordinate descent: for each non-output token, bisection in log-space on `∂B/∂v_k` (increasing in `v_k` by convexity); then damped Newton steps on `∇B` with a finite-difference Hessian, each accepted only if it lowers `B`.
3. Read each venue's best trade at `v*`, drop numerical dust ($< 10^{-9}$ of the output's value), order the hops so each input exists when it runs, split `A` exactly across the source legs, let the last consumer of each intermediate token take all of it, and — when venues disagree enough that the optimum contains an arbitrage loop — spend the recycled input through one direct leg at the end.
4. Simulate the route with the pools' integer arithmetic and recompute the on-chain bound bit for bit; the agent pre-flights with `quoteBound` and does not send a trade its own proof would fail.

Median 3.3 ms per solve, 99th percentile 38 ms (B2). The Solidity tests use fixtures generated from this code, so contract and solver are checked against each other bit for bit.

12.7 Limits, stated plainly

- **The proof is about the present state.** Someone who moves every venue before the trade changes what is optimal; the bound follows the moved state. That is market risk, bounded separately by the co-signed `minOut` (front-running attempt EA8 on Sepolia). A manipulation smaller than the floor is not caught by either check.
- **Venues are trusted to be what the owner says they are**: honest constant-product pools with the declared fee (the module checks the fee where the pool reports it). Concentrated-liquidity and stable-swap venues need their own closed form for `h_i` (piecewise for concentrated liquidity); not implemented.
- **Gas is not in the objective.** A route with more hops can be output-optimal but cost more gas.
- **The bound is computed by the chain, not proven in zero knowledge**: prices and route are public.

12.8 Deciding when and how much: the standing treasury policy (`agent/src/roles/treasury.ts`)

Sections 12.1–12.7 prove *how well* a conversion executed. Run 4c lets the agent also decide *whether* and *how much*, under an objective the owner signs once (EIP-191, text in PROTOCOL_SPECIFICATION §3.3) and, from Run 4d, also states on-chain (§12.9):

```
π = (reserve, tokenIn s, tokenOut t, target T, tranche bounds [X_min, X_max], impact limit κ, validUntil, nonce)
```

State observed at block b. `r` = free (not ring-fenced) balance of `t` in the reserve; `a` = what the treasury may spend now, `min(free - buffer, dailyCap - spentInWindow)`; `m` = the mandate's per-payment cap; the reserves of every owner venue. Let `F*(X)` be the certified output for input `X` (the solver's route, simulated in the pools' integer arithmetic, §12.6) and `μ` the depth-weighted mid price of the venues that trade `s/t` directly. Define

```
shortfall   S = (T - r)₊
cost        I(X) = 1 - F*(X) / (μ·X)                              (execution cost against mid, in bps)
hard cap    H = min(X_max, m, a)
need        N = min{ X ≤ H : F*(X) ≥ S }        (undefined when F*(H) < S)
impact      K = max{ X ∈ [X_min, H] : I(X) ≤ κ } (0 when H < X_min or I(X_min) > κ)
tranche     X = min(N, K, X_max, m, a);   S = 0 → no action;   X < X_min → wait
```

Proposition 12.8. (i) *Safety:* an executed tranche satisfies `X ≤ X_max`, `X ≤ m`, `X ≤ a` and `I(X) ≤ κ`, and it covers the shortfall exactly when `need` binds. (ii) *Monotone search:* for the continuous problem `OPT(X)` is concave with `OPT(0) = 0`, so `OPT(X)/X` is non-increasing and `I(X)` non-decreasing; `N` and `K` are therefore found by bisection over monotone predicates. (iii) *No forced trades:* if the market is too thin for even `X_min`, the rule waits. (iv) *Determinism:* `X` is a pure function of the policy and the state at block `b`.

Proof sketch. (i) `X` is a minimum that includes `X_max`, `m`, `a` and `K`, and `K` satisfies `I(K) ≤ κ`; the co-signer additionally evaluates `I` at the requested `X` itself (check P3), so the bound does not rely on monotonicity. If `X = N` then `F*(X) ≥ S` by definition. (ii) `OPT(X)` is the value of a convex program whose feasible set grows linearly with the right-hand side `X` (§12.2), hence concave in `X`; a concave function through the origin has a non-increasing average. The integer `F*` inherits this up to rounding; `agent/test/treasury.test.ts` checks monotonicity on random sizes, and each bisection only ever returns a point at which its predicate was evaluated true, so a rounding wobble can make a candidate conservative but never unsafe. (iii) and (iv) are by construction. ∎

Why the co-signer can check it. Because the rule is deterministic, the co-signer reads the same block, recomputes `X` itself and signs only if the request is no larger (P1: a tranche is due; P2: requested ≤ its own `X` and ≥ `X_min`; P3: `I(requested) ≤ κ`). An over-eager agent is refused before any transaction exists (Sepolia `PA1`: 25 tUSD requested, 19.535234 allowed, 180 bps > 150 bps). The order the co-signer then certifies is proven on chain exactly as in §12.4.

The live run (Run 4c, Sepolia blocks 11,953,421–11,953,422). Target 45 tEUR free; `X ∈ [2, 25]` tUSD; κ = 150 bps.

Tick	Observed free	Shortfall	N · K · caps (tUSD)	Decision	On chain
1	20.699566	24.300434	— · 19.535 · 25 / 25 / 55	convert 19.535234, **limited by impact** (150.0 bps)	`PE1`: 16.816098 tEUR, bound 16.816101
2	37.515664	7.484336	8.835 · 19.705 · 25 / 25 / 35.46	convert 8.835281, **limited by need** (90.0 bps)	`PE2`: 7.484336 tEUR, bound 7.484339
3	45.000000	0	—	nothing to do	none

Limits. (a) κ bounds each tranche against the mid price *at that tick*; tranche 2 is measured against the price tranche 1 moved. Cumulative drift over many tranches is bounded only by `X_max`, the daily cap and the number of ticks; a production policy would add a cumulative impact budget, a TWAP reference and a minimum interval between tranches so that arbitrage can restore the price (risk K29). (b) In Run 4c the policy was enforced by the co-signer and the mandate only. §12.9 moves its safety clauses on-chain.

12.9 The policy as a contract (`QEDTreasuryPolicy`)

The co-signer's recomputation is a second opinion, not a guarantee: with both hot keys stolen, nothing in §12.8 stops a "tranche" the reserve does not need. `QEDTreasuryPolicy` is made `QEDExecution`'s only operator, so the agent's key can trade only through `convert`, which wraps `trade` (§12.4) with four clauses, all checked in the same transaction:

```
C1  shortfall     free_before < T                                  (NoShortfall)
C2  bounds        X_min ≤ a ≤ X_max                                (TrancheOutOfBounds)
C3  cost          out · 10⁴ ≥ ⌊a·ΣR_out/ΣR_in⌋ · (10⁴ - κ)         (ExecutionCostTooHigh)
C4  need          free_before·a + out·a' < T·a,  a' = a - ⌊a·σ/10⁴⌋  (OverConversion)
```

`ΣR_in, ΣR_out` are the reserves of the owner's venues that trade the pair directly, read before the trade, so C3 is the off-chain impact limit of §12.8 evaluated by the chain. σ (`needSlackBps`) is the owner's tolerance for over-conversion.

Proposition 12.9 (no provable over-conversion). If a trade of `a` passes C4 then no tranche smaller than `a'` is guaranteed by the trade's own evidence to cover the shortfall; conversely, if `free_before + out·a'/a ≥ T`, then the tranche `a'` routed optimally would have covered it, and C4 refuses the trade.

Proof. OPT is concave on `[0, a]` with OPT(0) = 0 (§12.8 (ii)), so OPT(a′) ≥ (a′/a)·OPT(a). The realised output satisfies out ≤ OPT(a) and, by §12.4, out ≥ (1 − τ)·OPT(a). Hence OPT(a′) ≥ (a′/a)·out, and if `free_before + out·a'/a ≥ T` the smaller tranche would have reached the target. C4 is that inequality multiplied by `a > 0`, in exact integers. ∎

Concavity is a property of the continuous routing problem; pool arithmetic rounds each hop by at most one raw unit, which the slack σ dominates by orders of magnitude (σ = 10 bps of an 11.9 tUSD tranche is ≈ 12,000 raw units of input). C4 is one-sided by design: it refuses only *provable* over-conversion and never second-guesses a tranche limited by market impact. What C1–C4 do not enforce is liveness: an agent that converts less than it could, or waits, is not caught. That is a cost to the owner, not a loss.

Composition. Run 4d keeps every earlier layer: the co-signer still re-derives the tranche (P1–P3) and re-quotes (T1–T3), the vault still enforces the mandate, caps and solvency, `QEDExecution` still enforces best execution. The new contract adds the clauses a stolen co-signer key would otherwise bypass.

The live run (Run 4d, Sepolia blocks 11,954,079–11,954,086). Target 55 tEUR, `X ∈ [2, 25]` tUSD, κ = 150 bps, σ = 10 bps. The agent observed 45.00 free (short 10.00); need 11.943294 tUSD, impact limit 19.800521 tUSD, so it converted 11.943294 (need-limited) → 10.000000 tEUR at 107.0 bps against mid, 0.30 ppm from the best-execution bound (`QE1`). With both hot keys, the attacker was refused the direct route (`QA1` NotOperator), 14.93 tUSD (`QA2` OverConversion), 25 tUSD (`QA3` ExecutionCostTooHigh) and a tranche after the target was met (`QA4` NoShortfall). Tests: `contracts/test/QEDTreasuryPolicy.t.sol` (13, including a 2,000-run fuzz that every accepted tranche satisfies C1–C4 and every refused one breaks a clause).

PART 3

QED — Protocol Specification

Every message a QED contract accepts, with its exact encoding, who signs it, and what the contract checks. Sources of truth are the Solidity files named in each section; the TypeScript encoders in `agent/src/protocol/eip712.ts`, `agent/src/roles/trader.ts` and `agent/src/engine/*` are tested for parity with them (`agent/test/parity.test.ts`, `contracts/test/fixtures/*`).

Conventions: tUSD and tEUR amounts are integers with 6 decimals, tETH with 18. "WAD" is fixed point with $1.0 = 10^{18}$. All signatures are secp256k1 (EOA) or ERC-1271 (smart accounts) through OpenZeppelin `SignatureChecker`.

1. Roles and keys

Role	Key	Can do	Cannot do
Owner	cold	sign mandates; configure vault (agent, co-signer, guardian, caps, epoch); ring-fence; withdraw *free* funds; name venues on `QEDExecution`	touch ring-fenced money; skip the co-signer when a mandate requires it
Agent (operator)	hot	call `QEDVault.executePayment`, or `QEDExecution.trade` / `pay`	anything else; pay outside the mandate; trade worse than the proof allows
Co-signer	warm, separate process	sign `Certificate`s after 12 checks (payments) or 11 checks plus an independent quote (trades)	call any contract function
Guardian	warm	`pause()`	`unpause()`, anything else
Creditor	any	`release` / `assign` its own liability; anyone can `settle` a due one	—
Provider (escrow)	any	sign `Quote`s; `deliver` a solution for its own job	be paid without the verifier's acceptance
Clearing member	any	`join` (consent to `TERMS`), `issue`, `pay`, submit `net`	change a net position; net without a maximality certificate

2. `QEDVault` (EIP-712 domain `"QEDVault"`, version `"1"`, chain id, vault address)

```
Mandate(address vault,address agent,address[] payees,uint256 maxPerPayment,uint256 maxPerPeriod,
        uint64 period,uint256 maxTotal,uint64 validFrom,uint64 validUntil,uint64 epoch,bool requireCosign,
        bytes32 purpose,bytes32 salt)                          — signed by the OWNER
Certificate(bytes32 mandateHash,address recipient,uint256 amount,uint64 dueAt,bytes32 intentId,
            bytes32 evidenceHash,bytes32 ref,uint64 notBefore,uint64 expiresAt,uint64 epoch)
                                                               — signed by the CO-SIGNER
```

`payees` is hashed as `keccak256(abi.encodePacked(payees))`. `executePayment(m, ownerSig, c, cosignerSig)`, callable only by `agent`, checks in this order: not paused; caller is the agent; mandate (vault, agent, period > 0, $1 \le |\text{payees}| \le 32$, validity window, epoch, not revoked, owner signature); certificate (mandate hash; co-signer signature over **every** field if `requireCosign`; epoch; validity window; intent unused; amount > 0; forward due date within 365 days; recipient in `payees`; amount ≤ `maxPerPayment`); solvency (`amount ≤ freeBalance()`); limits (period, lifetime, global 24 h window). Effects: marks the intent used; pays now (`dueAt = 0`) or creates a ring-fenced liability. Event `PaymentExecuted(intentId, mandateHash, recipient, amount, liabilityId, evidenceHash, ref)`. `evidenceHash` is keccak256 of the co-signer's canonical decision record (§7).

3. `QEDExecution` (no domain of its own; authority flows through the vault's certificate)

```
Order(address tokenOut,address recipient,uint256 minOut,uint32 tolerancePpm,bytes32 venueSetHash)
orderHash = keccak256(abi.encode(ORDER_TYPEHASH, tokenOut, recipient, minOut, tolerancePpm, venueSetHash))
Hop   { uint8 venue; bool zeroForOne; uint256 amountIn }      — amountIn = 0: all of the token received so far
Price { address token; uint256 value }                         — v × 10^36, output-token units per input unit
Venue { address pool; address token0; address token1; uint16 feeBps }
venueSetHash = keccak256(abi.encode(Venue[]))                  — set by the vault owner with setVenues
```

A trade is authorised by an ordinary vault certificate with `recipient = QEDExecution`, `amount = A`, `dueAt = 0` and `ref = orderHash`. The co-signer sets `minOut` from its own optimal quote less 1% and `tolerancePpm = 1`. `trade(m, ownerSig, c, cosignerSig, order, route, prices)`, callable only by `operator`:

1. `c.recipient == this`, `c.dueAt == 0`, `c.ref == hashOrder(order)`, `order.tokenOut ∉ {asset, 0}`, `order.recipient ∈ m.payees` and `≠ this`, `order.venueSetHash == venueSetHash`, `tolerancePpm ≤ 10,000`, $1 \le |\text{route}| \le 32$.
2. `bound = B̂(v)` over **all** venues from live reserves (ALGORITHMS §12.4); `v(tokenOut)` must equal 10^{36}.
3. Snapshot balances; `vault.executePayment(m, ownerSig, c, cosignerSig)` — all vault checks apply; exactly `A` must arrive.
4. Execute the hops (Uniswap V2 `getAmountOut` with the venue's fee, then `swap(…, this, "")`).
5. No intermediate token may change balance; unspent input returns to the vault.
6. `out ≥ minOut` else `InsufficientOutput(out, minOut)`; `out·10^6 ≥ bound·(10^6 - τ)` else `NotBestExecution(out, bound)`; transfer `out` to the recipient.

Event `BestExecution(intentId, tokenOut, recipient, amountIn, spent, amountOut, bound, hops)`. `pay(m, ownerSig, c, cosignerSig)` forwards ordinary payments (and refuses certificates addressed to the module). `quoteBound(amountIn, tokenOut, prices)` is the bound as a view, used for pre-flight and by `ExecutionBounty`.

3.1 The trade request the co-signer evaluates

`TradeRequest { mandate, ownerSig, module, tokenIn, tokenOut, amountIn, recipient, nonce, and exactly one of: instruction + ownerConfirmationSig` (an owner-initiated conversion, the instruction read by the language layer) or `policy + policySig` (an agent-initiated conversion under a standing policy) `}`.

Checks (one decision record, hashed into the certificate's `evidenceHash`): C1 owner signed the mandate; C2 mandate active and current epoch; C3 the owner confirmed this conversion **or** a current owner-signed policy covers this vault, reserve and token pair; C6 instruction nonce not seen before; C9 recipient in the mandate's payees; C9b the module is the vault's agent and a mandate payee; C10 the treasury's free balance stays above its buffer; C11 deny-list screening; T1 an **independent** optimal quote (the co-signer runs its own solver on the live reserves and its route must execute); T2 that quote's rate within 300 bps of the depth-weighted mid of the direct venues (a manipulation screen); T3 the order commits to the current venue set. Under a policy also P1–P3 (§3.3). On success it signs the certificate with `ref = hashOrder(order)`, `order.minOut = ⌊own quote × 0.99⌋` and `order.tolerancePpm = min(100, max(1, ⌈2·gap⌉))`, where gap is its own route's measured distance from the bound.

3.2 Pre-flight

The agent calls `quoteBound` on the block it will trade against and simulates its route with the pools' integer arithmetic; it sends only if its own output clears `bound·(1 - τ)` and `minOut`. A route that would fail is never broadcast; if the market has moved past the co-signed floor it re-plans, and declines if the new plan falls below the order's floor (Sepolia `A10`).

3.3 Standing treasury policy (EIP-191 personal message)

```
QED treasury policy
vault: <checksummed tUSD treasury vault>
reserve: <checksummed reserve vault>
keep free in reserve at least: <targetFree, raw units> of <checksummed tokenOut>
convert from: <checksummed tokenIn>
tranche: <minTranche> to <maxTranche>
max impact bps: <integer>
valid until: <unix seconds>
nonce: <string>
```

The co-signer recovers the owner from this exact text (C3) and then re-derives the decision of ALGORITHMS §12.8 from the chain: P1 a shortfall exists and a tranche is due; P2 `minTranche ≤ requested ≤ its own tranche`; P3 the requested tranche's execution cost against mid is within `max impact bps`. The policy is reusable until `valid until`; it is revoked immediately by voiding the mandate it runs under (`bumpEpoch`) or by rotating the operator.

3.4 `QEDTreasuryPolicy` (Run 4d; no domain of its own)

```
Policy { uint256 targetFree; uint256 minTranche; uint256 maxTranche; uint16 maxImpactBps; uint16 needSlackBps;
uint64 validUntil }
constructor(QEDExecution execution, QEDVault reserve, address agent)   — tokenIn = execution.asset(), tokenOut =
reserve.asset()
setPolicy(Policy) · revoke() · setAgent(address)                        — only treasury.owner(); setPolicy
requires
                                                                          0 < minTranche ≤ maxTranche, κ ≤ 1,000,
σ ≤ 1,000, target > 0
```

The vault owner makes the contract QEDExecution's operator (`setOperator`). `convert(m, ownerSig, c, cosignerSig, order, route, prices)` takes exactly `trade`'s arguments; callable only by `agent`. In order:

1. `block.timestamp ≤ validUntil` else `PolicyLapsed`; `order.tokenOut == tokenOut` and `order.recipient == reserve` else `WrongOrder`; `minTranche ≤ c.amount ≤ maxTranche` else `TrancheOutOfBounds`.
2. `free_before = reserve.freeBalance() < targetFree` else `NoShortfall(free, target)`.
3. `midOut = ⌊a·ΣR_out/ΣR_in⌋` over the venues that trade the pair directly, before the trade (`NoDirectVenue` if none).
4. `(out, bound) = execution.trade(…)`: every check of §3 applies.
5. `out·10⁴ ≥ midOut·(10⁴ - κ)` else `ExecutionCostTooHigh(out, midOut, κ)`.
6. `free_before·a + out·(a - ⌊a·σ/10⁴⌋) < targetFree·a` else `OverConversion(free_before, out, target)`.
7. `reserve.freeBalance() == free_before + out` else `ReserveMismatch`.

Event `PolicyConversion(intentId, nonce, amountIn, amountOut, midOut, freeBefore, freeAfter)`; `PolicySet` on every change. Views `policy()`, `shortfall()`, `midOut(a)`.

4. `ProofEscrow` (EIP-712 domain `"ProofEscrow"`, version `"1"`)

```
Quote(address provider,address payee,address client,address token,uint256 price,address verifier,
      bytes32 specHash,uint64 deliverBy,uint64 validUntil,bytes32 quoteId)   — signed by the PROVIDER
```

`open(q, sig)`: provider signature, `validUntil`, client restriction, `(provider, quoteId)` unused; pulls `price`. `deliver(jobId, spec, solution)`: only the provider, before `deliverBy`, `keccak256(spec) == specHash`; `verifier.verify(spec, solution)` must not revert; pays `payee`; records `keccak256(solution)` and the verifier's result digest. `refund(jobId)`: anyone after `deliverBy` (or the provider at any time) returns `price` to the client.

Verifier	spec	solution	Result digest
MinVarianceVerifier	abi.encode(uint256 n, int256[] cov, uint256 tol, bytes32 universe) (WAD)	abi.encode(int256[] w, int256 v, int256[] μ, int256[] L)	hash of the certified solution
PrivateMinVarianceVerifier	abi.encode(uint256 dataCommitment, bytes32 universe, address provider, bytes vendorSig)	abi.encode(uint256[2] a, uint256[2][2] b, uint256[2] c, uint256 weightsCommitment, uint256 variance)	keccak256(abi.encode(weightsCommitment, variance))

Vendor attestation (private verifier): EIP-191 signature by `dataVendor` over `keccak256(abi.encode(keccak256("QED Private: data attestation v1"), chainid, dataCommitment, universe))`. Groth16 public signals: `[weightsCommitment, variance, dataCommitment, provider]`, each a canonical BN254 element.

5. `QEDClearing` (consent by transaction, no signatures)

Members call `join()`, emitting `Joined(member, index, TERMS)` with `TERMS = keccak256("QED Clearing v1: I consent to any netting that leaves my net position unchanged, creates no new claim, and is proven maximal on-chain.")`. `issue(creditor, amount, dueAt, memo)` creates an obligation (members only, no self-obligation, at most 128 open); `pay(id)` lets the debtor settle it with tokens.

```
Netting { uint256[] ids; uint128[] amounts; uint128[] x; int256[] potential; uint128[] y }
```

`net(p)`, callable by anyone, requires: `ids` = every open obligation, strictly increasing, with `amounts` equal to current amounts; `0 ≤ x ≤ amount`; every member's net position unchanged; `π_debtor - π_creditor + y ≥ 1` for every obligation; `Σx = Σ amount·y` (maximality); `Σx > 0`; potentials and multipliers bounded by 2^{64}. Event `Netted(round, prover, obligations, grossBefore, cleared, grossAfter)`.

6. Bounties

Contract	`claim` input	Pays iff	Otherwise
OptimalityBounty	(spec, solution, int256[] x)	the deployed MinVarianceVerifier accepts (spec, solution), x is feasible, and F(w) − F(x) exceeds the §4.4 bound	TheoremHolds(advantage, bound)
MaximalityBounty	(Economy, Certified, uint256[] alt)	QEDClearing's acceptance rule accepts Certified and alt is a valid larger netting	TheoremHolds(cleared, alt)
ExecutionBounty	(amountIn, tokenOut, Price[] prices, Hop[] route)	the route, run on the bounty's own funds through the module's venues, beats QEDExecution.quoteBound	TheoremHolds(out, bound)

7. Off-chain records

Decision records are canonical JSON (`agent/src/protocol/records.ts`: sorted keys, bigints as decimal strings), hashed with keccak256. The co-signer's record (`schema: qed.decision-record/v1`) contains the request, every check with its verdict and detail, the treasury snapshot and, for trades, its own quote, route and prices; its hash is the certificate's `evidenceHash`, anchored on-chain by `PaymentExecuted`. Owner instructions confirmed by signature use EIP-191 over the exact strings in `agent/src/roles/cosigner.ts` (`ownerInstructionMessage`, `ownerTradeMessage`).

8. Replay and domain separation, summarised

Message	Bound to	Replay protection
Mandate	chain id, vault (domain); agent	epoch, revocation, validity window
Certificate	chain id, vault (domain); mandate hash; every payment field	`intentId` single use; validity window; epoch
Order	the certificate (`ref`)	the certificate's `intentId`

Message	Bound to	Replay protection
Quote	chain id, escrow (domain)	`(provider, quoteId)` single use; `validUntil`
Private proof	provider address (public signal), data commitment, vendor attestation with chain id	job single settlement
Netting	the exact set and amounts of open obligations	amounts change after netting, so a replay fails `IncompleteSnapshot`

PART 4

QED — Security Design & Self-Assessment

> Scope: `contracts/src/*` (QEDVault, QEDLens, QEDExecution, ProofEscrow, MinVarianceVerifier, PrivateMinVarianceVerifier, QEDClearing, the three bounties, CPMMPool, TestUSD, TestToken) and the off-chain agent system in `agent/`. Status: **testnet prototype, not externally audited.** Every claim below links to a test, an invariant, or a public Sepolia transaction.

1. Security thesis

Treat the AI as compromised by default. Prompt injection, tool poisoning, model error and key theft are not edge cases for autonomous agents — they are the operating environment. QED therefore makes the safety of money independent of the AI's behaviour:

1. **The AI holds one key that can call one function** (`executePayment`), and that function succeeds only with an owner-signed mandate *and* an independent co-signer certificate *and* inside the solvency invariant.
2. **The worst case is computed, not hoped for.** `QEDLens.blastRadius` returns, at any block, the maximum loss if the agent key and the co-signer key are both stolen. Loss to addresses the owner never approved is 0.
3. **Proof replaces trust in payment for work.** The escrow pays only for answers that pass an on-chain KKT optimality check.
4. **We publish the keys.** The honeypot vault's agent and co-signer private keys are in the repo (`evidence/ethereum-sepolia/honeypot.json`). Its 90 tUSD ring-fence is protected by the contract, not by secrecy.
5. **A trade's quality is a precondition, not a report.** `QEDExecution` refuses any conversion whose measured output is more than $\tau = 1$ ppm below the best output *any* route through the owner's venues could have produced from the same state. A compromised agent key can no longer leak value through routing; under a slippage-only policy it could leak up to the whole tolerance on every trade (`docs/BENCHMARKS.md` B1).

2. Permission tiers (implemented in `QEDVault.sol`)

Capability	Owner (cold)	Agent (AI hot key)	Co-signer (independent service)	Guardian	Creditor	Anyone
Sign mandates (scope of agent authority)	✓ (off-chain EIP-712, EOA or ERC-1271 multisig)	✗	✗	✗	✗	✗
`executePayment` (spot / forward)	✗	✓ only with owner mandate + co-signer certificate	✗ (signs certificates only)	✗	✗	✗
Sign payment certificates	✗	✗	✓ after 12 policy checks	✗	✗	✗
`ringFence` (create protected liability)	✓ from free funds only	✗ (only via mandate-scoped forward payments)	✗	✗	✗	✗
`withdraw`	✓ free funds only — never ring-fenced	✗	✗	✗	✗	✗
`settle` a due liability	✓	✓	✓	✓	✓	✓ (always pays the creditor; works while paused)
`release` / `assign` a liability	✗	✗	✗	✗	✓ own claims only	✗

Capability	Owner (cold)	Agent (AI hot key)	Co-signer (independent service)	Guardian	Creditor	Anyone
`pause`	✓	✗	✗	✓	✗	✗
`unpause`	✓	✗	✗	✗ (can only make things safer)	✗	✗
`bumpEpoch` / `revokeMandate` (mass / single revocation)	✓	✗	✗	✗	✗	✗
`setAgent` / `setCosigner` / `setGuardian` / `setDailyCap`	✓	✗	✗	✗	✗	✗
`transferOwnership` (two-step)	✓	✗	✗	✗	✗	accept by pending owner

ProofEscrow tiers: provider signs quotes and is the only party that may `deliver`; client opens by presenting a provider-signed quote; anyone may `refund` after the deadline (funds go to the client only); the provider may release the client early. MinVarianceVerifier and QEDLens are stateless and privilege-free.

QEDClearing tiers (no owner, no admin, no upgrade path):

Capability	Member	Anyone	Notes
`join`	✓ (self only)	✓	emits the hash of the netting terms: explicit, on-chain consent
`issue` an obligation	✓ as **debtor** only	✗	nobody can create a debt for someone else
`pay` an obligation	✓ as **debtor** only	✗	tokens move debtor → creditor, nowhere else
`net` (submit a netting)	✓	✓	permissionless, because the contract enforces: unchanged net positions, no new claims, full snapshot, maximality proof

QEDExecution tiers (one module per vault; it is the vault's `agent`):

Capability	Vault owner	Operator (AI hot key)	Co-signer	Anyone
`setVenues` (the venue set every proof must range over)	✓ (invalidates outstanding orders)	✗	✗	✗
`setOperator` (rotate the AI key)	✓	✗	✗	✗
`trade`	✗	✓ only with a mandate, a certificate whose `ref` is the order hash, and a passing proof	✗ (signs the order's certificate)	✗
`pay` (forward an ordinary payment)	✗	✓	✗	✗
`quoteBound`, `venues`, `hashOrder`	✓	✓	✓	✓ (views)

QEDTreasuryPolicy tiers (Run 4d: the policy contract is QEDExecution's operator, so `trade` is reachable only through it):

Capability	Treasury owner	Agent (AI hot key)	Co-signer	Anyone
`setPolicy` (target, tranche bounds, κ, over-conversion slack, expiry)	✓	✗	✗	✗
`revoke` (ends the policy at once)	✓	✗	✗	✗
`setAgent`	✓	✗	✗	✗

Capability	Treasury owner	Agent (AI hot key)	Co-signer	Anyone
`convert` (one tranche)	✗	✓ only if a shortfall exists, the tranche is in bounds, its cost ≤ κ against mid and no smaller tranche provably covered the need, plus every `trade` condition	✗ (signs the order's certificate)	✗
`policy`, `shortfall`, `midOut`	✓	✓	✓	✓ (views)

CPMMPool has no owner (liquidity by transfer + `sync`, no LP shares); TestToken's only privilege is the deployer's `mint` on a valueless token.

PrivateMinVarianceVerifier, OptimalityBounty, MaximalityBounty and ExecutionBounty have no owner, no admin and no upgrade path. The private verifier's only configuration is fixed at deployment (the Groth16 verifier and the data vendor's attestation key). A bounty's only outflow is `claim`, which pays the caller only when its theorem is refuted; nobody, including the deployer, can withdraw a bounty pool.

Off-chain tiers: each role runs as a separate OS process that receives exactly one private key in its environment (`agent/scripts/live.ts → spawnRole`). The language model never receives any key, address book mutation rights or tool that can sign.

3. Security properties and how each is verified

#	Property	Mechanism	Verified by
I1	Vault balance ≥ ring-fenced liabilities, always	`a ≤ free` checks on every outflow (§1 ALGORITHMS)	invariant fuzzing (512×96, both hot keys stolen); `npm run verify` live
I2	`totalProtected` = Σ open liabilities	single code path for create / settle / release	invariant `ProtectedEqualsSumOfOpenLiabilities`
I3	Ring-fenced value reaches only its creditor	`settle` pays `liabilities[id].creditor`; only creditor may release/assign	invariant `CreditorsPaidExactly`; Sepolia P3
I4	Zero loss to addresses the owner did not approve	payee ∈ owner-signed mandate	invariant `ZeroLossToUnapprovedAddresses`; Sepolia X6, H4
I5	Signed terms are immutable	EIP-712 over every field; authenticity checked first	unit tests `Revert_Tampered*`; Sepolia X2, X3, X8, X9
I6	No replay	single-use `intentId` / `quoteId`	Sepolia X10; `test_Revert_Replay`
I7	Agent key has no admin power	`onlyOwner` / creditor / guardian gates	invariant `AgentKeyHasNoAdminPower`; Sepolia X13–X15, H6
I8	Bounded loss under total hot-key compromise	global window cap + free-balance bound	fuzz `BlastRadiusIsAnUpperBound`; Sepolia X11, X12, H5
I9	Pause stops the AI, never the creditors	`executePayment` checks `paused`; `settle` doesn't	`test_GuardianPausesButCannotUnpause_CreditorsStillPaid`; Sepolia P1–P3
I10	Escrow pays only for ε-optimal work	KKT certificate check (Theorem §4.4)	3×2000-run fuzz incl. "accepted ⇒ ε-optimal"; Sepolia X17, X18
I11	Clients can't underpay / redirect, providers can't swap the problem	quote binds price, payee, verifier, spec hash, deadline	`test_Revert_ClientTampers*`; Sepolia X2, X3
I12	Purchased data is the data the job committed to	`job.specHash == invoice.dataCommitment`, re-hashed by the agent	co-signer C8; agent `fulfil()`
I13	A netting never changes any member's net position	per-member conservation check	`test_Revert_ShiftingValueBetweenMembers`; 2,000-run cycle fuzz; Sepolia N2; `npm run verify`
I14	A netting never erases more than is owed and never creates a claim	0 ≤ x ≤ d; amounts only decrease	`test_Revert_CancellingMoreThanOwed`; Sepolia N3
I15	Only a provably maximal netting executes	LP-duality certificate, Σx = Σd·y, exact integers	60 random economies; TS solver = exhaustive oracle on 150 economies; Sepolia N1, N5

#	Property	Mechanism	Verified by
I16	A proof covers the whole, current state	every open id, current amounts	`test_Revert_HidingAnObligation`, `StaleAmounts_AndReplay`; Sepolia N4, N7
I17	The escrow pays for private work only if it is ε-optimal for the vendor's attested data	Groth16 proof of the KKT certificate + EIP-191 vendor attestation (§10 ALGORITHMS)	real-proof tests incl. 2,000-run corrupted-proof fuzz; no witness exists for 1/N, a 1 bp nudge or other data (`private.test.ts`); Sepolia Z3, ZA2, ZA3
I18	A valid proof is useless to anyone but its author	`provider` is a public input bound into the proof	`test_StolenProofIsUselessToAnotherProvider`; Sepolia ZA1
I19	The chain learns nothing about the model or the portfolio beyond two commitments and the variance	zero knowledge of Groth16; Poseidon commitments with 248-bit salts	by construction; `npm run verify` re-verifies the proof from public signals only
I20	Theorems 4.4 and 9.2 are falsifiable on-chain by anyone, for money	`OptimalityBounty`, `MaximalityBounty`	positive controls pay against unsound rules; differential test vs `QEDClearing` on 60 economies; 2×2,000-run fuzz; Sepolia BA1–BA3, BM1–BM2; pools checked daily by `npm run verify`
I21	Every executed conversion delivered at least $(1 - \tau)$ of the best output any route through the owner's venues could have produced, from the state it executed on	weak-duality bound $\hat{B}(\nu)$ computed on-chain with upward rounding; output measured as a balance change (§12 ALGORITHMS)	2×2,000-run soundness fuzz (random and near-optimal routes never beat the bound); bit-exact parity with the TS solver; TS weak-duality test (12,000 route/price pairs); Sepolia E1, E2, EA1–EA3; `npm run verify` recomputes the bound from pre-trade reserves
I22	A conversion's output reaches only an owner-approved recipient, and the module holds nothing between transactions	recipient ∈ mandate payees; leftovers revert; unspent input returns to the vault	`test_recipientMustBeInTheOwnerMandate`, `test_leftoverIntermediate_isRejected`; Sepolia EA4; `npm run verify` checks the module's balances are zero and every tEUR it sent went to the reserve
I23	The order (recipient, floor, tolerance, venue set) cannot be changed after the co-signer approved it	certificate `ref` = order hash; venue-set hash in the order	`test_tamperedOrder_isRejected`, `test_venueChangeInvalidatesOutstandingOrders`; Sepolia EA6
I24	Routing through the module weakens none of the vault's guarantees	funds arrive only via `executePayment` in the same transaction; QEDVault bytecode unchanged	`test_vaultLimitsReplayAndPauseStillApply`, `test_perPaymentCapStillApplies`, `test_payPassesThrough_butNotWithATradeCertificate`; Run 4 vault bytecode verified identical
I25	Theorem 12.3 is falsifiable on-chain by anyone, for money	`ExecutionBounty` runs the claimant's route on its own funds and compares with the deployed bound	positive control pays against a bound understated by 0.1%; donated holdings cannot be used; 2,000-run fuzz never pays; Sepolia XA1–XA3
I26	Under a standing policy the agent cannot convert more, or at a worse execution cost, than the owner's policy allows at that block	the co-signer re-derives the tranche from the chain (P1–P3) before it certifies; the mandate's caps and best execution still apply on-chain	`treasury.test.ts` (limits never exceeded, determinism); Sepolia PA1 (25 requested, 19.535234 allowed: refused), PE1–PE2, T3; `npm run verify` checks the target was met at PE2's block
I27	With both hot keys stolen, no conversion runs when the reserve meets its target, outside the owner's tranche bounds, above κ against the mid price, or larger than the shortfall provably required	`QEDTreasuryPolicy` is QEDExecution's only operator; clauses C1–C4 checked in the trade's transaction (ALGORITHMS §12.9, Proposition 12.9)	13 tests incl. `testFuzz_everyAcceptedTrancheSatisfiesThePolicy` (2,000 runs); Sepolia QA1–QA4 (attacker holding the agent and co-signer keys) refused, QE1 accepted; `npm run verify` re-checks every clause of QE1

Test totals: **145 Solidity tests** (unit, fuzz, stateful invariants — ≈350 000 adversarial calls per CI run, 60 random clearing economies, a real Groth16 proof attacked 2,000 ways, three bounties, best execution with two 2,000-run soundness fuzzers, the on-chain treasury policy with a 2,000-run clause fuzzer), **60 TypeScript tests** (TS ≡ Solidity parity on a live node, portfolio solver vs. a 20 000-sample oracle, netting solver vs. an exhaustive oracle, zero-knowledge prover soundness checks, routing weak duality on 12,000 route–price pairs and strong duality on 300 markets, the treasury policy's tranche rule, 32-case red-team).

Proven properties vs. trust assumptions

Proven (by code the chain runs, or by mathematics the tests exercise)	Assumed (a party or a fact we rely on)
I1–I27 above, within their stated conditions	the owner key is not compromised (K1); Ethereum consensus and the EVM behave as specified

Proven (by code the chain runs, or by mathematics the tests exercise)	Assumed (a party or a fact we rely on)
Theorems 4.4, 9.2 (with proofs in ALGORITHMS) and 12.3 (proof uses path deficiency from the literature, tested)	the Groth16 setup was not subverted (K18); BN254 pairing and keccak256 are secure
Accepted conversions are within τ of the optimum on the state they executed on	the owner's venues are honest constant-product pools with the declared fee (K22)
The bound is never understated by integer rounding	the co-signer's quote reflects a fair market when it signs (K23)
	the data vendor's attestation means what it says (§10); token contracts are standard ERC-20 (K9)

4. Threat model

Assets: ring-fenced liabilities; free treasury; escrowed client funds; integrity of signed terms; the owner's authority; confidentiality of keys.

Adversaries considered

Adversary	Capabilities assumed	Outcome (evidence)
External prompt injector	arbitrary text in RFQs, invoices, chat	guard + typed-only economics; no payment path (X1, red-team 25/25)
Manipulated LLM	outputs anything, including "pay Mallory"	co-signer refuses (X4); contract rejects (X5–X7)
Agent-key thief	signs and sends any tx as the agent	can only pay owner-approved payees within caps & solvency (X5–X15)
Agent **+ co-signer** key thief	forges valid certificates	still bounded by owner mandate, caps, solvency (X6, X11, X12)
Public-key attacker (honeypot)	both hot keys are public	$\leq$ 1 tUSD/day to CloudCo; ring-fence intact (H3–H6, live)
Malicious client	edits signed quotes	rejected (X2, X3)
Lazy / dishonest AI provider	submits unoptimised or near-miss work	rejected by mathematics; client refunded (X17–X19)
Proof thief / data forger	copies a valid zk proof from calldata; proves on self-attested data; overstates quality	proof bound to its author; vendor attestation required (ZA1–ZA3)
Theorem challenger	any input at all, with a 1,000 tUSD incentive per theorem	every refutation attempt reverts with the gap it could not close (BA1–BA3, BM1–BM2)
Compromised trading agent	holds the operator key; routes any way; picks any prices	cannot leak more than τ = 1 ppm per trade through routing (EA1–EA3); cannot redirect output (EA6); cannot strand value (EA4)
Front-runner / sandwich attacker	moves venue prices before a signed trade	refused by the co-signed floor when the move exceeds 1% (EA8); smaller moves are a residual risk (K23)
Liquidity provider colluding with the agent	owns liquidity in one venue and wants volume routed through it	routing to it beyond the optimum fails the proof (EA1, EA5)
Agent **and** co-signer keys stolen, under a standing policy	signs any order and certificate the mandate allows	the policy contract refuses bypass, over-conversion, excess cost and tranches after the target (QA1–QA4); loss bounded by the mandate's caps and best execution
Over-eager or compromised agent under a standing policy	requests larger or costlier tranches than the policy allows, or trades when no shortfall exists	the co-signer recomputes the decision and refuses (PA1); the mandate caps what any certificate can move
Execution-theorem challenger	any route and prices, with 1,000 tUSD on offer	every claim reverts with `TheoremHolds(output, bound)` (XA1–XA3)
Stranger	calls permissionless functions	can only settle due liabilities to their creditors (P3)
Owner-key thief	full owner powers	**out of scope** — see K1

STRIDE summary. Spoofing → EIP-712 signatures from fixed role addresses; Tampering → all terms signed, calldata re-hashed; Repudiation → every payment anchors a hash of its decision record; Information disclosure → LLM never sees keys, guard blocks secret requests (DE-1…6); Denial of service → no unbounded loops on-chain, payees $\leq$ 32; Elevation of privilege → single-function

agent key, owner-only admin.

5. Known-risk list (honest)

ID	Risk	Severity	Status / mitigation
K1	**Owner-key compromise = full control** of mandates, caps, withdrawals of *free* funds. Ring-fenced liabilities remain protected even then.	High	Owner can be an ERC-1271 multisig (tested: `test_SmartAccountOwner_ERC1271`). Roadmap: timelocked admin.
K2	**Both hot keys stolen**: attacker can move up to the blast radius to owner-approved payees (waste, not theft — unless an approved payee colludes).	Medium	Bounded and displayed on-chain (`blastRadius`); guardian pause; tight per-mandate caps.
K3	Fixed 24h windows allow up to 2× cap around a window boundary.	Low	The published bound accounts for it (inclusive counting). Roadmap: rolling window.
K4	**Verifier trust**: both sides must agree on the verifier contract in the quote; a malicious verifier could accept anything.	Medium	Verifier address is signed in the quote; clients pin canonical verifiers by bytecode (`npm run verify` checks bytecode). Roadmap: verifier registry.
K5	**ε-optimal, not exact**: accepted solutions are within `(2n+3+	ν	)τ` of the optimum; τ is client-chosen (≤ 1 %).
K6	**Data confidentiality** in the public verifier: delivering a §4 certificate reveals the covariance in calldata.	Low (resolved for private jobs)	`PrivateMinVarianceVerifier` (§10) proves the same certificate in zero knowledge; clients choose per job.
K7	**Guard is heuristic**: regex detectors can have false negatives/positives, the LLM is non-deterministic.	Medium	Guard is defence-in-depth only; the co-signer and contract are the binding controls. Red-team: 25/25 blocked, 0 false refusals.
K8	**Co-signer liveness**: if the co-signer is down, the agent cannot pay (fails safe).	Low	Fail-closed by design; owner can rotate co-signer.
K9	Token assumptions: standard ERC-20 (no fee-on-transfer / rebasing).	Low	Single, known asset per vault.
K10	Timestamp influence (validators ±seconds) on windows / deadlines.	Low	Windows are hours/days; certificates valid for 2 h.
K11	**Gas-schedule drift**: Sepolia's state-creation repricing (≈6.7× deployment cost) and EIP-7825's 2^{24} per-tx gas cap bound deployable code size.	Info	Vault slimmed to 9.1 KB (views moved to QEDLens); deploys at 14.96 M gas.
K12	**Execution topology**: our build sandbox had no RPC egress. Transactions were signed in the sandbox against a wall-clock-synchronised local replica of Sepolia, then the identical signed bytes were broadcast via a browser relay; every public receipt was compared with the replica's (status + logs). Two earlier attempts failed (gas schedule; one under-provisioned agent transaction) and were superseded by a run under fresh keys.	Info	Disclosed in `docs/EVIDENCE.md`; `npm run verify` re-derives every claim from the public chain; the canonical run is self-contained.
K13	Unaudited prototype on a testnet with a valueless token.	—	Do not use with real funds.
K14	Honeypot keys are public: anyone can spend ≤ 1 tUSD/day of honeypot free balance to CloudCo.	Expected	That is the demonstration of a bounded blast radius.
K15	**Clearing griefing**: a member can issue many tiny obligations (≤ 128 open) or front-run a netting with a new obligation, making a submitted proof stale.	Low	Fails safe (`IncompleteSnapshot` / `StaleAmount`); the prover recomputes in milliseconds. Roadmap: per-member caps, a proposal window.
K16	**Netting changes counterparties' credit mix** only by shrinking it: claims are reduced, never re-assigned, but a member loses a specific receivable it might have preferred to keep.	Low	Disclosed in the on-chain terms every member signs by joining.
K17	Clearing obligations are acknowledgements, not escrowed funds: a debtor can still default on what remains after netting.	Medium	Netting minimises what must be paid; pairing it with QEDVault ring-fencing is the roadmap.

ID	Risk	Severity	Status / mitigation
K18	**Trusted setup**: the Groth16 parameters came from a local two-phase ceremony whose contributions all ran on one machine; whoever held all contributions' randomness could forge proofs.	Medium (testnet)	Public-transaction beacons; transcript and `.ptau` / `.zkey` committed for `snarkjs zkey verify`. Production: phase 1 from a public ceremony, phase 2 with independent parties (`PTAU=… bash circuits/setup.sh`).
K19	**Circuit completeness**: an under-constrained circuit would accept bad witnesses.	Medium	Every arithmetic constraint is mirrored in `checkWitness`; explicit range checks keep all values ≪ p; tests show no witness exists for 1/N, a 1 bp nudge or other data. Roadmap: formal circuit audit (e.g. Picus / Circomspect).
K20	**Provider binding is per spec**: a client that accepts a quote whose spec names a different provider could pay for a proof it cannot use.	Low	Clients check `spec.provider == quote.provider` (enforced by QED's client agent); the escrow already pins delivery to the quoted provider.
K21	Bounty pools are finite and in a test token; they demonstrate falsifiability, not insurance.	Info	Pools and claims are public; `npm run verify` checks daily that no `Refuted` event exists.
K22	**Venue trust**: the bound assumes each owner-named venue is an honest constant-product pool with the declared fee. A malicious pool could report reserves that do not reflect its swap behaviour.	Medium	Only the vault owner names venues; the module cross-checks the fee where the pool reports it; changing the set voids outstanding orders. Production: pin venues by code hash.
K23	**Manipulation below the floor**: an attacker who moves every venue by less than the co-signer's 1% allowance before a trade is caught by neither check; the proof is relative to the moved state.	Medium	Private order flow, tighter floors for larger trades, a TWAP reference in the co-signer's T2 screen. Disclosed in ALGORITHMS §12.7.
K24	**Granularity**: integer rounding costs up to one raw unit of output per hop, so τ = 1 ppm is too tight for outputs of a few raw units.	Low	The co-signer sets τ per order; B2 measures the floor (max 7.4 ppm on tiny outputs).
K25	**Gas is not in the objective**: an output-optimal route can use more hops than a cheaper near-optimal one.	Low	Gas is paid by the operator's ETH, not the vault; at Sepolia prices a four-hop trade costs ~0.00001 ETH.
K26	**Concentrated-liquidity and stable-swap venues** are not supported by the bound.	Info	Their per-venue value h_i has a (piecewise) closed form; not implemented.
K27	**LLM provider credentials**: the language layer calls an external API with a key the operator supplies.	Low	Held only by the brain process, never logged or committed; the offline parser is the fallback; no money field depends on it.
K28	**Policy liveness is off-chain**: since Run 4d the policy's safety clauses (shortfall, bounds, cost, no provable over-conversion) are enforced by `QEDTreasuryPolicy`; what remains off-chain is liveness (an agent may convert less than it could, or wait) and the co-signer's choice of the *largest* tranche within κ. Over-conversion is refused only beyond the owner's slack σ.	Low (was Medium before Run 4d)	σ is the owner's parameter (10 bps on Sepolia); a slow agent costs the owner time, not money; `revoke` ends the policy at once.
K29	**Per-tranche, not cumulative, impact**: κ is measured against the mid price at each tick, so successive tranches can move the price further in total.	Low	Tranche size, daily cap and the 300 bps T2 screen bound it; Run 4c's second tranche paid 90 bps against the moved mid. Production: cumulative impact budget, TWAP reference, minimum interval between tranches.

5a. Key lifecycle, oracles, MEV, availability and administration

Key lifecycle. Each role's key is generated per run (`viem` `generatePrivateKey`), stored only in a `.keys.env*` file excluded from git with mode 0600, and loaded into one process. The language model never sees any key. Rotation is on-chain and immediate: `setAgent`, `setCosigner`, `setGuardian` (vault), `setOperator` (execution module); a key compromise is contained by `pause`

(guardian, one transaction) and `bumpEpoch` (owner: every mandate and certificate becomes void). Production would hold the owner key in an ERC-1271 multisig or MPC wallet and the agent and co-signer keys in HSM or cloud KMS signers; none of that is implemented here.

Oracles and data integrity. QED uses no price oracle. Conversions are proven against the venues' own reserves, read in the same transaction, so there is no stale price to exploit inside the trade. Portfolio data is either public in the spec (§4) or attested by the vendor's signature over a commitment (§10). The co-signer reads chain state itself and never trusts the agent's figures.

MEV and front-running. A signed trade can be front-run (EA8 on Sepolia). The proof cannot prevent this, because it is about the state the trade executes on; the co-signed floor bounds it. Escrow deliveries, clearing nettings and bounty claims are not front-runnable for profit: they pay only their sender (provider binding, or the claimant), or move no value.

Availability. Every failure mode fails closed: no co-signer means no payments (K8), a moved market means no trade (A10), and a stale clearing snapshot means no netting (K15). Creditors are never blocked: `settle` works while paused. No contract has an unbounded loop over user-controlled data (payees ≤ 32, venues ≤ 16, hops ≤ 32, open obligations ≤ 128).

Administration. No contract is upgradeable. The only administrators are each vault's owner (configuration, never ring-fenced funds) and the deployer's `mint` on test tokens. The clearing house, verifiers, escrow, pools and bounties have no admin at all.

Mitigation classes

Class	What it covers here
Eliminated by code	spending outside the mandate, breaking a ring-fence, replay, tampering with signed terms, a lazy proof being paid, a non-maximal netting, a sub-optimal conversion, value stranded in the module
Eliminated by cryptography	forged signatures, forged zero-knowledge proofs (given a sound setup), stolen proofs (provider binding)
Bounded by mechanism	loss under total hot-key compromise (`blastRadius`), front-running (co-signed floor), integer rounding (τ)
Shifted to incentives	anyone finding a flaw in Theorems 4.4, 9.2 or 12.3 can take the corresponding bounty
Delegated to trusted parties	the owner key; the co-signer's honesty for its quote and screens; the data vendor; the trusted setup; the venue set
Cannot be eliminated here	owner-key compromise; market manipulation below the floor; consensus failure; a regulator's view of an autonomous agent

Production-readiness limitations

Testnet only, valueless tokens, no external audit, no formal verification of the contracts or the circuit, a single- machine trusted setup, a co-signer that is one process rather than a quorum, demo-size liquidity, and venues that are our own constant-product pools rather than production DEXs. Each is listed above with its roadmap.

6. Incident response

1. **Guardian** pauses the vault (one transaction). Creditors keep being paid.
2. **Owner** bumps the epoch → every outstanding mandate and certificate is void.
3. **Owner** rotates the compromised key (`setAgent` / `setCosigner`), re-issues mandates, unpauses.
4. Forensics: every payment event carries `evidenceHash`; the decision record reproduces the exact inputs.

7. Compliance-relevant controls

- **Four-eyes / maker–checker** for every discretionary payment (agent proposes, co-signer certifies).
- **Segregation of duties**: owner, agent, co-signer, guardian are distinct keys and processes.
- **Ring-fencing** of obligations (bankruptcy-remote within the vault).
- **Sanctions / deny-list screening** at the co-signer (C11).
- **Audit trail**: canonical decision records, hash-anchored on-chain; LLM transcripts hashed per turn.
- **Explainability**: every decision has a human-readable rationale; the agent answers "why" from its decision log.

- **Kill switch** with creditor continuity.
- **Best execution as a precondition** (cf. MiFID II art. 27, FINRA rule 5310): every conversion carries a proof that it was within 1 ppm of the best available route, checked on-chain at the moment of execution.

PART 5

QED — Benchmarks and Ablations

All numbers on this page come from `benchmarks/run.ts`. It is deterministic (fixed seeds, no network) and writes `benchmarks/results.json`; `npx tsx benchmarks/run.ts` reproduces it in about 7 seconds. Each section states the baseline, the metric and what the result does **not** show. Unfavourable results are included.

B1 · Best execution: what a proof buys over the routing policies agents use without one

Setup. 1,000 seeded markets: 3–4 tokens, 1–3 direct pools plus 1–2 two-hop paths per bridge token, depths 100–10,000 USD per side, fees from {1, 5, 30, 100} bps, each venue mispriced by less than its own fee (so no fee-free arbitrage exists), trade sizes 0.1%–20% of the direct pools' depth. The certified route is QED's solver; shortfalls are measured against its integer-simulated output.

Policy (no proof)	Median shortfall	p90	p99	Already optimal (< 0.01 bp)	Passes a 1% slippage floor
Best single pool	74.5 bps	667 bps	1,534 bps	2.2%	55.4%
Equal split over direct pools	117.2 bps	1,097 bps	3,044 bps	1.7%	47.6%
Optimal split over direct pools only (a single-pair aggregator)	33.7 bps	350 bps	1,045 bps	6.2%	71.3%

The security reading (the reason QED exists). A wallet that enforces only a minimum output lets a compromised or careless agent use any route that clears the floor. Among routes that clear a 1% floor, the value given up is a median 14–32 bps and up to 99.9 bps per trade, depending on the policy. Under `QEDExecution` the same agent can give up at most $\tau = 1$ ppm (0.01 bp) of the bound, whatever route it picks.

Size matters; this is the unfavourable part.

Trade size (share of direct depth)	Markets	Direct-only median shortfall	Direct-only p90	Single pool median
< 0.5%	297	3.2 bps	40.9 bps	11.5 bps
0.5–2%	277	22.7 bps	96.4 bps	53.9 bps
2–5%	168	60.0 bps	230.9 bps	170.9 bps
> 5%	258	267.9 bps	769.7 bps	537.6 bps

For small trades in deep markets a decent router is already within a few basis points of the optimum: there the proof adds a *guarantee against a hostile agent* rather than much average improvement. The average improvement is large only when trades are large relative to liquidity, as in thin on-chain markets or the demo's pools.

Not shown. The baselines are simple policies, not production aggregators (1inch, 0x, CoW solvers), which use multi-path search and would sit closer to the optimum; we had no way to query them on our test venues. The markets are synthetic and contain only constant-product pools.

B2 · The certificate: precision and cost

Metric	Median	p90	p99	Max
Gap between realised output and the on-chain bound	0.075 ppm	0.75 ppm	4.2 ppm	7.4 ppm

The solver takes a median 3.4 ms per market on one CPU (p99 34 ms; printed by the script, not stored, because it depends on the machine). 92.3% of the 1,000 certified routes are within 1 ppm of their bound. Every one above 1 ppm is within one raw token unit per hop of it: integer rounding on outputs of a few tokens, where a single unit is several ppm. The live run uses $\tau = 1$ ppm on outputs of about 18 tEUR (gaps of 0.17 ppm). An order's τ should be at least `(hops + 1) / output` in raw units.

On-chain cost (Sepolia receipts). The honest four-hop trade E1, which pulls funds through the vault (two signature checks, caps, solvency), reads five venues, computes ten square roots, executes four swaps and checks three balances, used 1,122,781 gas on Sepolia; E2 used 667,936 (warm storage). At Sepolia's 0.01 gwei that is about 0.00001 ETH. We did not meter the bound alone on Sepolia; in Foundry, two `quoteBound` calls over the five venues cost 156,462 gas together, test overhead included. We did not build an on-chain solver to compare against, so the claim that verifying is cheaper than solving on-chain is argued (the bound needs one pass over the venues; solving needs an iterative search with square roots in every step), not measured.

B3 · Clearing: certified maximal netting vs a greedy netter vs none

500 seeded economies (4–12 members, 1–4 obligations per member on average, 1–200 tUSD each).

Netting	Share of gross debt cleared (median)	p90
None	0%	0%
Greedy: repeatedly cancel the shortest cycle	34.0%	59.2%
QED: maximal, with an LP-duality certificate	39.2%	65.3%

The greedy netter clears a median 4.2 percentage points less of the gross debt (p90 12.7, max 27.7) and is already optimal in 30.4% of economies. The unfavourable reading: on easy economies a heuristic is often enough. The certificate's value is that the contract can tell which case it is in, without trusting whoever computed the netting.

B4 · Paid work: what the escrow's optimality check prevents

500 seeded minimum-variance problems (4–8 assets, volatilities 5–60%, one-factor correlations). Without the KKT check, a provider can be paid for any feasible portfolio. Two lazy deliverables, measured against the certified optimum:

Deliverable without the check	Excess variance over the optimum (median)	p90	Min
Equal weights (1/N)	+259%	+908%	+10%
Everything in the lowest-volatility asset	+144%	+399%	0%

The size of these numbers depends on the generator: correlated factor models make 1/N look bad. The point is qualitative. With the check, neither deliverable is payable (live attack X17 on Sepolia: `DualityGapTooLarge`).

B5 · Authorisation layers: which layer refused each recorded attack

Taken from the public evidence manifests: for every attack transaction on Sepolia (44 across the four runs), the contract whose check produced the revert.

Layer that refused the attack	Attacks
`QEDVault` (mandate, co-signature, caps, solvency, ring-fence, replay, pause)	15
`QEDClearing` (conservation, completeness, duality certificate)	6
`QEDExecution` (best-execution bound, leftovers, operator)	5
`QEDExecution` with the co-signed order (floor, order hash)	3
`PrivateMinVarianceVerifier` (proof binding, attestation)	3
`OptimalityBounty` · `MaximalityBounty` · `ExecutionBounty`	3·2·3
`ProofEscrow` · `MinVarianceVerifier`	2·2

This is not a re-run with layers switched off, so removing a layer does not imply that the next one would have caught the attack. `benchmarks/results.json` lists every attack with its error.

Reproduce

```
npx tsx benchmarks/run.ts                      # B1–B5 → benchmarks/results.json
node --import tsx --test agent/test/execution.test.ts   # the property tests behind B1/B2
forge test --match-contract QEDExecutionTest    # on-chain soundness fuzzers (2 × 2,000 runs)
```

PART 6

QED — Prior Art and What Is Actually New

This page lists, for every claim QED could be accused of overstating, the closest prior work we know of and the precise difference. It was written to be read by someone who knows the literature. Where our contribution is an application or an integration rather than a new idea, it says so.

Scale used below: **new** = we found no prior system doing this; **specialisation** = a known technique applied to a setting where we found no prior deployment; **integration** = known parts combined; **known** = standard practice we use.

0. Best execution proved at the instant of the trade (`QEDExecution`) — the upgrade's defining claim

The claim: *a smart contract refuses an agent's conversion unless the output, measured as a balance change, is within τ (1 ppm on Sepolia) of a rigorous upper bound on what **any** route through the owner's venues could have returned, computed on-chain from live reserves in the same transaction, from a dual price vector the agent supplies.*

Closest prior art	What it does	Difference from QED
Angeris, Agrawal, Evans, Chitra, Boyd, *Optimal Routing for Constant Function Market Makers*, EC 2022; Diamandis, Resnick, Chitra, Angeris, *An Efficient Algorithm for Optimal Routing Through CFMMs* (2023)	Routing as a convex program; dual decomposition; the dual gives a bound used to *solve*	The mathematics QED's bound rests on (we cite it, §12.5). These papers compute routes off-chain; they do not make the dual bound an on-chain acceptance condition
Angeris & Chitra, *Improved Price Oracles: CFMMs* (2020)	Path deficiency of fee-charging CFMMs	The one step of Theorem 12.3 we take from the literature (tested, §12.3)
Zhavoronkov, *Multi-Path Routing in DEX Networks: Convex Allocation and an Improving-Path Certificate* (arXiv 2607.22540, 2026)	Off-chain router; a KKT multiplier certifies that no omitted path improves the candidate allocation	Certificate checked off-chain by the router; "execution is protected by an on-chain slippage tolerance" — exactly the gap QED closes
Jiang, Li, Wen, *Transfer algorithm for on-chain one-hop routing*, FC 2026 preproceedings	*Computes* a one-hop split across several AMMs fully on-chain, to a price-gap tolerance	Computes, approximately, for parallel pools of one pair; no bound, no certificate, no multi-hop. QED *verifies* in O(venues), for any route shape over any token graph
Zhou, Qin, Gervais, *A²MM* (2021)	Closed-form optimal split between two constant-product pools, executed atomically on-chain	Two pools in closed form; a heuristic beyond two; no proof for general graphs
CoW Protocol EBBO rule	Solvers must give prices at least as good as baseline AMMs; "not enforced by the smart contract", monitored afterwards, solvers slashed by governance	After-the-fact, social, against baseline pools. QED: in-transaction, by code, against the *optimum* over all owner venues
Intent protocols and aggregators (UniswapX, 1inch Fusion, ERC-7683 cross-chain intents, Paraswap, 0x); ERC-8165 *Agentic On-Chain Operation Interface* (draft, Feb 2026)	Fillers, routers or solvers compete; the contract enforces a minimum output (Dutch-auction decay, slippage limit, or ERC-8165's max-input / min-output safety envelope)	A floor bounds loss to the tolerance; QED bounds it to τ of the optimum. Floors and proofs compose: QED keeps a co-signed floor for market risk
Tangle Solve problem *Certified approximate optimal DeFi execution* (2026, open problem statement, no code)	Asks for an ε-certificate (e.g. a dual bound) of near-optimal DeFi execution, "independently checkable without trusting the solver"	Frames the open problem; we found no implementation there. QED is one for CFMM routing, checked by the chain at execution time
Yaish et al., *Suboptimality in DeFi* (IACR ePrint 2023/892); MiFID II art. 27, FINRA 5310	Measure sub-optimal execution after the fact; legal duty of best execution evidenced by periodic reports	Motivation: QED turns the duty into a precondition

Assessment: new, as far as our searches reach. Every ingredient is known: CFMM routing duality, path deficiency, fixed-point rounding. What we did not find, in papers, protocol documentation, or code, is a contract that accepts a trade *only if* its measured output is within a stated tolerance of an on-chain-computed duality bound over all permitted venues, so that an agent, solver or

filler with full routing discretion cannot leak more than τ. We also found no prior system that combines this with an AI agent's spending authority (the bound is checked inside the same transaction that draws funds from a mandate-limited vault) or that stakes money on the bound (`ExecutionBounty` , 1,000 tUSD, unclaimed). A reviewer who knows of one should hold us to this paragraph.

1. Payment that settles only on an on-chain-checked optimality certificate (`ProofEscrow` + `MinVarianceVerifier`)

Closest prior art	What it does	Difference from QED
Certifying algorithms — McConnell, Mehlhorn, Näher, Schweitzer, *Computer Science Review* 5(2), 2011	Algorithms that output a witness a simple checker can validate	QED uses exactly this idea; the checker is a smart contract and its verdict releases payment
TrueBit — Teutsch & Reitwießner, *A scalable verification solution for blockchains*	Pays solvers for off-chain computation; correctness enforced by an interactive verification game with challengers and deposits	TrueBit checks that a program was **executed correctly**, optimistically and with an incentive layer; QED checks, in one transaction and with no challenger, that an answer is **optimal** for its problem
Ofelimos — Fitzi, Kiayias, Panagiotakos, Russell, Crypto 2022	Proof-of-useful-work consensus in which miners run combinatorial-optimisation local search	Rewards progress of a search inside consensus; no per-job optimality guarantee to a paying client
LP / QP certificate checking in exact arithmetic (e.g. VIPR; CGAL QP solver certificates)	Verifies KKT / duality certificates of solver output	Off-chain correctness tooling; not a payment condition
CoW Protocol solver competition	Solvers propose batch settlements; the best one wins by surplus	Ranking among submitted solutions, not a proof that no better solution exists

Assessment: specialisation. KKT conditions and certifying algorithms are classical. What we did not find elsewhere is an escrow whose *acceptance condition* is an exact-integer optimality certificate for a convex QP (including a Cholesky convexity witness) with a stated ε-optimality theorem for the fixed-point tolerances (ALGORITHMS §4.4), deployed and exercised on a public chain against a dishonest provider.

2. Proof-gated multilateral netting (`QEDClearing`)

Closest prior art	What it does	Difference from QED
Liquidity-saving mechanisms and multilateral netting in payment systems (BIS/CPSS literature since the 1990s)	Offset mutual obligations to save liquidity	Run by a trusted operator
Fleischman & Dini (2021), Multilateral Trade Credit Set-off; Cycles Protocol — Buchman, Dini, Ahmed, Miller, Fleischman (2024–25)	Min-cost max-flow clearing of obligation graphs; on a Cosmos chain; a TEE computes the solution on encrypted intents and a ZK proof shows the output is **valid** (balanced, from submitted obligations)	The Cycles paper states that **optimality depends on the TEE**. QED makes maximality itself publicly checkable: an exact LP-duality certificate ($\Sigma x = \Sigma d \cdot y$, totally unimodular) verified on-chain, so anyone, including an interested member, can be the solver
Goldberg & Tarjan (1989), Karp (1978)	Minimum-mean cycle cancelling; minimum-mean cycle	The algorithms our off-chain solver uses

Assessment: specialisation, with one genuine difference (trustless *optimality*, not only validity). Not ours: the netting objective, the algorithms, and privacy — Cycles keeps obligations private; QEDClearing does not.

3. Optimality proven in zero knowledge (`PrivateMinVarianceVerifier`)

Closest prior art	What it does	Difference from QED
Otti — Angel, Blumberg, Ioannidis, Woods, *Efficient Representation of Numerical Optimization Problems for SNARKs*, USENIX Security 2022	Compiles LP, SDP and SGD problems into R1CS so that a SNARK proves the solution is optimal	The core technique (prove a certificate check inside a SNARK instead of the solver) is Otti's. QED applies it to a fixed-point min-variance QP and adds what a market needs: vendor attestation of committed data, a binding to the proving provider, a Solidity verifier, and settlement through an unmodified escrow

Closest prior art	What it does	Difference from QED
Tan, Gascón, Meiklejohn, Raykova, Wang, Luo, *Founding Zero-Knowledge Proofs of Training on Optimum Vicinity* (2025)	Proves a trained model is within a bounded distance of the optimum of a convex training problem	Same family of statements for ML training; no payment or on-chain settlement
zkML frameworks (EZKL and others)	Prove inference / computation of a model in ZK	Prove *computation*, not *optimality*

Assessment: specialisation / integration. We do not claim a new cryptographic technique.

4. Theorems with money on them (`OptimalityBounty`, `MaximalityBounty`)

Closest prior art	What it does	Difference from QED
Peter Todd's hash-collision bounties (2013)	Bitcoin P2SH scripts that pay anyone presenting a collision; the SHA-1 bounty was collected on 23 Feb 2017 after SHAttered	Same mechanism — a self-adjudicating, script-checked refutation bounty — applied to a cryptographic assumption
Optimistic-rollup fault proofs	On-chain adjudication of a disputed state transition	Adjudicate execution claims, funded by bonds
Bug-bounty platforms	Human-adjudicated rewards for vulnerabilities	Not self-adjudicating

Assessment: specialisation. The idea of a contract paying for a counterexample is Todd's. Pointing it at the *economic optimality theorem* of a deployed financial verifier (and at a clearing house's maximality rule), with positive-control tests proving the payout path works, is the part we did not find before.

5. The agent wallet itself (`QEDVault`, co-signer, guard)

QED element	Closest prior art	Assessment
Owner-signed EIP-712 mandate + independent co-signer certificate	Multisig and co-signing services (Safe, BitGo 2-of-3), policy engines (Fireblocks, Turnkey), agent wallets with spending policies (overview of agentic wallets), programmable signers (Lit Protocol), session keys (ERC-4337 / ERC-7579)	**integration**
Ring-fenced liabilities that only the creditor can receive, even from the owner	Escrow and allowance modules (Safe Allowance module), payment-streaming contracts	**integration**; the invariant proof and the "pause stops the AI, never the creditor" rule are careful engineering, not a new idea
Worst-case loss under total hot-key compromise computed by an on-chain view (`QEDLens.blastRadius`) and fuzzed as an upper bound	Rate limits and daily caps (Argent, Safe modules)	**specialisation**: we found caps everywhere but not a published, on-chain-computed bound tested as an invariant
Honeypot vault with published agent and co-signer keys	Public "steal this" demonstrations exist in security folklore	**demonstration device**, not an invention
LLM reads language; deterministic code fills every money field; guard; owner signature on the exact instruction	Dual-LLM pattern; CaMeL — Debenedetti et al., *Defeating Prompt Injections by Design* (2025)	**known** design principle, applied

6. What an expert should take away

QED's defensible contribution is not any single primitive. It is a consistent design rule — **every movement of money is conditioned on a statement the chain itself can check** — carried through five places where agent finance normally relies on trust: who may pay (signatures), what may never be spent (an invariant), whether paid work is any good (an optimality certificate, public or zero-knowledge), whether a clearing operator was honest (a duality certificate), and whether a conversion got the best price any route could (a duality bound checked at execution). Its mathematics is classical and stated with proofs; its novelty lies in where those proofs are enforced, and in being falsifiable on-chain for money.

Searches were run on 20 Oct 2026 across arXiv, IACR ePrint, USENIX, Financial Cryptography 2026 preproceedings, protocol documentation (CoW, UniswapX, 1inch, ERC-7683) and GitHub. The absence of a prior system in our search is not proof that none exists; if a reviewer knows of one, the comparison above is where it belongs.

PART 7

QED — Test Catalogue

Everything below runs in CI on every push (`.github/workflows/ci.yml`) and locally with `forge test && npm run test:ts`.

Solidity (Foundry, `contracts/test`)

Default profile: 2 000 fuzz runs per property, invariants 512 runs × depth 96. CI profile (`FOUNDRY_PROFILE=ci`): 5 000 fuzz runs, invariants 1 024 × 128.

`Invariants.t.sol` — stateful fuzzing with both hot keys stolen

`CompromisedAgentHandler` holds the agent key **and** the co-signer key and, on every call, chooses among: paying random/approved/attacker payees with genuinely signed certificates, forward payments, settling, releasing, admin calls, pausing, time travel. After every call:

Invariant	Statement
`VaultAlwaysCoversRingFencedLiabilities`	`token.balanceOf(vault) ≥ totalProtected`
`ProtectedEqualsSumOfOpenLiabilities`	`totalProtected = Σ open liabilities`
`CreditorsPaidExactly`	each creditor received exactly what was settled to it
`ZeroLossToUnapprovedAddresses`	the attacker's balance never increases
`DailyCapRespected`	agent outflow per 24 h window ≤ `dailyCap`
`NoAgentOutflowWhilePaused`	no agent-initiated outflow while paused
`AgentKeyHasNoAdminPower`	owner, agent, co-signer, guardian, caps never change via the handler
`test_HandlerIsNotVacuous`	the handler really executes successful payments (guards against vacuous invariants)

`QEDVault.t.sol` — 34 tests

Authorisation (owner mandate × co-signer certificate, ERC-1271 smart-account owner), every tampering path (amount, recipient, due date, evidence, mandate scope), replay, expiry, revocation (single + epoch), key rotation, per-payment / period / lifetime / global window caps, solvency under total hot-key compromise, forward payments as ring-fenced promises, settlement by anyone when due (also while paused), creditor-only release/assign, guardian pause without unpause, two-step ownership, and `testFuzz_BlastRadiusIsAnUpperBound` (no sequence of attacker payments exceeds the published `blastRadius`).

`ProofEscrow.t.sol` — 13 tests

Full lifecycle quote → open → deliver → settle into the agent's vault; client tampering with price / payee / verifier / spec / deadline; impostor-signed quotes; quote replay, wrong client, expiry; lazy 1/N portfolio; almost-optimal portfolio; fake convexity witness; solving a different problem; only-provider-delivers-once; refund after deadline by anyone (to the client only); early refund by the provider; `check` is a pure dry run.

`MinVarianceVerifier.t.sol` — 12 tests

Honest certificate passes and returns the variance; asymmetric covariance, negative weight (short selling), budget violation, negative multiplier, dimension mismatch, overflow and tolerance games are rejected; gas cost. Fuzz properties derived from the theorem in `docs/ALGORITHMS.md §4.4`:

- `testFuzz_AcceptedImpliesEpsilonOptimal` — anything accepted is within `(2n+3+|v|)τ` of the true optimum;
- `testFuzz_MaterialReallocationIsRejected` — moving ≥ 1e-5 of weight away from the optimum is rejected;
- `testFuzz_RandomPortfolioWithBestMultipliersIsRejected` — a random portfolio dressed with its best possible multipliers is rejected.

`QEDClearing.t.sol` (15 tests)

- `test_OptimalNettingExecutes_PositionsUnchanged`: the demo economy's proven netting clears 169 of 200 tUSD; every member's net position is unchanged.
- `test_GridlockThenSettlementWithExactCash`: gross payment fails (`ERC20InsufficientBalance`); after netting, the remaining debts settle in topological order with each agent's net debit only; every agent ends at exactly its net position.
- Rejections: `GreedyNettingIsNotProvablyMaximal` (162 vs 169), `ShiftingValueBetweenMembers`, `CancellingMoreThanOwed`, `HidingAnObligation`, `StaleAmounts_AndReplayAfterNetting`, `ForgedDualCertificate`, `IdsNotIncreasing`, `NothingToNet`, `PotentialOverflowGames`, `MembershipAndDebtRules`.
- `testFuzz_AnyCirculationAroundTheOptimumIsRejected` (2,000 runs): push any amount of debt around any of the 11 simple cycles of the demo economy; conservation still holds, and every such proposal is rejected.
- `test_SixtyRandomEconomies`: 60 random economies (3–7 agents, 3–16 debts) from the TypeScript solver: every optimal certificate executes with the exact cleared amount; wherever the greedy agent falls short (11 economies) it is rejected with `NotProvablyMaximal`.

`PrivateMinVarianceVerifier.t.sol` (11 tests): a real Groth16 proof, attacked

The fixture (`npm run fixtures:private`) is a genuine proof from `circuits/private_minvar.circom`.

- Accepted: the proof verifies through the generated Groth16 verifier and returns `keccak(weightsCommitment, variance)`; ≈ 270 k gas.
- Rejected: an understated variance, a swapped portfolio commitment, the same proof under another provider's spec (`StolenProofIsUselessToAnotherProvider`), data attested by anyone but the vendor, an attestation replayed on another chain, a non-canonical field element.
- `testFuzz_AnyCorruptedProofCoordinateIsRejected` (2,000 runs): perturb any of the 8 proof coordinates by any amount; always `ProofRejected`.
- `test_EscrowPaysOnlyForThePrivateProof`: through `ProofEscrow`, Mallory's copy of QED's proof is refused and QED's delivery pays the vault.

`Bounties.t.sol` (11 tests): theorems with money on them

- `OptimalityBounty`: the equal-weight portfolio, the certified portfolio itself and 2,000 random feasible portfolios (`testFuzz_Optimality_NoFeasiblePortfolioRefutesTheTheorem`) all fail to refute Theorem 4.4; a forged certificate cannot even enter (the deployed verifier reverts); infeasible challengers are refused; **positive control:** against a verifier that accepts anything, the bounty pays the first real refutation.
- `MaximalityBounty`: the demo economy is accepted at exactly 169; the greedy 162 cannot refute it; 2,000 random circulations built from the economy's cycles never beat it; `test_Maximality_AgreesWithQEDClearingOnSixtyEconomies` executes each of the 60 economies on a fresh `QEDClearing` and checks the bounty's rule agrees; **positive control:** an acceptance rule that under-reports by 7 tUSD gets refuted and pays out.

`QEDExecution.t.sol` (28 tests): best execution, proved at the instant of the trade

The fixture (`npm run fixtures:execution`) is the TypeScript engine's output on the five demo venues, so the Solidity bound is checked **bit for bit** against the off-chain replica.

- Accepted: the solver's 4-venue, two-hop route for 20 tUSD returns 18.086846 tEUR against an on-chain bound of 18.086849 (`test_honestRoute_isAccepted_andMatchesTheSolverBitForBit`); `quoteBound` equals the TypeScript bound exactly; `test_honestBoundIsTight` shows the gap is below 1 ppm.
- Rejected (`NotBestExecution`): an optimally split direct-only route that a 1% slippage floor would accept (−33 bps); a 0.6 bp skim; any price vector offered for a bad route (`test_noPriceVectorRescuesABadRoute`). Rejected for structure: a stranded bridge token (`Leftover`), an unknown pool, a mis-normalised price vector, a single-venue route below the co-signed floor (`InsufficientOutput`).
- Order and authority: a tampered order (`OrderMismatch`), a recipient outside the owner's mandate, a venue-set change invalidating outstanding orders, a tolerance above the cap, operator-only trading and vault-owner-only configuration, a declared fee that differs from the pool's own; the vault's mandate, replay protection, pause and per-payment cap still apply; `pay` passes through but rejects a trade certificate.

- `test_frontRun_isStoppedByTheCosignedFloor`: a sandwich attacker moves the market between signing and execution; the co-signed floor reverts the trade.
- `testFuzz_boundIsNeverBeaten` and `testFuzz_nearOptimalRoutesNeverBeatTheBound` (2,000 runs each): random amounts, random routes over all five venues and random price vectors; no executed route ever returns more than the on-chain bound (Theorem 12.3, weak duality with upward rounding).
- `ExecutionBounty` (6 tests): the optimal route and lowered prices cannot claim; the pool's own holdings and over-spending cannot be used; `testFuzz_bounty_neverPays` (2,000 runs); **positive control:** against an unsound bound source the bounty pays the first real refutation.

`QEDTreasuryPolicy.t.sol` (13 tests): the owner's policy, enforced on-chain

With QEDTreasuryPolicy as QEDExecution's operator and the fixture's 20 tUSD route (18.086846 tEUR, 111.5 bps against mid):

- Accepted: a tranche under a target it does not over-shoot; a tranche that exactly covers the need (shortfall just above out·(1 − σ)); the mid-price reference equals ΣR_out/ΣR_in of the direct venues.
- Refused: no shortfall (`NoShortfall`); over-conversion (`OverConversion`); cost above κ = 100 bps (`ExecutionCostTooHigh`); a tranche above the owner's maximum (`TrancheOutOfBounds`); a lapsed and a revoked policy (`PolicyLapsed`); an order paying anyone but the reserve (`WrongOrder`); the agent's key calling `trade` directly (`NotOperator`) and anyone else calling `convert` (`NotAgent`); non-owners configuring it, and invalid parameters.
- `test_ringFencingCreatesTheShortfall`: the owner ring-fences reserve money for a creditor; the shortfall that creates makes the same tranche legitimate.
- `testFuzz_everyAcceptedTrancheSatisfiesThePolicy` (2,000 runs over target, κ and σ): every accepted tranche satisfies C1–C4; every refused one breaks at least one, and nothing moves.

TypeScript (`node --test`, `agent/test`)

File	What it proves
`parity.test.ts`	Starts anvil, deploys the contracts, and checks **TypeScript ≡ Solidity** for every EIP-712 hash/digest (mandate, certificate, quote) and for the KKT checker's verdict and returned variance.
`engine.test.ts`	Certifying solver: honest certificate has zero stationarity residual; matches a 20 000-sample brute-force oracle on the simplex; lazy 1/N fails only on complementary slackness; a 0.01 % nudge is rejected; fixed-point round trip; economics (price = cost × 2.5 rounded up; unsettled revenue never counts as capital).
`netting.test.ts`	Netting solver equals an **exhaustive brute-force oracle** on 150 random economies; certificates are exact; netting never changes a net position; remaining debts always form a DAG that settles with net debits only.
`private.test.ts`	The zero-knowledge prover: the fixed-point certificate satisfies every circuit constraint with zero duality gap and matches the exact solver to 10^{-12} per weight; the Groth16 proof verifies and its public signals equal the commitments, the provider and the variance; a tampered signal fails; **no proof exists** for the lazy 1/N portfolio, a 1-basis-point nudge, or a different data commitment (the witness generator's constraints fail).
`execution.test.ts`	The best-execution engine: `isqrt` is the exact floor square root on 2,000 inputs up to 2^{250}; path deficiency (repeated swaps on one pool never beat one swap, 3,000 cases); **weak duality**: no route at any prices beats the bound (400 markets × 10 routes × 3 price vectors); **strong duality in practice**: the solver's route is within 1 ppm of its own bound, or within one raw unit per hop, on 300 random markets; the certified route beats every baseline on 200 markets; the committed Solidity fixture equals the engine's current output.
`treasury.test.ts`	The standing-policy tranche rule: execution cost is non-decreasing in size; a tranche never exceeds any of its five limits and covers the shortfall when need binds; no shortfall → no action, a market too thin for the minimum tranche → wait; the decision is deterministic, so the co-signer recomputes exactly what the agent decided.
`guard.test.ts`	The 32-case red-team corpus (`redteam.corpus.ts`: 25 attacks across induced transfer, data extraction, privilege escalation and prompt injection, in English and Chinese, plus 7 benign requests) through the deterministic guard; plus overrides of a fully compromised LLM (proposes paying the attacker; leaks secrets; exceeds the free balance).

End-to-end

- `QED_OFFLINE=1 npm run local` — the whole economy (deploy, fund, lifecycle, conversation, 18 attacks, honeypot, emergency) on a local chain, in CI.
- `npm run local:clearing` — the clearing economy (gridlock, 6 attacks, proven netting, settlement) on a local chain.

- `npm run local:private` — the private economy (zero-knowledge proof, escrow settlement, 3 attacks, both bounties funded and 5 refutation attempts) on a local chain.
- `QED_OFFLINE=1 npm run local:execute` — the best-execution economy (5 venues, the owner's instruction read by the brain, 2 certified conversions, 8 refused attacks, a front-run, then the standing policy run to its target: PA1 refused, two tranches, stop; then the policy as a contract: four attacks with both hot keys refused, one tranche accepted) on a local chain with dev keys, in CI. Being deterministic, it reproduces Runs 4c and 4d to the raw unit.
- `npx tsx benchmarks/run.ts` — B1–B5 benchmarks with fixed seeds; CI re-runs them and diffs `benchmarks/results.json`, so the published numbers are reproducible.
- `npm run zk:setup` — re-runs the trusted setup from the circuit (new keys; the committed keys are the ones deployed).
- `npm run verify` — independent re-verification of the public Sepolia evidence for all four runs (bytecode, receipts, replayed revert errors, signatures, KKT re-check, netting certificate re-check, Groth16 proof re-verified off-chain with snarkjs, vendor attestation recovered, every accepted trade's bound recomputed from pre-trade reserves and its route replayed, the policy's target met, every clause of the on-chain policy re-checked for QE1, all three bounty pools intact, live invariants; 244 checks), in CI on every push and daily.
- `npm run redteam` — the corpus against the live language model alone and the guarded pipeline; report in `evidence/redteam/report.md`.

Clean-clone reproduction log

When (UTC)	Machine	Steps	Result
2026-10-19 16:50	Fresh Linux container with nothing installed (no Foundry, no keys, no prior state)	`git clone --recursive`, install Foundry 1.7.1 + solc 0.8.26 from their GitHub releases, `npm ci`, `forge build`, `forge test`, `npm run test:ts`	**67 / 67** Solidity tests and **42 / 42** TypeScript tests passed
2026-10-19 21:46	Fresh `git clone --recursive` of commit `dee4c07` into an empty directory (Foundry 1.7.1 toolchain present; no keys, no `node_modules`, no build output)	`npm ci`, `forge build`, `forge test`, `npm run test:ts`, `QED_OFFLINE=1 npm run local`, `npm run local:clearing`	**82 / 82** Solidity and **45 / 45** TypeScript tests passed; both economies ran end to end on a local chain (4 min 6 s)
2026-10-20 02:29	Fresh `git clone --recursive` of commit `aeaf628` into an empty directory (Foundry 1.7.1 toolchain present; no keys, no `node_modules`, no build output)	`npm ci`, `forge build`, `forge test`, `npm run test:ts`, `QED_OFFLINE=1 npm run local`, `npm run local:clearing`, `npm run local:private`	**104 / 104** Solidity and **50 / 50** TypeScript tests passed; all three economies ran end to end on a local chain, including a real Groth16 proof (4 min 49 s)
2026-10-20 13:40 IST	Fresh `git clone --recursive` of commit `87cb60c` into an empty directory (Foundry 1.7.1 toolchain present; no keys, no `node_modules`, no build output)	`npm ci`, `forge build`, `forge test`, `npm run test:ts`, `QED_OFFLINE=1 npm run local:execute`	**132 / 132** Solidity and **60 / 60** TypeScript tests passed; the best-execution economy and the standing-policy loop ran end to end with dev keys, the policy met its target (3 min 58 s)
2026-10-20 14:30 IST	Fresh `git clone --recursive` of commit `6acc29d` (final code) into an empty directory (Foundry 1.7.1 present; no keys, no `node_modules`, no build output)	`npm ci`, `forge build`, `forge test`, `npm run test:ts`, `QED_OFFLINE=1 npm run local:execute`	**145 / 145** Solidity and **60 / 60** TypeScript tests passed; the best-execution economy, the standing policy and the policy contract (12 refused attacks) ran end to end with dev keys (4 min 2 s)
every push + daily	GitHub Actions `ubuntu-latest`	`.github/workflows/ci.yml`: Solidity suite, TypeScript suite, all four economies on a local chain, benchmark reproducibility, `npm run verify` (all four runs) against public Sepolia	green

PART 8

QED — Reproducibility

Exact commands to rebuild, test, run, verify and re-derive every number we publish. Each block lists what you should see. Times are from a 4-core Linux container. Every command here runs in CI on every push (`.github/workflows/ci.yml`), and the clean-clone runs are logged in TESTING.md.

0. Toolchain

Tool	Version we used	Needed for
Node.js	22.x (22.22.0)	everything off-chain
Foundry (`forge`, `anvil`, `cast`)	1.7.1	contracts, local chains
solc	0.8.26 (fetched by forge; via-IR, optimizer 200, EVM cancun, no CBOR metadata)	bytecode reproduction
circom	2.2 (optional)	only to re-run the zk trusted setup
A Sepolia RPC	any public endpoint; archive state for historical checks	`npm run verify`, live runs

No API key is needed for anything below except `npm run redteam` (Anthropic) and live runs (your own funded keys).

1. Build from a clean clone (≈ 2 min)

```
git clone --recursive https://github.com/Nightcore709/qed-agent-wallet && cd qed-agent-wallet
npm ci
forge build
```

Expect `Compiler run successful`. Submodules: OpenZeppelin 5.1 and forge-std.

2. Tests (≈ 2½ min)

```
forge test          # expect: 145 tests passed, 0 failed   (≈ 100 s; invariants ≈ 350 k adversarial calls)
npm run test:ts     # expect: # tests 60  # pass 60        (≈ 35 s; starts its own anvil for TS ≡ Solidity
parity)
npm run typecheck   # expect: no output
```

`FOUNDRY_PROFILE=ci forge test` runs the heavier CI profile (5,000 fuzz runs, invariants 1,024 × 128).

3. Run every economy on a local chain, no keys (≈ 8 min in total)

```
QED_OFFLINE=1 npm run local            # main economy: paid work, conversation, 18 attacks, honeypot, pause
npm run local:clearing                 # five AI businesses in gridlock, 6 attacks, proven netting, settlement
npm run local:private                  # zero-knowledge job (real Groth16 proof), escrow, both theorem bounties
QED_OFFLINE=1 npm run local:execute    # best execution + the autonomous policy loop (below)
```

`QED_OFFLINE=1` uses the deterministic offline parser instead of the language model; the output says so. Evidence lands in `evidence/local*/`. Each script fails (non-zero exit) if any expected success reverts or any expected attack succeeds.

Exercise the autonomous agent. `local:execute` ends with the standing-policy loop of Run 4c, using deterministic dev keys. Its last lines must be:

```
  • PA1   An over-eager agent asks to convert 25.00 tUSD at once; the co-signer re-derives 19.535234 and refuses
  • T1    Agent observes 20.699566 tEUR free (short 24.300434) and decides to convert 19.535234 tUSD now —
limited by impact
  ✓ PE1   Agent converts 19.535234 tUSD → 16.816098 tEUR; bound 16.816101; reserve free 20.699566 → 37.515664
  • T2    Agent observes 37.515664 tEUR free (short 7.484336) and decides to convert 8.835281 tUSD now — limited
by need
  ✓ PE2   Agent converts 8.835281 tUSD → 7.484336 tEUR; bound 7.484339; reserve free 37.515664 → 45.00
  • T3    Agent observes 45.00 tEUR free: target met, nothing to do
```

The run then deploys `QEDTreasuryPolicy`, makes it the only operator, and replays Run 4d: `QA1` – `QA4` refused (NotOperator, OverConversion, ExecutionCostTooHigh, NoShortfall) and `QE1` converting 11.943294 tUSD → 10.00 tEUR.

These are the same figures, to the raw unit, as transactions `PE1`, `PE2` and `QE1` on Sepolia: the engine is deterministic and the local market is built exactly as the public one. Set `POLICY_IMPACT_BPS=50` and the agent refuses to trade at all (`T1 … waits: the market is too thin: any tranche ≥ 2000000 would pay more than 50 bps`): a policy it cannot honour produces no transaction, not a forced one.

4. Benchmarks (≈ 1 min, deterministic)

```
npx tsx benchmarks/run.ts
git diff --exit-code benchmarks/results.json    # expect: no diff (CI fails on any drift)
```

Only solver wall-clock time varies between machines; it is printed, not stored.

5. Re-verify the public evidence, with no keys (≈ 3 min)

```
npm run verify                                  # RPC_URL and ARCHIVE_RPC may be overridden
```

It checks, from a public Sepolia RPC: the bytecode of all 24 contracts against this build; every recorded receipt's status, sender and events; every reverted attack's custom error by replaying it on archive state; signatures recovered from calldata; the KKT certificate and the netting certificate re-checked; the Groth16 proof re-verified with snarkjs; for each accepted conversion (E1, E2, PE1, PE2) the bound recomputed from the pre-trade reserves, the route replayed and an independent optimum solved; the policy target met; all three bounty pools intact; Mallory received nothing. Expect `ALL CHECKS PASSED` (244 checks in CI on 20 Oct 2026, including every clause of the on-chain policy for QE1); the report is written to `evidence/ethereum-sepolia/verification.json`. In CI each failed check is also an annotation on the run.

6. Reproduce the deployed bytecode

```
node agent/scripts/sourcify-inputs.mjs          # regenerates verification/<Contract>.json (standard-JSON
inputs)
solc --standard-json < verification/QEDExecution.json > out.json   # solc 0.8.26
```

All 24 contracts are verified on Sourcify with creation and runtime match (verification/README.md).

7. Regenerate derived files

```
npm run fixtures:execution && forge test --match-contract QEDExecution   # Solidity fixtures from the TS engine
npm run evidence:md                                                       # docs/EVIDENCE.md from the manifests
npm run build:app                                                         # the dashboard (app/ → site/, dist/)
```

`agent/test/execution.test.ts` fails if the committed fixture drifts from the engine's output.

8. Your own run on Sepolia

1. `cp .env.example .keys.env` and generate fresh keys (the file shows a one-line generator); `.keys.env*` is gitignored.
2. Fund only the deployer with Sepolia ETH (≈ 0.05 ETH for the main run; the scripts send every other role its gas).
3. Run, with a fixed gas limit (Sepolia reprices state creation; see DEPLOYMENT.md):

```
RPC_URL=https://ethereum-sepolia-rpc.publicnode.com CHAIN_ID=11155111 GAS_LIMIT=16700000 \
  MAX_FEE_GWEI=0.02 PRIORITY_FEE_GWEI=0.01 REQUIRE_FIXED_GAS=1 npm run live
```

4. `npm run verify` then checks your run from your manifest (it writes to `evidence/ethereum-sepolia/`, so do this in your own clone).

Runs 2–4 (`clearing.ts`, `private.ts`, `execute.ts`, `execution-bounty.ts`, `execute-policy.ts`) read the same environment and key files and build on Run 1's contracts. We executed them through the replica pipeline below, not directly against a public RPC; pointing them at one should work the same way but is untested by us. The policy loop itself is exercised with dev keys by `local:execute` (§3).

9. How the canonical evidence was produced (replica and relay)

Our build sandbox had no outbound RPC, so each run was executed against a local replica of Sepolia and the signed bytes were broadcast unchanged:

```
# 1. replica: chain id 11155111, wall-clock timestamps, signers' nonces and ETH mirrored from Sepolia
KEYS_FILE=.keys.env.execution EXTRA_KEYS=.keys.env.clearing SCRIPT=agent/scripts/execute-policy.ts \
  SHADOW_OF=11155111 START_STATE='{"<deployer>":{"nonce":18,"wei":"…"},"<mallory>":{"nonce":17,"wei":"…"}}' \
  OUTBOX_SKIP=59 OUTBOX_NAME=outbox-11155111-execution-policy EVIDENCE_DIR=evidence/shadow-execution-policy \
  npx tsx agent/scripts/local.ts
# 2. the replica first replays the earlier runs' signed transactions byte for byte (agent/src/replica.ts) and
#    aborts if any hash or status differs; only the new transactions are exported (OUTBOX_SKIP)
# 3. relay: any machine with RPC access sends relay/outbox-*.json with eth_sendRawTransaction, grouped by sender,
#    and compares each public receipt's status and logs with the replica's → relay/receipts-*.json
# 4. finalize: agent/scripts/finalize-execution*.ts merges public receipts into evidence/ethereum-
sepolia/execution/
```

Run 4d (`agent/scripts/execute-policy-chain.ts`) also sets `ANVIL_GENESIS_TS` to a time before Run 4, so the replica replays Runs 4–4c **at their original block timestamps**: their certificates had expired by then, and a wall-clock replay would have diverged.

All 196 receipts matched (status and every log, excluding the chain's EIP-7708 system log). Because the hashes are of the exact signed bytes, anyone can confirm the relay changed nothing: `keccak256(raw)` of each outbox entry is the transaction hash on Etherscan.

PART 9

QED — Deployment & Operations

Live deployment (Ethereum Sepolia, chain id 11155111)

24 contracts, all verified on Sourcify with a creation and runtime bytecode match; the full table with explorer links is in `verification/README.md`, every transaction in `EVIDENCE.md`.

Run	Contracts	First block
1 · payments, escrow, honeypot	QEDVault (agent) `0x441f…8ca6` · ProofEscrow `0x2e33…ba9f` · MinVarianceVerifier `0x1d3e…dd05` · QEDLens `0x8461…f101` · TestUSD `0x7adb…3f35` (6 dp, `faucet()` 1,000/day) · QEDVault (honeypot, keys published) `0xe5b3…7f04`	11,948,657
2 · certified clearing	QEDClearing `0x7b7d…6ad2` · TestUSD (clearing) `0x6753…52d4`	11,949,578
3 · zero-knowledge job, bounties	Groth16Verifier `0xc043…4e7b` · PrivateMinVarianceVerifier `0x1270…b453` · OptimalityBounty `0xfc21…b677` · MaximalityBounty `0xd767…7d69`	11,951,192
4 · best execution	QEDExecution `0x8e2e…9481` · QEDVault tUSD treasury `0x04d1…d117` · QEDVault euro reserve `0x6fb7…9c53` · tEUR `0x98d1…362f` · tETH `0xf61c…580f` · CPMMPool ×5 (`0xf88d…8a58`, `0x1fd2…6031`, `0x4422…829b`, `0x7067…dbfa`, `0x8155…1c64`)	11,952,692
4b · execution bounty	ExecutionBounty `0x3148…19c4` (1,000 tUSD)	11,952,779
4d · the policy as a contract	QEDTreasuryPolicy `0xf7f2…69e7` (QEDExecution's operator since block 11,954,081)	11,954,079

Machine-readable: `deployments/11155111.json` (Run 1) and the `contracts` block of each run's `evidence/ethereum-sepolia/**/manifest.json`.

Prerequisites

- Node 22, npm
- Foundry (`forge`, `anvil`, `cast`) — `curl -L https://foundry.paradigm.xyz | bash && foundryup`
- `git clone --recursive` (OpenZeppelin 5.1 and forge-std are submodules)

```
npm ci
forge build           # solc 0.8.26, via-IR, optimizer 200 runs
```

Local (no keys, no network)

```
anvil &                           # or let the script start one
QED_OFFLINE=1 npm run local       # deterministic dev keys, offline brain
```

Evidence lands in `evidence/local/`; build the dashboard against it with `EVIDENCE=evidence/local npm run build:app`.

Public network

1. `cp .env.example .keys.env` and fill in **fresh** keys (one per role). `.keys.env*` is gitignored.
2. Fund only the deployer; the script funds every other role with exactly the gas it needs.
3. Run:

```
RPC_URL=https://ethereum-sepolia-rpc.publicnode.com CHAIN_ID=11155111 \
GAS_LIMIT=16700000 MAX_FEE_GWEI=0.02 PRIORITY_FEE_GWEI=0.01 REQUIRE_FIXED_GAS=1 \
npm run live
```

The orchestrator spawns the co-signer (port 7701), vendor (7702) and agent (7703) as **separate processes, each given exactly one private key**, and records every step into `evidence/<network>/manifest.json`.

Why a fixed gas limit on Sepolia

Sepolia currently prices state creation far above the classic schedule (a plain transfer to a fresh account ≈ 205 k gas; deploying the 9.1 KB vault ≈ 15 M gas) and EIP-7825 caps any transaction at $2^{24} = 16\,777\,216$ gas. Local nodes don't model this, so `eth_estimateGas` against a replica under-estimates. Every transaction therefore carries `GAS_LIMIT=16700000`; only gas **used** is charged. `REQUIRE_FIXED_GAS=1` makes every process refuse to send without it.

Signing without RPC egress (how the canonical evidence was produced)

`SHADOW_OF=11155111 npm run local` runs the same economy against an anvil replica (chain id 11155111, `osaka`, wall-clock timestamps, deployer nonce/balance mirrored from Sepolia), then `agent/scripts/outbox.ts` exports the signed raw transactions in canonical order to `relay/outbox-11155111.json`. Any machine with RPC access can broadcast them unchanged (`eth_sendRawTransaction`) and compare each receipt with the replica's (`shadowStatus`, `shadowLogs`). `npm run resume` rebuilds the replica by replaying the exact bytes already on-chain and continues the scenario.

Operations runbook

Situation	Action	Who
Suspected agent or co-signer compromise	`pause()`	guardian or owner
Invalidate every outstanding mandate and certificate	`bumpEpoch()`	owner
Revoke one mandate	`revokeMandate(hash)`	owner
Rotate keys	`setAgent` / `setCosigner` / `setGuardian`	owner
Change the global 24 h cap	`setDailyCap`	owner
Resume	`unpause()`	owner only
A creditor's bill is due	`settle(id)`	anyone — works while paused
Change the venues the agent may trade on	`QEDExecution.setVenues(pools, fees)`: each declared fee is cross-checked against the pool's own `feeBps()`; the new venue-set hash invalidates every outstanding signed order	vault owner
Rotate the trading hot key	`QEDExecution.setOperator(addr)`	vault owner
Withdraw the agent's trading authority entirely	`QEDVault.setAgent(other)` — QEDExecution then cannot move funds at all	vault owner
Change or stop the standing treasury policy	`QEDTreasuryPolicy.setPolicy(p)` or `revoke()` (immediate); also expiry, a new operator, or `pause()` of the vault	vault owner
Rotate the agent key under the policy	`QEDTreasuryPolicy.setAgent(addr)`	vault owner

Monitor: `QEDExecution.quoteBound(amountIn, tokenIn, tokenOut, prices)` is a free view that returns the bound any route would be measured against, so a monitor can price every pending order before it lands; `BestExecution` events record input, spent, output and bound for every accepted trade. `QEDLens.snapshot(vault)` returns balance, ring-fenced, free, 24 h blast radius, open liabilities, epoch and paused state in one call; the dashboard polls it live.

PART 10

QED — Known limitations

What QED does not do, what it assumes, and what we have not verified. Security risks are catalogued with severities in SECURITY.md §5 (K1–K29); this page groups them with the product, engineering and evaluation limits so a reviewer can see the whole boundary in one place.

1. Status

- **Testnet prototype.** Ethereum Sepolia only, valueless tokens (tUSD, tEUR, tETH), demo-size liquidity. Do not use with real funds (K13).
- **Not audited.** No external audit, no formal verification of the contracts or the zk circuit (K19). The security self-assessment is ours.
- **Not production-ready** in the sense of an operated service: no HSM or KMS signers, no monitoring or alerting service, no co-signer quorum, no upgrade path (contracts are deliberately immutable). SECURITY §5a lists what production would need.

2. Best execution (`QEDExecution`)

Limit	Consequence	Where it is discussed
The proof is about the state the trade executes on	A front-runner who moves every venue changes what is optimal; the bound follows. Moves larger than the co-signed 1% floor revert (EA8); smaller ones are not caught	ALGORITHMS §12.7, K23
Venues must be honest constant-product pools with the declared fee	A malicious pool could report reserves unrelated to its swap behaviour. Only the vault owner names venues; fees are cross-checked	K22
Constant-product venues only	Uniswap V3-style concentrated liquidity, Curve stable-swap and order books are not covered by the bound; their per-venue term has a (piecewise) closed form that we did not implement	K26
The bound covers the owner's venue set, not the whole market	"Best" means best through the venues the owner allowed; a better price elsewhere is out of scope by design	ALGORITHMS §12.4
Integer granularity	Rounding costs up to one raw unit of output per hop; $\tau = 1$ ppm is too tight for outputs of a few raw units. The co-signer sets τ adaptively (1–100 ppm)	K24, BENCHMARKS B2
Gas is not in the objective	An output-optimal route may use more hops than a cheaper near-optimal one	K25
Prices and route are public	The proof is computed by the chain, not in zero knowledge, so the trade reveals its route	ALGORITHMS §12.7
Path deficiency is taken from the literature	Theorem 12.3 uses it as a lemma; we test it (3,000 random cases) rather than re-prove it	ALGORITHMS §12.3

3. Autonomy

Limit	Consequence	Where
Policy liveness is off-chain	Since Run 4d `QEDTreasuryPolicy` enforces the policy's safety clauses on-chain (shortfall, bounds, cost, no provable over-conversion beyond the owner's slack σ). It cannot force an agent to act: a slow or idle agent costs the owner time, not money	K28
Impact is per tranche against the current mid	Successive tranches can move the price further in total; no cumulative budget or TWAP reference yet	K29, ALGORITHMS §12.8
One objective type	The live policy keeps a reserve topped up. Other objectives (rebalancing to weights, paying a schedule of invoices in foreign currency) would reuse the same loop but are not implemented	—
The language model is a parser, not a planner	It reads owner instructions; deterministic code decides amounts and routes. This is a deliberate safety choice, not a capability claim	ALGORITHMS §8

Limit	Consequence	Where
No scheduler in the repository	Run 4c's ticks run in sequence inside one script; a deployed agent would run the same loop on a timer or on events	—

4. The rest of QED

- **Clearing:** obligations are acknowledgements, not escrowed funds (K17); griefing by tiny obligations fails safe (K15).
- **Private optimality:** the Groth16 setup is a single-machine ceremony and must be trusted (K18); the circuit is fixed at $n = 6$ assets.
- **Paid work:** one problem class (long-only minimum variance) has a certificate verifier; others need their own.
- **Guard:** regex-based and heuristic; it is defence in depth, never the binding control (K7).

5. Evaluation limits

- **Benchmarks are on synthetic markets** (fixed seeds, 1,000 random markets), not on historical mainnet pool states. They measure what a proof buys over routing policies *without* one; they do not measure any named aggregator. For small trades in deep markets a good router is already within about 3 bps, so there the proof's value is the guarantee, not the average (BENCHMARKS B1).
- **The red-team corpus is ours** (32 cases); it shows the architecture's behaviour, not coverage of all attacks.
- **No user study** and no traction claims.

6. How the evidence was produced

The build sandbox had no outbound RPC. Every transaction was signed in the sandbox against a replica of Sepolia and the identical bytes were broadcast through a browser relay; all 196 public receipts matched the replica (status and logs). Two early attempts under other keys were abandoned and are disclosed (K12, EVIDENCE.md). The keys of the very first run were lost in a container reset, so that run cannot sign again; its evidence is unaffected.

7. Not verified

- Behaviour on mainnet gas schedules and with real MEV searchers.
- Interaction with tokens that charge fees on transfer or rebase (K9: unsupported).
- Liveness of the dashboard's live reads: it falls back to the committed snapshot when a public RPC is unreachable.
- Long-running operation: every run is a scripted scenario of minutes to hours.

APPENDIX A

QED — On-chain Evidence (Ethereum Sepolia)

> Generated from `evidence/ethereum-sepolia/manifest.json` and `evidence/ethereum-sepolia/receipts.json` by `npm run evidence:md`. Re-derive every line from the public chain with `npm run verify` (no keys needed).

Network	Ethereum Sepolia (chain id 11155111)
Blocks	11,948,657 → 11,949,339
Transactions	55 (36 succeeded · 19 reverted **by design** — every one an attack or a paused-vault test)
Plus Run 4 (best execution, execution bounty, standing policy)	73 more transactions — see below
Plus Run 3 (zero-knowledge job, bounties)	24 more transactions — see below
Plus Run 2 (certified clearing)	44 more transactions on a separate contract — see below
Off-chain signed artefacts	7 (mandate, quote, certificate, vendor release, conversation, red-team) — hashes anchored on-chain
Total gas	66,358,024
Language model in the loop	anthropic:claude-sonnet-5-5

Contracts

Contract	Address	Deployment tx
QEDVault — the agent's vault	`0x441f71f12a1f8a3b7d432851d4d4244fc33e8ca6`	`0xf4b13b49…80a5`
ProofEscrow	`0x2e3362d6dc88c40cf95f885c44fe8fff9979ba9f`	`0x84e391b5…e83d`
MinVarianceVerifier	`0x1d3eced4bd1cef7edc315315b9fd6acae283dd05`	`0x903d0e80…2589`
QEDLens	`0x846186f21227793760429696bb4fd7490236f101`	`0xf67a8e98…e8d9`
TestUSD (tUSD)	`0x7adb609421e30b3df3063ff2de9d425564893f35`	`0x209da471…7dd4`
QEDVault — HONEYPOT (keys published)	`0xe5b3e7773115dba454e7e40fa97a5d3e332c7f04`	`0xde7ac12c…1438`

Actors (one key each, one process each)

Role	Address
deployer	`0x297ea575224e00FeF5a94c8f046af3540Fd60D5d`
owner	`0xb7Ed1049456550Cbd8e1C6578A8cF1DD495797f7`
agent	`0x2A101d90D3E502bDBd4a06c6712cA7D240A9d0Bb`
cosigner	`0xf1F8941003702C5141977Ee0E9E03A45a9f62402`
guardian	`0x22842F73B4596735d1b55DCaeEC10c5f48522e0E`
client	`0x286C262a6B324a56C84057d9B11a6F3A02232d18`
vendor	`0x6Bb74076b522a9d38c62EC7dF914274e121fFAb8`
creditor	`0x2d3e8af597fcA9F4ecDc41C69F2956EDd6f1CB78`
mallory	`0x3BDB7Ed120ff19453EA5A1e59A60AB72D7f2Dc7e`
hpAgent	`0x22f224dd5Db8344E6474c9d165DC273E96c173F5`
hpOwner	`0x8B3fB35964E882513b44a01Ca41B3AC626200eDc`
hpCosigner	`0x35b370861B06aA2a372f02BdF027f5E324153ab7`

Every step of the scenario

Step	What happened	Actor	Result	Transaction	Block	Gas
D1	Deploy TestUSD (valueless 6-dp test stablecoin)	Deployer	success	`0x209da471…7dd4`	11948657	3,716,239
D2	Deploy MinVarianceVerifier (on-chain KKT optimality checker)	Deployer	success	`0x903d0e80…2589`	11948657	3,847,926
D3	Deploy ProofEscrow (work settles on proof, not trust)	Deployer	success	`0x84e391b5…e83d`	11948657	9,051,450
D4	Deploy QEDVault for the QED agent	Deployer	success	`0xf4b13b49…80a5`	11948657	14,963,244
D5	Deploy the HONEYPOT vault (agent + co-signer keys published)	Deployer	success	`0xde7ac12c…1438`	11948657	14,963,232
D6	Deploy QEDLens (stateless on-chain views: blast radius, snapshots, EIP-712 digests)	Deployer	success	`0xf67a8e98…e8d9`	11948658	8,026,770
S1	Owner deposits 100 tUSD into the agent's vault	Owner	success	`0xdbbc3dd1…a139`	11948660	148,905
S2	Owner ring-fences 70 tUSD for CloudCo's compute bill (protected liability #1)	Owner	success	`0xbbdb4d37…253b`	11948660	800,291
S3	Owner signs the operating mandate off-chain (EIP-712) — no transaction, no gas	Owner	off-chain, signed	`0xc4cd1e885a…`		
L1	QED agent evaluates the RFQ and signs a quote: 15.00 tUSD	QED agent	off-chain, signed	`0xd9e55c9e6e…`		
L2	Client funds the escrow with the agent-signed quote (job #1, 15 tUSD)	Client (Northwind)	success	`0xa0546be0…46b9`	11948661	1,389,524
L3	Independent co-signer passes 12 checks and issues a payment certificate	Co-signer	off-chain, signed	`0xb0dd4c9948…`		
L4	AGENT KEY pays Helix 6 tUSD under owner mandate + co-signer certificate	QED agent	success	`0x56a2334e…83b6`	11948662	747,079
L5	Vendor sees the payment on-chain and releases the licensed risk model	Helix Data	off-chain, signed	—		
L6	Agent delivers the optimal portfolio + KKT certificate → escrow verifies on-chain → 15 tUSD settles into the vault	QED agent	success	`0x4166253f…35f9`	11948662	424,082
C1	Owner-confirmed chat payment: 3 tUSD to Helix (clarified, corrected, signed)	QED agent	success	`0x7000d3cc…5ee3`	11948662	236,892
C2	Forward payment: agent PROMISES Helix 4 tUSD in 7 days — ring-fenced on creation	QED agent	success	`0xf0658094…bcad`	11948662	691,012
C3	Red-team conversation: induced transfer, data extraction, privilege escalation, prompt injection — all refused	Owner ⇄ QED agent	off-chain, signed	—		
X1	Prompt injection inside a counterparty RFQ: instruction ignored, legitimate work still quoted	Mallory → QED agent	off-chain, signed	—		
X2	Client-side tampering: open escrow with the agent's quote but price 15 → 1 tUSD	Mallory	**reverted** · `BadProviderSignature`	`0xf5f2dff7…c917`	11948664	45,976
X3	Client-side tampering: redirect the agent's payee to Mallory	Mallory	**reverted** · `BadProviderSignature`	`0x86cda26b…2902`	11948664	45,976
X4	Worst case: the LLM obeys the injection and requests payment → independent co-signer REFUSES	Co-signer	off-chain, signed	`0xdb5718a9f2…`		
X5	Stolen AGENT key + co-signature forged by Mallory → pay Mallory 25	Mallory	**reverted** · `BadCosignerSignature`	`0xd3e5a89f…d3ab`	11948665	91,032

Step	What happened	Actor	Result	Transaction	Block	Gas
X6	Stolen AGENT key + stolen CO-SIGNER key → genuinely signed certificate paying Mallory	Mallory	**reverted** · `PayeeNotInMandate`	`0xf9a023d7…c018`	11948665	91,032
X7	Stolen keys + a mandate Mallory signed herself (payee: Mallory, cap 1000)	Mallory	**reverted** · `BadOwnerSignature`	`0xa9b9a57f…a9f5`	11948665	88,984
X8	Harvest the agent's real certificate from calldata; change amount 6 → 9	Mallory	**reverted** · `BadCosignerSignature`	`0xc84501ca…09b9`	11948665	91,032
X9	Same genuine certificate redirected to another approved payee	Mallory	**reverted** · `BadCosignerSignature`	`0xca320184…4b87`	11948665	91,032
X10	Replay the exact genuine certificate	Mallory	**reverted** · `IntentAlreadyUsed`	`0xca786a4e…2957`	11948665	91,032
X11	Both hot keys: pay CloudCo 33.00 tUSD — one dollar more than the free balance	Mallory	**reverted** · `SolvencyViolation`	`0x5835240c…2e09`	11948665	91,032
X12	Both hot keys: pay CloudCo 13.00 tUSD — above the remaining 24h window	Mallory	**reverted** · `ExceedsDailyCap`	`0x6b4b0b71…e354`	11948665	91,032
X13	Stolen agent key calls withdraw()	Mallory	**reverted** · `NotOwner`	`0xb988e05e…bcec`	11948665	19,352
X14	Stolen agent key tries to release CloudCo's ring-fence	Mallory	**reverted** · `NotCreditor`	`0x9c908ed0…aaee`	11948665	19,852
X15	Stolen agent key tries setDailyCap(max)	Mallory	**reverted** · `NotOwner`	`0x48b6a13b…c2a8`	11948665	17,524
X16	Client hires Mallory instead (cheaper: 9 tUSD) — job #2 funded	Client (Northwind)	success	`0x952b0913…6f8d`	11948666	1,291,592
X17	Mallory delivers a lazy 1/N portfolio dressed with the best possible multipliers	Mallory	**reverted** · `DualityGapTooLarge`	`0x5a6f26ac…6481`	11948667	191,384
X18	Mallory delivers an 'almost optimal' portfolio (optimum shifted by 0.01%)	Mallory	**reverted** · `StationarityViolated`	`0xc269055a…f0fe`	11948668	191,384
H1	Honeypot owner deposits 100 tUSD	Honeypot owner	success	`0xe6553dd5…7279`	11948669	148,905
H2	Honeypot owner ring-fences 90 tUSD for CloudCo until 30 Jun 2027	Honeypot owner	success	`0x1826c4bb…ebd9`	11948669	800,291
H3	Using ONLY the published keys: pay CloudCo 1 tUSD (allowed — proves the keys are real)	Anyone (published keys)	success	`0xd401d7e9…7de6`	11948670	746,554
H4	Published keys: pay Mallory 10 tUSD	Mallory	**reverted** · `PayeeNotInMandate`	`0x9f1f19d5…23b7`	11948670	88,984
H5	Published keys: pay CloudCo 50 tUSD early	Mallory	**reverted** · `ExceedsPerPaymentCap`	`0xf30a4765…1b4f`	11948670	88,984
H6	Published agent key: withdraw()	Mallory	**reverted** · `NotOwner`	`0x887cab2c…3c3f`	11948670	19,352
X19	Mallory missed the deadline with a valid proof → anyone refunds the client	Client (Northwind)	success	`0x014cb969…4b83`	11949335	63,177
P1	Guardian hits the kill-switch: vault paused	Guardian	success	`0x282afb62…640b`	11949336	31,188

Step	What happened	Actor	Result	Transaction	Block	Gas
P2	While paused, even a fully valid agent payment is refused	QED agent	**reverted** · `VaultPaused`	`0x6750861d…0b0f`	11949337	91,032
P3	Bill due while paused: MALLORY triggers settlement — CloudCo receives exactly 70 tUSD	Mallory (as a stranger)	success	`0x9f4a753c…135d`	11949338	89,792
P4	Owner reviews and unpauses	Owner	success	`0x6ba8db0a…243c`	11949339	30,815

Attack transactions (19) — each reverted with exactly the designed error

Step	Attack	Defence (custom error)	Layer
X2	Client-side tampering: open escrow with the agent's quote but price 15 → 1 tUSD	`BadProviderSignature`	ProofEscrow
X3	Client-side tampering: redirect the agent's payee to Mallory	`BadProviderSignature`	ProofEscrow
X5	Stolen AGENT key + co-signature forged by Mallory → pay Mallory 25	`BadCosignerSignature`	QEDVault
X6	Stolen AGENT key + stolen CO-SIGNER key → genuinely signed certificate paying Mallory	`PayeeNotInMandate`	QEDVault
X7	Stolen keys + a mandate Mallory signed herself (payee: Mallory, cap 1000)	`BadOwnerSignature`	QEDVault
X8	Harvest the agent's real certificate from calldata; change amount 6 → 9	`BadCosignerSignature`	QEDVault
X9	Same genuine certificate redirected to another approved payee	`BadCosignerSignature`	QEDVault
X10	Replay the exact genuine certificate	`IntentAlreadyUsed`	QEDVault
X11	Both hot keys: pay CloudCo 33.00 tUSD — one dollar more than the free balance	`SolvencyViolation`	QEDVault
X12	Both hot keys: pay CloudCo 13.00 tUSD — above the remaining 24h window	`ExceedsDailyCap`	QEDVault
X13	Stolen agent key calls withdraw()	`NotOwner`	QEDVault
X14	Stolen agent key tries to release CloudCo's ring-fence	`NotCreditor`	QEDVault
X15	Stolen agent key tries setDailyCap(max)	`NotOwner`	QEDVault
X17	Mallory delivers a lazy 1/N portfolio dressed with the best possible multipliers	`DualityGapTooLarge`	MinVarianceVerifier
X18	Mallory delivers an 'almost optimal' portfolio (optimum shifted by 0.01%)	`StationarityViolated`	MinVarianceVerifier
H4	Published keys: pay Mallory 10 tUSD	`PayeeNotInMandate`	QEDVault
H5	Published keys: pay CloudCo 50 tUSD early	`ExceedsPerPaymentCap`	QEDVault
H6	Published agent key: withdraw()	`NotOwner`	QEDVault
P2	While paused, even a fully valid agent payment is refused	`VaultPaused`	QEDVault

Set-up transactions (funding, mints, approvals)

#	Transaction	What	Block
6	`0x04dad896…0170`	Fund gas: owner (0.003 ETH)	11948658
7	`0xbe80e5de…29a6`	Fund gas: agent (0.004 ETH)	11948658
8	`0x20134f85…5b49`	Fund gas: client (0.002 ETH)	11948658
9	`0x7e261aca…074d`	Fund gas: Mallory (0.004 ETH)	11948658
10	`0xa6179d11…b41f`	Fund gas: guardian (0.001 ETH)	11948658

#	Transaction	What	Block
11	`0xfd346ae4…0131`	Fund gas: honeypot owner (0.002 ETH)	11948658
12	`0xd47563a3…1231`	Fund gas: honeypot agent (0.002 ETH)	11948659
13	`0x63d04fe7…5ff9`	Mint 100 tUSD to owner	11948659
14	`0x75ea1d95…242d`	Mint 100 tUSD to client (Northwind)	11948659
15	`0x57128e5f…8303`	Mint 100 tUSD to honeypot owner	11948659
16	`0xda52f56f…a20b`	Owner approves vault	11948660
19	`0x7f7b5268…71e2`	Client approves escrow	11948661
25	`0xfbdefe11…6083`	Mint 50 tUSD to Mallory	11948663
26	`0x6a54f559…8fec`	Mallory approves escrow	11948664
43	`0xf4482304…09e9`	Honeypot owner approves honeypot vault	11948669

Final state (read from QEDLens after the last transaction)

	Balance	Ring-fenced	Free	24 h blast radius
Agent vault	36.00	4.00	32.00	32.00
Honeypot vault	99.00	90.00	9.00	1.00

Token balances: CloudCo (creditor) 71.00 · Helix (vendor) 9.00 · Northwind (client) 85.00 · Mallory 50.00 (all of it minted to her for the test; **0 from any vault or the escrow**).

Run 2 — certified clearing of an agent economy (QEDClearing)

> `evidence/ethereum-sepolia/clearing/manifest.json` , `receipts.json` , `proof.json` . Separate keys, separate token, separate contract; `npm run verify` re-checks it too, including an independent re-check of the netting certificate taken from the executed calldata.

Blocks	11,949,578 → 11,949,690
Transactions	44 (37 succeeded · 7 reverted **by design**)
Gross debt between 5 AI businesses	200.00 tUSD in 11 obligations; cash held in total 28.00 tUSD
Naive netting (shortest cycles first)	162.00 — **refused on-chain** as `NotProvablyMaximal`
Proven-maximal netting	169.00 cancelled with the LP-duality certificate Σx = Σdᵧ checked in exact integers
Settled with tokens afterwards	31.00 tUSD; open obligations at the end: 0

Contract	Address
QEDClearing	`0x7b7de15772198d82d07019fc816cffc52e7d6ad2`
TestUSD (clearing run)	`0x6753a8ea4560f07534bcfbca2dea790afb9552d4`

Role	Address
deployer	`0x94C938E642BbC657D5F45546E35268a70c936448`
northwind	`0x053DCBCaEF06A44feAeFd94A2DbE9F160E789816`
qed	`0x0460e0d0753E487b3a5E26FE8cf16A4baC6C918d`
cloudco	`0x0418CfE812572f01535Fb260b6a77dAb5704D737`
helix	`0xE21F926030fd77Ad4EFEbd1b22D6633cda3499C7`
atlas	`0x13958b9C4154996E6Db79f9a86c5765e0D6048AF`

Role	Address
mallory	`0x56D161255Ced6863698eA3c6a886982088fa30a8`

Step	What happened	Actor	Result	Transaction	Block	Gas
K1	Deploy the clearing run's TestUSD (valueless; minter = this run's deployer)	Deployer	success	`0x627457ae…5865`	11949578	3,716,239
K2	Deploy QEDClearing (proof-gated multilateral netting)	Deployer	success	`0x58efadf2…d140`	11949578	8,579,134
J1	Northwind joins the clearing house	Northwind	success	`0x73dc94e3…03ab`	11949579	348,185
J2	QED joins the clearing house	QED	success	`0xba620589…537d`	11949580	250,265
J3	CloudCo joins the clearing house	CloudCo	success	`0x4e6748d9…aa6b`	11949581	250,265
J4	Helix joins the clearing house	Helix	success	`0x2b3c68ee…6229`	11949582	250,265
J5	Atlas joins the clearing house	Atlas	success	`0x03e19549…30ca`	11949583	250,265
I1	Northwind owes QED 40 tUSD (portfolio subscription)	Northwind	success	`0x7b808c9a…3cee`	11949584	795,367
I2	QED owes CloudCo 30 tUSD (GPU compute)	QED	success	`0xbd67bb55…a165`	11949585	501,607
I3	CloudCo owes Helix 25 tUSD (data licence)	CloudCo	success	`0xadfa6dc4…8c32`	11949586	501,619
I4	Helix owes Northwind 20 tUSD (advisory fees)	Helix	success	`0x8b216187…75e5`	11949587	501,607
I5	QED owes Helix 15 tUSD (risk model)	QED	success	`0x7a0649e1…680f`	11949588	501,607
I6	Helix owes QED 15 tUSD (model validation)	Helix	success	`0x280d6f94…4d71`	11949589	501,607
I7	CloudCo owes Northwind 12 tUSD (volume rebate)	CloudCo	success	`0x59af539e…e0c0`	11949590	501,595
I8	Northwind owes CloudCo 10 tUSD (hosting)	Northwind	success	`0x57bc03f7…1398`	11949591	501,607
I9	Atlas owes QED 18 tUSD (backtests)	Atlas	success	`0xf5c02f7a…e673`	11949592	501,619
I10	Helix owes Atlas 9 tUSD (data cleaning)	Helix	success	`0x8bfe4d58…b7a2`	11949593	501,607
I11	CloudCo owes Atlas 6 tUSD (labelling)	CloudCo	success	`0x0ed4ee56…ee96`	11949594	501,607
G1	Gridlock: Northwind tries to pay its 40 tUSD debt gross, but holds 18	Northwind	**reverted** · `ERC20InsufficientBalance`	`0x7d86cdc9…3b2c`	11949599	87,944
P0	QED agent proves the maximal netting: 169.00 of 200.00 tUSD can be cancelled	QED agent	off-chain	—		
N1	Lazy netting (shortest cycles first): cancels 162.00, not 169.00	Mallory / rival clearing bot	**reverted** · `NotProvablyMaximal`	`0x1b62ae8c…4976`	11949600	162,976
N2	Netting that quietly cancels 1 tUSD more of Northwind's debt to QED	Mallory / rival clearing bot	**reverted** · `NetPositionChanged`	`0x29c4ef66…3eaf`	11949600	164,780
N3	Netting that cancels more than an obligation is worth	Mallory / rival clearing bot	**reverted** · `ExceedsObligation`	`0x96a304a4…bdfb`	11949600	138,136

Step	What happened	Actor	Result	Transaction	Block	Gas
N4	Netting over a snapshot that hides one obligation	Mallory / rival clearing bot	**reverted** · `IncompleteSnapshot`	`0xd6c3f25c…4c9c`	11949600	129,944
N5	Forged certificate: drop a dual multiplier to fake a smaller bound	Mallory / rival clearing bot	**reverted** · `DualInfeasible`	`0xa7d7e7bc…ef8a`	11949600	138,136
N6	Proven-maximal netting executes: 169.00 tUSD of debt cancelled, 200.00 → 31.00	QED agent	success	`0x46288ece…05a2`	11949601	550,826
N7	Replay the executed netting	Mallory / rival clearing bot	**reverted** · `IncompleteSnapshot`	`0x4588659b…4df5`	11949602	138,136
S1	Northwind pays QED the remaining 18.00 tUSD	Northwind	success	`0x8e6ffd33…358c`	11949687	190,980
S2	CloudCo pays Atlas the remaining 3.00 tUSD	CloudCo	success	`0x8be4b11f…8ebf`	11949688	93,060
S3	Helix pays QED the remaining 4.00 tUSD	Helix	success	`0xe8af7d69…0648`	11949689	93,060
S4	Atlas pays QED the remaining 6.00 tUSD	Atlas	success	`0xb69b59c9…a654`	11949690	91,741

Final token balances equal each agent's net position: Northwind 0.00 · QED 28.00 · CloudCo 0.00 · Helix 0.00 · Atlas 0.00. Mallory received 0.

Set-up transactions of this run (funding, mints): `0xda9bfc81…7390`, `0x8e8c0c3f…f2b6`, `0xbb7e24a6…a102`, `0xd23466d2…5222`, `0xe0a46cd9…001a`, `0xd0ba9980…c4c9`, `0x0ce9e106…3182`, `0x3e69b56d…19f5`, `0x0dc85d8e…de39`, `0x5e9ad960…91dc`, `0xab31a916…1411`, `0x63e9af20…40d2`, `0xe2af5f53…991b`, `0x97a1b6f6…7320`.

Run 3 — zero-knowledge optimality and theorem bounties (QED Private)

> `evidence/ethereum-sepolia/private/manifest.json`, `receipts.json`. Built on the main run's ProofEscrow, TestUSD and MinVarianceVerifier; `npm run verify` re-verifies the Groth16 proof off-chain with snarkjs, recovers the vendor's attestation from calldata and checks both bounty pools.

Blocks	11,951,192 → 11,951,215
Transactions	24 (16 succeeded · 8 reverted **by design**)
Private job	job #3: 12.00 tUSD paid into QED's vault on a Groth16 proof (12,569 constraints, proved in 1.5 s)
What the chain saw	data commitment `0x0ec573bb27cdf14a…` (attested by Helix), portfolio commitment `0x057717d386e492ea…`, variance 0.0015702689, provider
Bounties	1000.00 + 1000.00 tUSD unclaimed after every refutation attempt

Contract	Address
Groth16Verifier	`0xc04329693c7b464ab636107b31dcf6746e204e7b`
PrivateMinVarianceVerifier	`0x1270287aaf21f6cc939c255fc1ba294d9268b453`
OptimalityBounty	`0xfc2129f0432538d034c5307299022b3d369eb677`
MaximalityBounty	`0xd767782fc47eefdfc2d764dba1b2ec0a0b557d69`

Role	Address
deployer	`0x94C938E642BbC657D5F45546E35268a70c936448`
client	`0x053DCBCaEF06A44feAeFd94A2DbE9F160E789816`
qed	`0x0460e0d0753E487b3a5E26FE8cf16A4baC6C918d`
helix	`0xE21F926030fd77Ad4EFEbd1b22D6633cda3499C7`

Role	Address
sponsor	`0x13958b9C4154996E6Db79f9a86c5765e0D6048AF`
mallory	`0x56D161255Ced6863698eA3c6a886982088fa30a8`

Step	What happened	Actor	Result	Transaction	Block	Gas
K3	Deploy the Groth16 verifier generated from circuits/private_minvar.circom	Deployer	success	`0xe7edce9a…85ea`	11951192	2,635,710
K4	Deploy PrivateMinVarianceVerifier (registered data vendor: Helix)	Deployer	success	`0xf28684ac…9868`	11951193	3,420,169
K5	Deploy OptimalityBounty on the verifier that settled job #1	Deployer	success	`0x2e91dbe5…cc1b`	11951194	3,393,875
K6	Deploy MaximalityBounty on the clearing house's acceptance rule	Deployer	success	`0x487d5e0b…138a`	11951195	4,400,401
B1	QED funds the optimality bounty: 1,000 tUSD	Deployer	success	`0x616b0fb1…3775`	11951197	128,918
B2	Atlas funds the maximality bounty: 1,000 tUSD	Atlas	success	`0xdf74e4c8…d614`	11951199	128,918
V0	Helix attests its Private Markets model by commitment only	Helix (data vendor)	off-chain	—		
Q1	QED quotes 12 tUSD for the provably optimal private portfolio; Mallory undercuts at 8	QED agent / Mallory	off-chain	—		
Z1	Northwind funds job #3 in the same ProofEscrow: 12 tUSD, verifier = zero-knowledge	Northwind (client)	success	`0xed610de8…70b3`	11951202	1,291,592
Z2	Northwind also funds Mallory's cheaper job #4: 8 tUSD	Northwind (client)	success	`0x8f0fe4d2…bf01`	11951203	1,193,672
P1	QED proves the portfolio optimal in zero knowledge (1.5 s on one CPU)	QED agent	off-chain	—		
Z3	QED delivers the zero-knowledge proof: the escrow verifies it and pays 12 tUSD into QED's vault	QED agent	success	`0xbb619bf0…2ec7`	11951204	530,050
ZA1	Mallory copies QED's proof from the public calldata into her own job	Mallory	**reverted** · `ProofRejected`	`0xbe69abd9…d28e`	11951205	269,489
ZA2	Mallory claims a lower variance than any portfolio can achieve	Mallory	**reverted** · `ProofRejected`	`0x95426566…9431`	11951206	269,501
ZM	Mallory opens a self-dealt job #5 on a data set she attested herself	Mallory	success	`0xd721136c…9a44`	11951209	1,190,784
ZA3	Mallory delivers a genuine proof about self-attested data	Mallory	**reverted** · `UntrustedDataAttestation`	`0x35bbaa47…25b7`	11951210	62,360
BA1	Mallory claims the 1,000 tUSD bounty with the equal-weight portfolio against QED's job #1 certificate	Mallory	**reverted** · `TheoremHolds`	`0x6a584945…d19d`	11951211	219,644
BA2	…and with QED's own optimum shifted by 0.1%	Mallory	**reverted** · `TheoremHolds`	`0xb9fbcad2…e059`	11951212	219,344
BA3	…and with the forged 1/N certificate the chain refused in job #2 (X17)	Mallory	**reverted** · `DualityGapTooLarge`	`0x68e498bb…1c35`	11951213	205,720
BM1	Mallory claims the clearing bounty with the naive netting (162 tUSD)	Mallory	**reverted** · `TheoremHolds`	`0x47ef93bf…62bb`	11951214	195,480
BM2	…and with a 170 tUSD netting that cancels 1 tUSD more of Northwind's debt to QED	Mallory	**reverted** · `NetPositionChanged`	`0xd5124345…af2a`	11951215	195,480

Set-up transactions of this run (faucet draws, approvals): `0xe8c1aa8a…8086`, `0xa6c497bf…ba06`, `0x0d750770…6e7a`, `0x52b9a61f…2552`, `0x1f93f3a3…93a7`, `0x37f9ba83…feb2`.

Run 4 — best execution, proved at the instant of the trade (QEDExecution)

> `evidence/ethereum-sepolia/execution/manifest.json`, `receipts.json`, `records/`. Run 4 deploys five constant-product venues, a second QEDVault as the euro reserve and the QEDExecution module; Run 4b adds ExecutionBounty; Run 4c runs a standing owner-signed treasury policy. `npm run verify` recomputes every accepted trade's bound from the pre-trade reserves, replays the route, solves independently, and checks the bounty pool and the policy's target.

Blocks	11,952,692 → 11,954,086
Transactions	73 (58 succeeded · 15 reverted **by design**)
E1	20.000000 tUSD → **18.086846 tEUR**; on-chain bound 18.086849
E2	20.000000 tUSD → **17.612720 tEUR**; on-chain bound 17.612723
Policy tick 1	reserve free 20.699566 tEUR, shortfall 24.300434: convert 19.535234 tUSD (limited by impact, 150.0 bps)
Policy tick 2	reserve free 37.515664 tEUR, shortfall 7.484336: convert 8.835281 tUSD (limited by need, 90.0 bps)
Policy tick 3	reserve free 45.000000 tEUR, shortfall 0.000000: nothing to do
ExecutionBounty	1000.000000 tUSD unclaimed after 3 refutation attempts
QEDExecution token holdings at the end of Run 4 (re-checked after Run 4c by `npm run verify`)	usd 0 · eur 0 · eth 0 (nothing stranded)

Contract	Address
QEDExecution	`0x8e2ed1ca426c7961a7ee1ecb6cef5d1fbf1f9481`
QEDVault — tUSD treasury	`0x04d1ef625ad58e3641032267a8f4fb7bc191d117`
QEDVault — euro reserve	`0x6fb7178744fa0b76be8ec9bb58a262e541bd9c53`
ExecutionBounty	`0x3148f3710f4e4f700dbf359f63e9e116e6e319c4`
TestToken tEUR · tETH	`0x98D1A388120e5A535341532047B604655fe1362F` · `0xF61C0459cb436Ae760B3af0e58700e9df046580f`
CPMMPool venue 0	`0xf88d53902b9ddf1abf20cfc020a03affa9298a58`
CPMMPool venue 1	`0x1fd2928ce46c29623ed72a1134a761c2a3536031`
CPMMPool venue 2	`0x442229dacb4dc05689f95138017d9ea2020d829b`
CPMMPool venue 3	`0x70674a53cd7f1e46d1d10bb17c6007d458ebdbfa`
CPMMPool venue 4	`0x81557a91d28ce0b17f475466a2b7e3edb8541c64`

Role	Address
deployer	`0x94C938E642BbC657D5F45546E35268a70c936448`
owner	`0x9c61629911658eDf3Fe27415bdD48baaFBc188d4`
operator	`0x0A6A9db9C72afB3d5fD5f2c35E2376eE4aF6bC00`
cosigner	`0x6C34ddDB7AAcf80348c0CCC7F24Ce66285e52b96`
guardian	`0x37e2A6AE45c9d546Fe27ed023eCB6893028b590a`
lp1	`0x16E4CdBA0A1704960d90BbCFd4F8849E2B1a9bC2`
lp2	`0x8f45490746F6704224D89D20911bB2aE93063d0a`
lp3	`0xA5FC8fA91280cF2d15DFf3D8EF9FE797952725dC`
mallory	`0x56D161255Ced6863698eA3c6a886982088fa30a8`

Role	Address
cloudco	`0x0418CfE812572f01535Fb260b6a77dAb5704D737`
lp4	`0xbfcD82dEeB70295775F60DF4Eb5fcC19B96206E4`

Step	What happened	Actor	Result	Transaction	Block	Gas
D1	Deploy tEUR, a valueless 6-decimal test euro	Deployer	success	`0x6d5d2d62…8e2a`	11952692	3,262,131
D2	Deploy tETH, an 18-decimal bridge asset	Deployer	success	`0x9333bcb3…3d1e`	11952692	3,262,143
D3	Deploy venue 0: tUSD/tEUR · 0.30% · deep	Deployer	success	`0x94d0cad8…210f`	11952692	3,632,106
D4	Deploy venue 1: tUSD/tEUR · 0.05% · thin	Deployer	success	`0xc895f898…08fd`	11952692	3,632,106
D5	Deploy venue 2: tUSD/tETH · 0.30%	Deployer	success	`0xd6e045cf…d649`	11952692	3,632,106
D6	Deploy venue 3: tETH/tEUR · 0.30%	Deployer	success	`0x75492715…ef9c`	11952692	3,632,115
D7	Deploy venue 4: tUSD/tEUR · 1.00% · off-market	Deployer	success	`0xe0f6e4ab…471f`	11952692	3,632,106
D8	Deploy QED's tUSD treasury vault (the unchanged QEDVault)	Deployer	success	`0x5f487d96…1211`	11952692	14,963,220
D9	Deploy the euro reserve: a second QEDVault, denominated in tEUR, with a zero agent cap	Deployer	success	`0x31c372f4…ee83`	11952692	14,855,264
D10	Deploy QEDExecution for the treasury vault (operator: the AI's hot key)	Deployer	success	`0x95e8c3d7…80dd`	11952692	15,330,304
G1	Deployer sends 0.003 Sepolia ETH for gas to owner	Deployer	success	`0x61288f9d…879b`	11952692	204,600
G2	Deployer sends 0.006 Sepolia ETH for gas to operator	Deployer	success	`0x890726e1…16cf`	11952692	204,600
G3	Deployer sends 0.002 Sepolia ETH for gas to lp1	Deployer	success	`0x9482ebd9…1fd2`	11952692	204,600
G4	Deployer sends 0.002 Sepolia ETH for gas to lp2	Deployer	success	`0x8a2cc19f…f742`	11952692	204,600
G5	Deployer sends 0.002 Sepolia ETH for gas to lp3	Deployer	success	`0xee0c11c6…e06d`	11952692	204,600
O1	Owner makes QEDExecution the treasury vault's agent (key rotation, on-chain)	Owner	success	`0x153b711e…b783`	11952693	31,788
O2	Owner names the five venues the agent may trade on	Owner	success	`0x73b74ce0…2fa4`	11952693	1,938,167
L1	LP1 draws 1,000 tUSD from the public faucet	LP1	success	`0x80d37572…c8b5`	11952694	250,123
L2	LP2 draws 1,000 tUSD from the public faucet	LP2	success	`0xb6709fef…2a1e`	11952695	250,123
L3	LP3 draws 1,000 tUSD from the public faucet	LP3	success	`0xbbbdd17f…a397`	11952696	250,123
L4	LP1 provides 800.00 tUSD to venue 0	LP1	success	`0x127040b3…c893`	11952697	140,534
L5	Deployer mints 736.00 tEUR into venue 0	Deployer	success	`0x9c40e292…d7be`	11952698	238,168
L6	Venue 0 syncs its reserves	Deployer	success	`0x4006dd81…3ffa`	11952698	140,901

Step	What happened	Actor	Result	Transaction	Block	Gas
L7	LP2 provides 250.00 tUSD to venue 1	LP2	success	`0x4288f8c4…03d9`	11952699	140,546
L8	Deployer mints 230.125 tEUR into venue 1	Deployer	success	`0x7ad7b7c2…ea17`	11952702	140,260
L9	Venue 1 syncs its reserves	Deployer	success	`0x6ba013a7…c546`	11952702	140,901
L10	LP2 provides 600.00 tUSD to venue 2	LP2	success	`0x430efc9f…3cda`	11952703	140,534
L11	Deployer mints 0.20 tETH into venue 2	Deployer	success	`0x9649968b…3872`	11952704	238,204
L12	Venue 2 syncs its reserves	Deployer	success	`0x401d280e…7e71`	11952704	140,901
L13	Deployer mints 0.30 tETH into venue 3	Deployer	success	`0xed23831f…84d9`	11952704	140,284
L14	Deployer mints 828.15 tEUR into venue 3	Deployer	success	`0x3438a671…2715`	11952704	140,260
L15	Venue 3 syncs its reserves	Deployer	success	`0xbd65d9a8…4c5d`	11952704	140,879
L16	LP3 provides 300.00 tUSD to venue 4	LP3	success	`0x3bda0847…164c`	11952705	140,534
L17	Deployer mints 268.50 tEUR into venue 4	Deployer	success	`0x84ea56c6…1eb1`	11952706	140,248
L18	Venue 4 syncs its reserves	Deployer	success	`0x3c8cd82d…81a3`	11952706	140,901
L19	LP3 funds QED's treasury vault with 100 tUSD	LP3	success	`0x88e9ec45…e9de`	11952707	140,534
L20	LP3 sends Mallory 100 tUSD	LP3	success	`0xf65b9e59…5180`	11952707	42,614
A0	Owner signs the trading mandate: payees = execution module, euro reserve, CloudCo; ≤ 25 tUSD per conversion, ≤ 100 a day	Owner	off-chain	—		
A1	Owner: “Move 20 tUSD of this month's revenue into the euro reserve — CloudCo's euro invoices are due next week.”	Owner → language model → guard	off-chain	—		
A2	Owner confirms; the co-signer re-quotes on its own (18.086846 tEUR) and signs an order with floor 17.905977 and τ = 1 ppm	Owner, then co-signer	off-chain	—		
A3	Agent plans: 4 hops through 4 venues, expected 18.086846 tEUR; on-chain bound 18.086849	QED agent	off-chain	—		
E1	Agent converts 20 tUSD → 18.086846 tEUR into the euro reserve; the chain checks the proof: bound 18.086849	QED agent (operator key)	success	`0x56f798cd…9690`	11952708	1,122,781
R1	Owner ring-fences 15 tEUR in the euro reserve for CloudCo's invoice, due in 7 days	Owner	success	`0xa37131fa…791d`	11952709	800,257
A4	Owner: “Top up the euro reserve with another 20 tUSD.”	Owner → language model → guard	off-chain	—		
A5	Owner confirms; the co-signer re-quotes on its own (17.61272 tEUR) and signs an order with floor 17.436592 and τ = 1 ppm	Owner, then co-signer	off-chain	—		
A6	Honest plan for order 2: 17.61272 tEUR, bound 17.612723; floor 17.436592	QED agent	off-chain	—		

Step	What happened	Actor	Result	Transaction	Block	Gas
EA1	Route over the direct pools only, optimally split: 17.5541 tEUR (−33.28 bps, above the 1% floor)	Compromised agent (operator key)	**reverted** · `NotBestExecution`	`0xccd07d17…4937`	11952710	508,799
EA2	Skim: the optimal route with 5% of one leg moved (−0.47 bps)	Compromised agent (operator key)	**reverted** · `NotBestExecution`	`0xe9d68952…7b90`	11952710	650,809
EA3	A “forged proof”: prices chosen to make the single-pair route look optimal	Compromised agent (operator key)	**reverted** · `NotBestExecution`	`0x0b459146…8472`	11952710	508,799
EA4	Strand the bridge token: buy tETH and never sell it	Compromised agent (operator key)	**reverted** · `Leftover`	`0x3a957099…4e58`	11952710	581,568
EA5	Everything through one pool: 17.404968 tEUR (−117.96 bps)	Compromised agent (operator key)	**reverted** · `InsufficientOutput`	`0x565d52b6…15e1`	11952710	378,278
EA6	Redirect the order's output to Mallory	Compromised agent (operator key)	**reverted** · `OrderMismatch`	`0x7e317abb…7066`	11952710	154,520
EA7	Mallory calls the module directly with the genuine order	Mallory	**reverted** · `NotOperator`	`0xf6423a13…1545`	11952711	154,520
E2	Same order, honest route: 17.61272 tEUR, bound 17.612723: accepted	QED agent (operator key)	success	`0xbd051424…0e6f`	11952712	667,936
A7	Owner: “And put another 20 tUSD into the euro reserve.”	Owner → language model → guard	off-chain	—		
A8	Owner confirms; the co-signer re-quotes on its own (17.213445 tEUR) and signs an order with floor 17.04131 and τ = 1 ppm	Owner, then co-signer	off-chain	—		
A9	Agent signs its plan for order 3: 17.213445 tEUR expected, floor 17.04131	QED agent	off-chain	—		
M1	Mallory front-runs: sends 30.00 tUSD to venue 0	Mallory	success	`0xcde2feff…c382`	11952713	42,626
M2	…and takes 25.196509 tEUR out of venue 0	Mallory	success	`0xa471900c…9858`	11952713	171,384
M3	Mallory front-runs: sends 10.00 tUSD to venue 1	Mallory	success	`0x245ed560…c8ae`	11952713	42,614
M4	…and takes 8.379134 tEUR out of venue 1	Mallory	success	`0x1123ac59…9bf7`	11952713	73,452
EA8	The agent's signed trade lands after the front-run: it would now yield 16.473967 tEUR	QED agent (operator key)	**reverted** · `InsufficientOutput`	`0xaa364d64…16d1`	11952714	650,553
A10	Agent re-plans on the moved market (16.920559 tEUR at best) and declines to trade	QED agent	off-chain	—		
XB1	Deploy ExecutionBounty on the live QEDExecution	Deployer	success	`0x35827387…01f2`	11952779	5,997,780
XB2	Deployer sends Sepolia ETH for gas to a fourth liquidity provider	Deployer	success	`0xa0b2f08b…1baf`	11952780	204,600
XB3	LP4 draws 1,000 tUSD from the public faucet	LP4	success	`0xc48900c2…d4b2`	11952781	250,123
XB4	LP4 funds the execution bounty: 1,000 tUSD	LP4	success	`0x66d22910…b780`	11952781	128,918
XA1	Mallory claims with the optimal route for 20 tUSD (16.920559 tEUR) and its own price proof	Mallory	**reverted** · `TheoremHolds`	`0x05813963…6b4e`	11952782	550,183
XA2	…with prices lowered 3% to shrink the bound	Mallory	**reverted** · `TheoremHolds`	`0x3624e169…a809`	11952782	380,442

Step	What happened	Actor	Result	Transaction	Block	Gas
XA3	…with the whole 1,000 tUSD pool in one optimal trade (535.11 tEUR)	Mallory	**reverted** · `TheoremHolds`	`0xdc6140ae…b3e2`	11952782	520,345
MU1	Mallory unwinds: returns 25.196509 tEUR to venue 0	Mallory	success	`0x1cdbba5d…dfbc`	11953421	42,560
MU2	…and takes 29.826566 tUSD back out of venue 0	Mallory	success	`0x06a46723…5329`	11953421	73,509
MU3	Mallory unwinds: returns 8.379134 tEUR to venue 1	Mallory	success	`0x6165abf0…7ebe`	11953421	34,039
MU4	…and takes 9.990375 tUSD back out of venue 1	Mallory	success	`0x3bf2e870…9000`	11953421	73,497
P0	Owner signs a standing policy: keep ≥ 45.00 tEUR free in the euro reserve; tranches of 2.00–25.00 tUSD; ≤ 1.5% execution cost	Owner	off-chain	—		
PA1	An over-eager agent asks to convert 25.00 tUSD at once; the co-signer re-derives 19.535234 and refuses	Co-signer	off-chain	—		
T1	Agent observes 20.699566 tEUR free (short 24.300434) and decides to convert 19.535234 tUSD now — limited by impact	QED agent	off-chain	—		
C1	Co-signer re-derives the same decision from the chain and signs the order (floor 16.647937 tEUR, τ = 1 ppm)	Co-signer	off-chain	—		
PE1	Agent converts 19.535234 tUSD → 16.816098 tEUR; bound 16.816101; reserve free 20.699566 → 37.515664	QED agent (operator key)	success	`0xaaa0bacd…c9ff`	11953422	667,936
T2	Agent observes 37.515664 tEUR free (short 7.484336) and decides to convert 8.835281 tUSD now — limited by need	QED agent	off-chain	—		
C2	Co-signer re-derives the same decision from the chain and signs the order (floor 7.409492 tEUR, τ = 1 ppm)	Co-signer	off-chain	—		
PE2	Agent converts 8.835281 tUSD → 7.484336 tEUR; bound 7.484339; reserve free 37.515664 → 45.00	QED agent (operator key)	success	`0xa9e90f58…ae35`	11953422	667,948
T3	Agent observes 45.00 tEUR free: target met, nothing to do	QED agent	off-chain	—		
QD1	Deploy QEDTreasuryPolicy: the owner's standing policy, enforced by the chain	Deployer	success	`0xcea932ac…5d54`	11954079	9,691,312
QD2	Owner sets the policy on-chain: keep ≥ 55.00 tEUR free; tranches 2.00–25.00 tUSD; ≤ 1.5% execution cost; at most 0.1% over-conversion	Owner	success	`0x5fb70f5f…fff5`	11954080	576,618
QD3	Owner makes the policy contract QEDExecution's operator	Owner	success	`0x9b4a8ef6…4f3b`	11954081	35,295
QP0	Owner signs the same policy as text for the co-signer	Owner	off-chain	—		
QT1	Agent observes 45.00 tEUR free (short 10.00) and decides to convert 11.943294 tUSD — limited by need	QED agent	off-chain	—		
QC1	Co-signer re-derives the same tranche and signs the order (floor 9.90 tEUR, τ = 1 ppm)	Co-signer	off-chain	—		
QA1	The agent's key calls QEDExecution.trade directly with the genuine co-signed order	Attacker (agent key + co-signer key)	**reverted** · `NotOperator`	`0x39093e14…4a9f`	11954082	154,520

Step	What happened	Actor	Result	Transaction	Block	Gas
QA2	Convert 14.929117 tUSD when 11.943294 covers the shortfall (best-executed, co-signed with the stolen key)	Attacker (agent key + co-signer key)	**reverted** · `OverConversion`	`0xb49d0c4f…f9f3`	11954083	713,606
QA3	Convert the maximum tranche, 25.00 tUSD, into the thin market	Attacker (agent key + co-signer key)	**reverted** · `ExecutionCostTooHigh`	`0xc5760e24…2be9`	11954084	713,144
QE1	Agent converts 11.943294 tUSD → 10.00 tEUR through the policy contract; reserve free 45.00 → 55.00	QED agent (operator key)	success	`0x12739525…41c8`	11954085	718,374
QT2	Agent observes 55.00 tEUR free: target met, nothing to do	QED agent	off-chain	—		
QA4	With the target met, convert another 2.00 tUSD anyway	Attacker (agent key + co-signer key)	**reverted** · `NoShortfall`	`0x2c68af03…245e`	11954086	154,520

How these transactions were produced — full disclosure

Signed in a build sandbox without RPC egress against a wall-clock-synchronised replica of Sepolia (same chain id, nonces, balances); the identical signed bytes were broadcast via a browser relay and every public receipt compared with the replica (status + logs). The final phase was executed after rebuilding the replica by replaying the exact signed transactions already on Sepolia.

- The relay fetched `relay/outbox-11155111.json`, `relay/outbox-11155111-b2.json`, `relay/outbox-11155111-clearing.json`, `relay/outbox-11155111-private.json` and the three `relay/outbox-11155111-execution*.json` files from a **pinned commit** of this repository and broadcast the bytes unchanged; the transaction hashes in this file are therefore the hashes of those exact bytes.
- Each public receipt was compared with the replica's receipt: 55/55 receipts matched the replica (status + logs; EIP-7708 system logs excluded); clearing run: 44/44 receipts matched the replica (status + logs; EIP-7708 system logs excluded); private run: 24/24 receipts matched; best-execution runs: 73/73 receipts matched the replica (status + logs; EIP-7708 system logs excluded); Runs 4b–4d first replayed the earlier runs' signed bytes on the replica (4d at their original timestamps).
- Block timestamps differ by seconds between replica and Sepolia; no assertion depends on them (windows are 24 h, certificates live 2 h, deadlines are days).
- Two earlier attempts under different keys failed and were abandoned: the first ran out of gas on deployment under Sepolia's state-creation repricing; in the second, one agent payment was under-provisioned with gas. The vault was slimmed (via-IR; views moved to QEDLens), every transaction now carries an explicit 16.7 M gas limit (only gas used is charged), and the canonical run above was executed under **fresh keys**, so it shares no state with those attempts.
- Gas used on Sepolia differs from the replica because Sepolia prices state creation and calldata differently; the relay compared status and logs, not gas.

Block timestamps

First: block 11948657 at 2026-10-19T14:06:36Z · last: block 11949339 at 2026-10-19T16:24:36Z.